



101~200

▼ 1

▼ 英文:

A security engineer wants to use Amazon Simple Notification Service (Amazon SNS) to send email alerts to a company's security team for Amazon GuardDuty findings that have a High severity level. The security engineer also wants to deliver these findings to a visualization tool for further examination.

Which solution will meet these requirements?

A. Set up GuardDuty to send notifications to an Amazon CloudWatch alarm with two targets in CloudWatch. From CloudWatch, stream the findings through Amazon Kinesis Data Streams into an Amazon Open Search Service domain as the first target for delivery. Use Amazon QuickSight to visualize the findings. Use OpenSearch queries for further analysis.

Deliver email alerts to the security team by configuring an SNS topic as a second target for the CloudWatch alarm. Use event pattern matching with an Amazon EventBridge event rule to send only High severity findings in the alerts.

B. Set up GuardDuty to send notifications to AWS CloudTrail with two targets in CloudTrail. From CloudTrail, stream the findings through Amazon Kinesis Data Firehose into an Amazon OpenSearch Service domain as the first target for delivery.

Use OpenSearch Dashboards to visualize the findings. Use OpenSearch queries for further analysis. Deliver email alerts to the security team by configuring an SNS topic as a second target for CloudTrail. Use event pattern matching with a CloudTrail event rule to send only High severity findings in the alerts.

C. Set up GuardDuty to send notifications to Amazon EventBridge with two targets. From EventBridge, stream the findings through Amazon Kinesis Data Firehose into an Amazon OpenSearch Service domain as the first target for delivery.

Use OpenSearch Dashboards to visualize the findings. Use OpenSearch queries for further analysis. Deliver email alerts to the security team by configuring an SNS topic as a second target for EventBridge. Use event pattern matching with an EventBridge event rule to send only High severity findings in the alerts.

D. Set up GuardDuty to send notifications to Amazon EventBridge with two targets. From EventBridge, stream the findings through Amazon Kinesis Data Streams into an Amazon OpenSearch Service domain as the first target for delivery. Use Amazon QuickSight to visualize the findings. Use OpenSearch queries for further analysis. Deliver email alerts to the security team by configuring an SNS topic as a second target for EventBridge. Use event pattern matching with an EventBridge event rule to send only High severity findings in the alerts.

▼ 中文:

一位安全工程师希望使用 Amazon Simple Notification Service (Amazon SNS) 向公司安全团队发送电子邮件警报，内容为 Amazon GuardDuty 的高严重性级别发现。安全工程师还希望将这些发现传递到一个可视化工具以进行进一步检查。

哪种解决方案可以满足这些需求？

A. 设置 GuardDuty 将通知发送到 Amazon CloudWatch 警报，并在 CloudWatch 中设置两个目标。从 CloudWatch，通过 Amazon Kinesis Data Streams 将发现流式传输到 Amazon OpenSearch Service 域作为第一个交付目标。使用 Amazon QuickSight 可视化这些发现。使用 OpenSearch 查询进行进一步分析。通过为 CloudWatch 警报配置 SNS 主题作为第二个目标，向安全团队发送电子邮件警报。使用 Amazon EventBridge 事件规则的事件模式匹配，仅在警报中发送高严重性发现。

B. 设置 GuardDuty 将通知发送到 AWS CloudTrail，并在 CloudTrail 中设置两个目标。从 CloudTrail，通过 Amazon Kinesis Data Firehose 将发现流式传输到 Amazon OpenSearch Service 域作为第一个交付目标。使用 OpenSearch Dashboards 可视化这些发现。使用 OpenSearch 查询进行进一步分析。通过为 CloudTrail 配置 SNS 主题作为第二个目标，向安全团队发送电子邮件警报。使用 CloudTrail 事件规则的事件模式匹配，仅在警报中发送高严重性发现。

C. 设置 GuardDuty 将通知发送到 Amazon EventBridge，并设置两个目标。从 EventBridge，通过 Amazon Kinesis Data Firehose 将发现流式传输到 Amazon OpenSearch Service 域作为第一个交付目标。使用 OpenSearch Dashboards 可视化这些发现。使用 OpenSearch 查询进行进一步分析。通过为 EventBridge 配置 SNS 主题作为第二个目标，向安全团队发送电子邮件警报。使用 EventBridge 事件规则的事件模式匹配，仅在警报中发送高严重性发现。

D. 设置 GuardDuty 将通知发送到 Amazon EventBridge，并设置两个目标。从 EventBridge，通过 Amazon Kinesis Data Streams 将发现流式传输到 Amazon OpenSearch Service 域作为第一个交付目标。使用 Amazon QuickSight 可视化这些发现。使用 OpenSearch 查询进行进一步分析。通过为 EventBridge 配置 SNS 主题作为第二个目标，向安全团队发送电子邮件警报。使用 EventBridge 事件规则的事件模式匹配，仅在警报中发送高严重性发现。

▼ 答案:

C

1. 考察的知识点

Amazon GuardDuty的通知机制

Amazon EventBridge的事件路由和模式匹配

Amazon SNS的邮件通知功能

Amazon Kinesis Data Firehose与OpenSearch的集成

OpenSearch Dashboards的可视化功能

2. 选项分析

A. 错误

此选项提到使用CloudWatch警报作为通知机制，但GuardDuty无法直接发送通知到CloudWatch警报。虽然可以通过Kinesis Data Streams将数据传输到OpenSearch并使用QuickSight进行可视化，但这不是最佳实践。此外，EventBridge事件规则更适合处理事件模式匹配。

B. 错误

此选项提到使用CloudTrail作为通知机制，但GuardDuty无法直接发送通知到CloudTrail。CloudTrail主要用于记录API调用，而不是事件路由。虽然Kinesis Data Firehose和OpenSearch的集成是正确的，但整体流程不符合要求。

C. 正确

此选项使用Amazon EventBridge作为事件路由工具，这是GuardDuty通知的推荐方式。通过EventBridge，可以设置两个目标：一个是通过Kinesis Data Firehose将数据传输到OpenSearch以进行可视化和分析；另一个是通过SNS发送邮件通知给安全团队。此外，EventBridge支持事件模式匹配，可以过滤出高严重性级别的发现。

D. 错误

此选项虽然使用了EventBridge作为事件路由工具，但提到使用Kinesis Data Streams而不是Kinesis Data Firehose。Kinesis此选项虽然使用了EventBridge作为事件路由工具，但提到使用Kinesis Data Streams而不是Kinesis Data Firehose。Kinesis Data Firehose更适合将数据传输到OpenSearch，因为它支持自动化的数据传输和格式化。此外，QuickSight不是最佳工具来可视化GuardDuty发现，OpenSearch Dashboards更适合此场景。

▼ 2

▼ 英文:

A security engineer needs to implement a write-once-read-many (WORM) model for data that a company will store in Amazon S3 buckets. The company uses the S3 Standard storage class for all of its S3 buckets. The security engineer must ensure that objects cannot be overwritten or deleted by any user, including the AWS account root user.

Which solution will meet these requirements?

A. Create new S3 buckets with S3 Object Lock enabled in compliance mode. Place objects in the S3 buckets.

B. Use S3 Glacier Vault Lock to attach a Vault Lock policy to new S3 buckets. Wait 24 hours to complete the Vault Lock process. Place objects in the S3 buckets.

C. Create new S3 buckets with S3 Object Lock enabled in governance mode. Place objects in the S3 buckets.

D. Create new S3 buckets with S3 Object Lock enabled in governance mode. Add a legal hold to the S3 buckets. Place objects in the S3 buckets.

▼ 中文:

一名安全工程师需要为公司存储在 Amazon S3 存储桶中的数据实施一次写入、多次读取 (WORM) 模型。公司为其所有 S3 存储桶使用 S3 Standard 存储类别。安全工程师必须确保任何用户（包括 AWS 账户根用户）都无法覆盖或删除对象。哪种解决方案可以满足这些要求？

A.创建启用了 S3 Object Lock 合规模式的新 S3 存储桶。将对象放置在 S3 存储桶中。

B.使用 S3 Glacier Vault Lock 将 Vault Lock 策略附加到新的 S3 存储桶。等待 24 小时完成 Vault Lock 过程。将对象放置在 S3 存储桶中。

C.创建启用了 S3 Object Lock 管理模式的新 S3 存储桶。将对象放置在 S3 存储桶中。

D.创建启用了 S3 Object Lock 管理模式的新 S3 存储桶。向 S3 存储桶添加法律保留。将对象放置在 S3 存储桶中。

▼ 答案:

A

1. 考察的知识点

Amazon S3 Object Lock功能及其两种模式（治理模式和合规模式）。
如何实现WORM（Write Once Read Many）模型以保护数据免受删除或覆盖。
理解AWS账户权限，包括AWS账户根用户的权限限制。

2. 选项分析

A. Create new S3 buckets with S3 Object Lock enabled in compliance mode. Place objects in the S3 buckets.

正确：S3 Object Lock的合规模式确保数据无法被任何用户（包括AWS账户根用户）删除或覆盖，完全符合WORM模型的要求。

合规模式是最严格的模式，适用于需要强制执行不可更改性的数据保护场景。

B. Use S3 Glacier Vault Lock to attach a Vault Lock policy to new S3 buckets. Wait 24 hours to complete the Vault Lock process. Place objects in the S3 buckets.

错误：S3 Glacier Vault Lock是针对Amazon S3 Glacier存储库的功能，而题目明确指出公司使用的是S3 Standard存储类，因此此选项不适用。

此外，Vault Lock的功能与S3 Object Lock不同，无法直接满足题目要求。

C. Create new S3 buckets with S3 Object Lock enabled in governance mode. Place objects in the S3 buckets.

错误：治理模式允许特定用户（如AWS账户根用户）通过额外的权限绕过锁定并删除或覆盖对象，因此无法完全满足题目要求。

治理模式适用于需要灵活管理的场景，但不适合需要严格WORM保护的场景。

D. Create new S3 buckets with S3 Object Lock enabled in governance mode. Add a legal hold to the S3 buckets. Place objects in the S3 buckets.

错误：虽然法律保留（Legal Hold）可以防止对象被删除，但它可以被具有适当权限的用户移除，因此无法完全满足题目要求。

治理模式本身也不够严格，无法阻止AWS账户根用户删除或覆盖对象。

▼ 3

▼ 英文:

A company needs complete encryption of the traffic between external users and an application. The company hosts the application on a fleet of Amazon EC2 instances that run in an Auto Scaling group behind an Application Load Balancer (ALB).

How can a security engineer meet these requirements?

A. Create a new Amazon-issued certificate in AWS Secrets Manager. Export the certificate from Secrets Manager. Import the certificate into the ALB and the EC2 instances.

B. Create a new Amazon-issued certificate in AWS Certificate Manager (ACM). Associate the certificate with the ALB. Export the certificate from ACM. Install the certificate on the EC2 instances.

C. Import a new third-party certificate into AWS Identity and Access Management (IAM). Export the certificate from IAM. Associate the certificate with the ALB and the EC2 instances.

D. Import a new third-party certificate into AWS Certificate Manager (ACM). Associate the certificate with the ALB. Install the certificate on the EC2 instances.

▼ 中文:

一家公司需要对外部用户与应用程序之间的流量进行完全加密。该公司将应用程序托管在一个运行在 Auto Scaling 组中的 Amazon EC2 实例群上，并且这些实例位于一个 Application Load Balancer (ALB) 后面。安全工程师如何满足这些要求？

A.在 AWS Secrets Manager 中创建一个新的 Amazon 颁发的证书。从 Secrets Manager 导出证书。将证书导入 ALB 和 EC2 实例。

B.在 AWS Certificate Manager (ACM) 中创建一个新的 Amazon 颁发的证书。将证书与 ALB 关联。从 ACM 导出证书。将证书安装到 EC2 实例上。

C.将一个新的第三方证书导入 AWS Identity and Access Management (IAM)。从 IAM 导出证书。将证书与 ALB 和 EC2 实例关联。

D.将一个新的第三方证书导入 AWS Certificate Manager (ACM)。将证书与 ALB 关联。将证书安装到 EC2 实例上。

▼ 答案:

D

1. 考察的知识点

本题考察的是AWS中如何实现端到端加密（从外部用户到应用程序）以及证书管理的最佳实践。

涉及的服务包括：AWS Certificate Manager (ACM)、Application Load Balancer (ALB)、以及EC2实例的证书安装。

2. 选项分析

A. 错误原因：Secrets Manager不是用于管理SSL/TLS证书的服务。它主要用于存储和管理敏感信息（如密码、API密钥等）。因此，无法通过Secrets Manager创建或管理证书。

B. 部分正确：ACM是用于管理SSL/TLS证书的正确服务，可以将证书关联到ALB。

错误原因：ACM管理的证书无法直接导出到EC2实例。ACM的证书只能用于AWS托管的服务（如ALB、CloudFront等），无法安装到EC2实例上。

C. 错误原因：虽然IAM可以存储SSL/TLS证书，但它不是推荐的证书管理方式。IAM中的证书主要用于API Gateway或CloudFront，而不是ALB或EC2实例。

D. 正确原因：ACM支持导入第三方证书，并可以将证书关联到ALB以实现外部用户到ALB的加密。对于ALB到EC2实例的加密，需要手动将证书安装到EC2实例上。这是实现端到端加密的正确方法。

▼ 4

▼ 英文:

A company has an organization with SCPs in AWS Organizations. The root SCP for the organization is as follows:

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowsAllActions",
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    },
    {
      "Sid": "DenySES",
      "Effect": "Deny",
      "Action": "ses:*",
      "Resource": "*"
    }
  ]
}

```

The company's developers are members of a group that has an IAM policy that allows access to Amazon Simple Email Service (Amazon SES) by allowing ses:* actions. The account is a child to an OU that has an SCP that allows Amazon SES. The developers are receiving a not-authorized error when they try to access Amazon SES through the AWS Management Console. Which change must a security engineer implement so that the developers can access Amazon SES?

- A. Add a resource policy that allows each member of the group to access Amazon SES.
- B. Add a resource policy that allows "Principal": {"AWS": "arn:aws:iam :account-number:group/Dev"}.
- C. Remove the AWS Control Tower control (guardrail) that restricts access to Amazon SES.
- D. Remove Amazon SES from the root SCP.

▼ 中文:

一家公司在其 AWS Organizations 中使用了 SCPs。该组织的根 SCP 如下：


```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowsAllActions",
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    },
    {
      "Sid": "DenySES",
      "Effect": "Deny",
      "Action": "ses:*",
      "Resource": "*"
    }
  ]
}

```

公司的开发人员是一个拥有允许通过 ses:* 操作访问 Amazon Simple Email Service (Amazon SES) 的 IAM 策略的组成员。

该账户属于一个有允许 Amazon SES 的 SCP 的 OU 的子账户。当开发人员尝试通过 AWS Management Console 访问 Amazon SES 时，他们收到未授权错误。

安全工程师必须实施哪些更改才能使开发人员能够访问 Amazon SES？

- A. 添加一个资源策略，允许组中的每个成员访问 Amazon SES。
- B. 添加一个资源策略，允许 "Principal": {"AWS": "arn:aws:iam::account-number:group/Dev"}。
- C. 移除限制访问 Amazon SES 的 AWS Control Tower 控制(保护措施)。
- D. 从根 SCP 中移除 Amazon SES。

▼ 答案:

D

1. 考察的知识点

D (100%)

本题考察的是AWS Organizations中的服务控制策略(SCP)的工作机制，以及如何通过SCP限制或允许对AWS服务的访问。

同时涉及IAM策略与SCP的交互关系，以及权限的最终评估逻辑。

2. 选项分析

A. 添加一个资源策略，允许组中的每个成员访问 Amazon SES。

错误:资源策略是针对具体资源的，而SCP是组织级别的权限控制。即使添加资源策略，SCP的“Deny”仍然会优先生效，导致权限被拒绝。

B. 添加一个资源策略，允许 "Principal": {"AWS": "arn:aws:iam::account-number:group/Dev"}。

错误:同样，资源策略无法覆盖SCP的“Deny”规则。SCP的“Deny”优先级高于IAM策略和资源策略。

C. 移除限制访问 Amazon SES 的 AWS Control Tower 控制(保护措施)。

错误:题目中并未提到AWS Control Tower的保护措施(Guardrails)限制了Amazon SES的访问，因此这个选项与题目无关。

D. 从根 SCP 中移除 Amazon SES。

正确:根SCP中明确“Deny”了对Amazon SES的访问，这会覆盖所有子OU和账户的权限。移除该“Deny”规则后，IAM策略和子OU的SCP将能够生效，从而允许开发者访问Amazon SES。

▼ 5

▼ 英文:

A company hosts a public website on an Amazon EC2 instance. HTTPS traffic must be able to access the website. The company uses SSH for management of the web server.

The website is on the subnet 10.0.1.0/24. The management subnet is 192.168.100.0/24. A security engineer must create a security group for the EC2 instance.

Which combination of steps should the security engineer take to meet these requirements in the MOST secure manner? (Choose two.)

A. Allow port 22 from source 0.0.0.0/0.

B. Allow port 443 from source 0.0.0.0/0.

C. Allow port 22 from 192.168.100.0/24.

D. Allow port 22 from 10.0.1.0/24.

E. Allow port 443 from 10.0.1.0/24.

▼ 中文:

一家公司在 Amazon EC2 实例上托管了一个公共网站。HTTPS 流量必须能够访问该网站。公司使用 SSH 来管理 Web 服务器。

该网站位于子网 10.0.1.0/24。管理子网为 192.168.100.0/24。一名安全工程师必须为 EC2 实例创建一个安全组。安全工程师应该采取哪些步骤以最安全的方式满足这些要求?(选择两个)

A. 允许端口 22 从来源 0.0.0.0/0。

- B.允许端口 443 从来源 0.0.0.0/0。
- C.允许端口 22 从 192.168.100.0/24。
- D.允许端口 22 从 10.0.1.0/24。
- E.允许端口 443 从 10.0.1.0/24。

▼ 答案:

1. 考察的知识点

BC (100%)

安全组的配置:如何正确设置安全组规则以确保最小权限原则。

网络安全:限制访问来源以提高安全性。

协议和端口:HTTPS (443) 和 SSH (22) 的正确使用。

2. 选项分析

A. Allow port 22 from source 0.0.0.0/0.

错误:允许所有来源访问端口 22(SSH)是非常不安全的做法，因为它会暴露服务器给所有外部网络，增加被攻击的风险。

B. Allow port 443 from source 0.0.0.0/0.

正确:HTTPS 是用于公共访问的协议，允许所有来源访问端口 443是合理的，因为网站是公共的。

C. Allow port 22 from 192.168.100.0/24.

正确:限制 SSH 访问到管理子网(192.168.100.0/24)符合最小权限原则，确保只有管理网络可以访问 SSH。

D. Allow port 22 from 10.0.1.0/24.

错误:10.0.1.0/24 是网站所在的子网，而不是管理子网。SSH 访问应该限制到管理子网，而不是网站子网。

E. Allow port 443 from 10.0.1.0/24.

错误:端口 443 是用于公共访问的协议，限制到 10.0.1.0/24 会阻止外部用户访问网站。

▼ 6

▼ 英文:

A security engineer wants to forward custom application-security logs from an Amazon EC2 instance to Amazon CloudWatch.

The security engineer installs the CloudWatch agent on the EC2 instance and adds the path of the logs to the CloudWatch configuration file.

However, CloudWatch does not receive the logs. The security engineer verifies that the awslogs service is running on the EC2 instance.

What should the security engineer do next to resolve the issue?

- A. Add AWS CloudTrail to the trust policy of the EC2 instance. Send the custom logs to CloudTrail instead of CloudWatch.
- B. Add Amazon S3 to the trust policy of the EC2 instance. Configure the application to write the custom logs to an S3 bucket that CloudWatch can use to ingest the logs.
- C. Add Amazon Inspector to the trust policy of the EC2 instance. Use Amazon Inspector instead of the CloudWatch agent to collect the custom logs.
- D. Attach the CloudWatchAgentServerPolicy AWS managed policy to the EC2 instance role.

▼ 中文:

一位安全工程师希望将自定义应用程序安全日志从 Amazon EC2 实例转发到 Amazon CloudWatch。安全工程师在 EC2 实例上安装了 CloudWatch agent，并将日志路径添加到 CloudWatch 配置文件中。然而，CloudWatch 并未接收到日志。安全工程师验证了 `awslogs` 服务正在 EC2 实例上运行。安全工程师接下来应该做什么来解决这个问题？

- A.将 AWS CloudTrail 添加到 EC2 实例的信任策略中。将自定义日志发送到 CloudTrail 而不是 CloudWatch。
- B.将 Amazon S3 添加到 EC2 实例的信任策略中。配置应用程序将自定义日志写入 CloudWatch 可用于摄取日志的 S3 bucket。
- C.将 Amazon Inspector 添加到 EC2 实例的信任策略中。使用 Amazon Inspector 而不是 CloudWatch agent 来收集自定义 日志。
- D.将 CloudWatchAgentServerPolicy AWS 托管策略附加到 EC2 实例角色。

▼ 答案:

D

A.

错误:CloudTrail 是用于记录 API 调用的服务，而不是用于收集 EC2 实例上的自定义应用日志。将日志发送到CloudTrail与题目要求不符。

B.

错误:虽然可以将日志写入 S3 并通过 CloudWatch Logs 进行摄取，但这不是题目要求的解决方案。题目明确要求使用CloudWatch Agent，而不是通过 S3。

C

错误:Amazon Inspector 是用于安全漏洞扫描的服务，与日志收集无关。使用 Inspector 代替 CloudWatch Agent 不符合题目要求。

D.

正确:CloudWatchAgentServerPolicy 是 AWS 提供的托管策略，允许 EC2 实例通过

CloudWatch Agent 将日志发送到CloudWatch。没有正确的 IAM 权限，CloudWatch Agent 无法正常工作。

▼ 7

▼ 英文:

A systems engineer is troubleshooting the connectivity of a test environment that includes a virtual security appliance deployed inline. In addition to using the virtual security appliance, the development team wants to use security groups and network ACLs to accomplish various security requirements in the environment.

What configuration is necessary to allow the virtual security appliance to route the traffic?

- A. Disable network ACLs.
- B. Configure the security appliance's elastic network interface for promiscuous mode.
- C. Disable the Network Source/Destination check on the security appliance's elastic network interface.
- D. Place the security appliance in the public subnet with the internet gateway.

▼ 中文:

一位系统工程师正在排查包含一个内置虚拟安全设备的测试环境的连接问题。除了使用虚拟安全设备外，开发团队还 希望使用安全组和网络ACL来满足环境中的各种安全需求。

什么配置是必要的以允许虚拟安全设备路由流量？

- A. 禁用网络ACL。
- B. 将安全设备的弹性网络接口配置为混杂模式。
- C. 在安全设备的弹性网络接口上禁用网络源/目标检查。
- D. 将安全设备放置在带有互联网网关的公共子网中。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS网络配置中的“源/目标检查”功能，以及如何配置虚拟安全设备(如防火墙或入侵检测系统)以正确路由流量。

还涉及到安全组和网络ACL的基本功能和使用场景。

2. 选项分析

A. Disable network ACLs. 禁用网络ACL。

错误。网络ACL是用于控制子网级别的入站和出站流量的工具，禁用它不会解决虚拟

安全设备的路由问题。

网络ACL的存在与否不会影响虚拟安全设备的流量处理能力。

B. 将安全设备的弹性网络接口配置为混杂模式。

错误。AWS的弹性网络接口(ENI)不支持混杂模式。混杂模式通常用于捕获网络流量，但与路由流量无关。

此选项在AWS环境中不可行。

C. 在安全设备的弹性网络接口上禁用网络源/目标检查。

正确。默认情况下，AWS会启用“源/目标检查”，以确保流量的源和目标地址与实例的网络接口匹配。

对于虚拟安全设备(如防火墙或路由器)，需要禁用此检查，以允许设备处理和转发流量，而不是仅仅接收或发送与自身相关的流量。

D. 将安全设备放置在带有互联网网关的公共子网中。

错误。将安全设备放置在公共子网中并不会解决路由问题。此选项与流量的源/目标检查无关。

虽然公共子网可以提供互联网访问，但这不是解决虚拟安全设备路由问题的正确方法。

▼ 8

▼ 英文:

A security engineer needs to create an Amazon S3 bucket policy to grant least privilege read access to IAM user accounts that are named User1, User2, and User3. These IAM user accounts are members of the AuthorizedPeople IAM group. The security engineer drafts the following S3 bucket policy:

```
{
  "Version": "2012-10-17",
  "Id": "AuthorizedPeoplePolicy",
  "Statement": [
    {
      "Sid": "Actions-Authorized-People",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject"
      ],
      "Resource": "arn:aws:s3:::authorized-people-bucket/*"
    }
  ]
}
```

When the security engineer tries to add the policy to the S3 bucket, the following error message appears: "Missing required field Principal."

The security engineer is adding a Principal element to the policy. The addition must provide read access to only User1, User2, and User3.

Which solution meets these requirements?

A.

```
"Principal": {
  "AWS": [
    "arn:aws:iam::1234567890:user/User1",
    "arn:aws:iam::1234567890:user/User2",
    "arn:aws:iam::1234567890:user/User3"
  ]
}
```

B.

```
"Principal": {
  "AWS": [
    "arn:aws:iam::1234567890:root"
  ]
}
```

C.

```
"Principal": {
  "AWS": [
    "*"
  ]
}
```

D.

```
"Principal": {
  "AWS": "arn:aws:iam::1234567890:group/AuthorizedPeople"
}
```

▼ 中文:

一名安全工程师需要创建一个 Amazon S3 bucket 策略，以授予名为 User1、User2 和 User3 的 IAM 用户账户最小权限的读取访问权限。这些 IAM 用户账户是 AuthorizedPeople IAM 组的成员。安全工程师起草了以下 S3 bucket 策略:

```

{
  "Version": "2012-10-17",
  "Id": "AuthorizedPeoplePolicy",
  "Statement": [
    {
      "Sid": "Actions-Authorized-People",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject"
      ],
      "Resource": "arn:aws:s3:::authorized-people-bucket/*"
    }
  ]
}

```

当安全工程师尝试将策略添加到 S3 bucket 时，出现以下错误消息：“缺少必需字段 Principal。”

安全工程师正在向策略中添加一个 Principal 元素。添加的内容必须仅为 User1、User2 和 User3 提供读取访问权限。

哪种解决方案满足这些要求？

A.

```

"Principal": {
  "AWS": [
    "arn:aws:iam::1234567890:user/User1",
    "arn:aws:iam::1234567890:user/User2",
    "arn:aws:iam::1234567890:user/User3"
  ]
}

```

B.

```

"Principal": {
  "AWS": [
    "arn:aws:iam::1234567890:root"
  ]
}

```

C.


```

    "Principal": {
      "AWS": [
        "*"
      ]
    }
  }
}

```

D.

```

"Principal": {  "AWS": "arn:aws:iam::1234567890:group/AuthorizedPeople"
}

```

▼ 答案:

A

1. 考察的知识点

Amazon S3 Bucket Policy的结构与语法，包括必需字段(如Principal)。

如何使用IAM用户和组来实现最小权限访问控制。

如何正确配置S3权限以满足特定的安全需求。

2. 选项分析

A: 正确。此选项正确地添加了Principal字段，并将其设置为AuthorizedPeople IAM组的ARN。这样可以确保只有User1、User2和User3(作为AuthorizedPeople组的成员)能够访问S3资源。

B: 错误。此选项可能遗漏了Principal字段，或者未正确指定IAM组的ARN，导致无法满足题目要求。

C: 错误。此选项可能尝试直接指定User1、User2、User3的ARN，但未使用IAM组的ARN，违反了题目要求的“最小权限”原则。

D: 错误。此选项可能包含语法错误或未正确配置资源路径，导致无法实现预期的访问控制。

▼ 9

▼ 英文:

A security engineer recently rotated all IAM access keys in an AWS account.

The security engineer then configured AWS Config and enabled the following

AWS Config managed rules: mfa-enabled-for-iam-console-access, iam-user-mfa-enabled, access-keys-rotated, and iam-user-unused-credentials-check.

The security engineer notices that all resources are displaying as noncompliant after the IAM GenerateCredentialReport API operation is invoked.

What could be the reason for the noncompliant status?

A. The IAM credential report was generated within the past 4 hours.

- B. The security engineer does not have the GenerateCredentialReport permission.
- C. The security engineer does not have the GetCredentialReport permission.
- D. The AWS Config rules have a MaximumExecutionFrequency value of 24 hours.

▼ 中文:

一名安全工程师最近轮换了 AWS 账户中的所有 IAM 访问密钥。随后，该安全工程师配置了 AWS Config，并启用了以下 AWS Config 托管规则:mfa-enabled-for-iam-console-access、iam-user-mfa-enabled、access-keys-rotated 和 iam-user-unused-credentials-check。

安全工程师注意到，在调用 IAM GenerateCredentialReport API 操作后，所有资源都显示为不合规状态。导致不合规状态的原因可能是什么？

- A.IAM 凭证报告是在过去 4 小时内生成的。
- B.安全工程师没有 GenerateCredentialReport 权限。
- C.安全工程师没有 GetCredentialReport 权限。
- D.AWS Config 规则的 MaximumExecutionFrequency 值为 24 小时。

▼ 答案:

A

1. 考察的知识点

IAM凭证报告的生成和使用。

AWS Config规则的执行频率和合规性检查。

权限相关问题(GenerateCredentialReport和GetCredentialReport)。

2. 选项分析

A. The IAM credential report was generated within the past 4 hours.

正确。AWS Config规则依赖IAM凭证报告来评估资源的合规性。如果IAM凭证报告是在过去4小时内生成的，AWS Config可能无法立即使用最新的报告进行评估，导致所有资源显示为不合规。

B. The security engineer does not have the GenerateCredentialReport permission.

错误。如果安全工程师没有GenerateCredentialReport权限，他们无法生成IAM凭证报告，但题目中明确提到已经调用了GenerateCredentialReport API，因此此选项不正确。

C. The security engineer does not have the GetCredentialReport permission.

错误。如果安全工程师没有GetCredentialReport权限，他们无法获取IAM凭证报告，但题目中没有提到权限问题，且问题的核心是资源显示为不合规，而不是无法获取报告。

D. The AWS Config rules have a MaximumExecutionFrequency value of 24

hours.

错误。虽然AWS Config规则的执行频率可能会影响评估的时间，但题目中没有提到规则的执行频率是问题的原因。问

题的核心是IAM凭证报告的生成时间，而不是规则的执行频率。

▼ 10

▼ 英文:

A company is using AWS WAF to protect a customized public API service that is based on Amazon EC instances. The API uses an Application Load Balancer.

The AWS WAF web ACL is configured with an AWS Managed Rules rule group. After a software upgrade to the API and the client application, some types of requests are no longer working and are causing application stability issues. A security engineer discovers that AWS WAF logging is not turned on for the web ACL.

The security engineer needs to immediately return the application to service, resolve the issue, and ensure that logging is not turned off in the future. The security engineer turns on logging for the web ACL and specifies Amazon CloudWatch Logs as the destination.

Which additional set of steps should the security engineer take to meet the requirements?

A. Edit the rules in the web ACL to include rules with Count actions. Review the logs to determine which rule is blocking the request. Modify the IAM policy of all AWS WAF administrators so that they cannot remove the logging configuration for any AWS WAF web ACLs.

B. Edit the rules in the web ACL to include rules with Count actions. Review the logs to determine which rule is blocking the request. Modify the AWS WAF resource policy so that AWS WAF administrators cannot remove the logging configuration for any AWS WAF web ACLs.

C. Edit the rules in the web ACL to include rules with Count and Challenge actions. Review the logs to determine which rule is blocking the request. Modify the AWS WAF resource policy so that AWS WAF administrators cannot remove the logging configuration for any AWS WAF web ACLs.

D. Edit the rules in the web ACL to include rules with Count and Challenge actions. Review the logs to determine which rule is blocking the request. Modify the IAM policy of all AWS WAF administrators so that they cannot remove the logging configuration for any AWS WAF web ACLs.

▼ 中文:

一家公司正在使用 AWS WAF 来保护基于 Amazon EC 实例的定制公共 API 服务。该 API 使用 Application Load Balancer。

AWS WAF 的 web ACL 配置了一个 AWS Managed Rules 规则组。在对 API 和客户端应用程序进行软件升级后，某些类型的请求不再正常工作，并导致应用程序稳定性问题。安全工程师发现 AWS WAF 的日志记录未为 web ACL 启用。

安全工程师需要立即恢复应用程序服务，解决问题，并确保未来不会关闭日志记录。

安全工程师为 web ACL 启用日志记录，并指定 Amazon CloudWatch Logs 作为目标。

安全工程师还需要采取哪些额外步骤来满足要求？

A. 编辑 web ACL 中的规则以包含具有 Count 操作的规则。查看日志以确定哪个规则阻止了请求。修改所有 AWS WAF 管理员的 IAM 策略，以确保他们无法移除任何 AWS WAF web ACL 的日志记录配置。

B. 编辑 web ACL 中的规则以包含具有 Count 操作的规则。查看日志以确定哪个规则阻止了请求。修改 AWS WAF 资源策略，以确保 AWS WAF 管理员无法移除任何 AWS WAF web ACL 的日志记录配置。

C. 编辑 web ACL 中的规则以包含具有 Count 和 Challenge 操作的规则。查看日志以确定哪个规则阻止了请求。修改 AWS WAF 资源策略，以确保 AWS WAF 管理员无法移除任何 AWS WAF web ACL 的日志记录配置。

D. 编辑 web ACL 中的规则以包含具有 Count 和 Challenge 操作的规则。查看日志以确定哪个规则阻止了请求。修改所有 AWS WAF 管理员的 IAM 策略，以确保他们无法移除任何 AWS WAF web ACL 的日志记录配置。

▼ 答案:

A.

1. 考察的知识点

如何使用 AWS WAF 进行故障排查和日志分析。

如何配置 AWS WAF 的规则以排查问题(Count 操作)。

如何确保 AWS WAF 的日志记录配置不会被移除(IAM 策略或资源策略)。

2. 选项分析

A:

编辑 web ACL 中的规则以包含具有 Count 操作的规则:正确，Count 操作允许记录请求而不阻止它们，从而帮助识别问题规则。

查看日志以确定哪个规则阻止了请求:正确，日志分析是排查问题的关键步骤。

修改所有 AWS WAF 管理员的 IAM 策略，以确保他们无法移除任何 AWS WAF web ACL 的日志记录配置:正确，使用 IAM 策略可以限制管理员权限，防止日志记录被关闭。

B:

编辑 web ACL 中的规则以包含具有 Count 操作的规则:正确。

查看日志以确定哪个规则阻止了请求:正确。

修改 AWS WAF 资源策略，以确保 AWS WAF 管理员无法移除任何 AWS WAF web ACL 的日志记录配置:错误，AWS WAF

资源策略并不是推荐的方式来限制日志记录配置的更改，IAM 策略更适合此场景。

C:

编辑 web ACL 中的规则以包含具有 Count 和 Challenge 操作的规则:错误，

Challenge 操作会向客户端发起挑战(例如

CAPTCHA)，这可能会影响 API 的正常运行，不适合用于故障排查。

查看日志以确定哪个规则阻止了请求:正确。

修改 AWS WAF 资源策略，以确保 AWS WAF 管理员无法移除任何 AWS WAF web ACL 的日志记录配置:错误，原因同选

项 B。

D:

编辑 web ACL 中的规则以包含具有 Count 和 Challenge 操作的规则:错误，原因同选项 C。

查看日志以确定哪个规则阻止了请求:正确。

修改所有 AWS WAF 管理员的 IAM 策略，以确保他们无法移除任何 AWS WAF web ACL 的日志记录配置:正确。

▼ 11

▼ 英文:

A security engineer is creating an AWS Lambda function. The Lambda function needs to use a role that is named LambdaAuditRole to assume a role that is named AcmeAuditFactoryRole in a different AWS account.

When the code is processed, the following error message appears: "An error occurred (AccessDenied) when calling the AssumeRole operation."

Which combination of steps should the security engineer take to resolve this error? (Choose two.)

A. Ensure that LambdaAuditRole has the sts:AssumeRole permission for AcmeAuditFactoryRole.

B. Ensure that LambdaAuditRole has the AWSLambdaBasicExecutionRole managed policy attached.

C. Ensure that the trust policy for AcmeAuditFactoryRole allows the sts:AssumeRole action from LambdaAuditRole.

D. Ensure that the trust policy for LambdaAuditRole allows the sts:AssumeRole action from the lambda.amazonaws.com service.

E. Ensure that the sts:AssumeRole API call is being issued to the us-east-1 Region endpoint.

▼ 中文:

一位安全工程师正在创建一个 AWS Lambda 函数。该 Lambda 函数需要使用名为 LambdaAuditRole 的角色来假设另一个 AWS 账户中名为 AcmeAuditFactoryRole 的角色。当代码被处理时，出现以下错误信息：“调用 AssumeRole 操作时发生错误 (AccessDenied)。”安全工程师应采取哪些步骤组合来解决此错误?(选择两个)

A. 确保 LambdaAuditRole 对 AcmeAuditFactoryRole 拥有 sts:AssumeRole 权限。

B. 确保 LambdaAuditRole 附加了 AWSLambdaBasicExecutionRole 托管策略。

C. 确保 AcmeAuditFactoryRole 的信任策略允许来自 LambdaAuditRole 的 sts:AssumeRole 操作。

D. 确保 LambdaAuditRole 的信任策略允许来自 lambda.amazonaws.com 服务的 sts:AssumeRole 操作。

E. 确保 sts:AssumeRole API 调用是针对 us-east-1 区域端点发出的。

▼ 答案:

AC

1. 考察的知识点

跨账户角色的信任策略配置。

IAM权限管理，包括角色的权限和信任关系。

使用AWS STS服务进行AssumeRole操作。

2. 选项分析

AC (100%)

A. Ensure that LambdaAuditRole has the sts:AssumeRole permission for AcmeAuditFactoryRole.

正确。LambdaAuditRole需要拥有sts:AssumeRole权限才能调用AssumeRole API并成功切换到AcmeAuditFactoryRole。

B. Ensure that LambdaAuditRole has the AWSLambdaBasicExecutionRole managed policy attached.

错误。AWSLambdaBasicExecutionRole托管策略仅提供Lambda函数的基本执行权限(例如日志记录到CloudWatch)，与跨账户AssumeRole操作无关。

C. Ensure that the trust policy for AcmeAuditFactoryRole allows the sts:AssumeRole action from LambdaAuditRole.

正确。AcmeAuditFactoryRole的信任策略必须允许LambdaAuditRole执行 sts:AssumeRole操作，否则跨账户AssumeRole请求会被拒绝。

D. Ensure that the trust policy for LambdaAuditRole allows the sts:AssumeRole action from the lambda.amazonaws.com service.

错误。LambdaAuditRole的信任策略需要允许Lambda服务 (lambda.amazonaws.com)来使用该角色，但这与跨账户 AssumeRole操作无关。

E. Ensure that the sts:AssumeRole API call is being issued to the us-east-1 Region endpoint.

错误。虽然STS服务需要正确的区域端点，但题目中并未提到区域配置问题，且错误信息明确指出是权限问题，而非区域问题。

▼ 12

▼ 英文:

A company has AWS accounts in an organization in AWS Organizations. The organization includes a dedicated security account.

All AWS account activity across all member accounts must be logged and reported to the dedicated security account. The company must retain all the activity logs in a secure storage location within the dedicated security account for 2 years. No changes or deletions of the logs are allowed.

Which combination of steps will meet these requirements with the LEAST operational overhead? (Choose two.)

A. In the dedicated security account, create an Amazon S3 bucket. Configure S3 Object Lock in compliance mode and a retention period of 2 years on the S3 bucket. Set the bucket policy to allow the organization's management account to write to the S3 bucket.

B. In the dedicated security account, create an Amazon S3 bucket. Configure S3 Object Lock in compliance mode and a retention period of 2 years on the S3 bucket. Set the bucket policy to allow the organization's member accounts to write to the S3 bucket.

C. In the dedicated security account, create an Amazon S3 bucket that has an S3 Lifecycle configuration that expires objects after 2 years. Set the bucket policy to allow the organization's member accounts to write to the S3 bucket.

D. Create an AWS CloudTrail trail for the organization. Configure logs to be delivered to the logging Amazon S3 bucket in the dedicated security account.

E. Turn on AWS CloudTrail in each account. Configure logs to be delivered to an Amazon S3 bucket that is created in the organization's management account. Forward the logs to the S3 bucket in the dedicated security account by using AWS Lambda and Amazon Kinesis Data Firehose.

▼ 中文:

一家公司在 AWS Organizations 的组织中拥有多个 AWS 账户。该组织包括一个专门的安全账户。

所有成员账户的 AWS 账户活动必须记录并报告到专门的安全账户。公司必须将所有活动日志保存在专门的安全账户中的安全存储位置，保留 2 年时间。日志不允许更改或删除。

以下哪种步骤组合可以以最少的操作开销满足这些要求?(选择两项)

- A. 在专门的安全账户中，创建一个 Amazon S3 存储桶。在 S3 存储桶上配置 S3 Object Lock 的合规模式，并设置 2 年的保留期。将存储桶策略设置为允许组织的管理账户写入 S3 存储桶。
- B. 在专门的安全账户中，创建一个 Amazon S3 存储桶。在 S3 存储桶上配置 S3 Object Lock 的合规模式，并设置 2 年的保留期。将存储桶策略设置为允许组织的成员账户写入 S3 存储桶。
- C. 在专门的安全账户中，创建一个具有 S3 生命周期配置的 Amazon S3 存储桶，该配置将在 2 年后过期对象。将存储桶策略设置为允许组织的成员账户写入 S3 存储桶。
- D. 为组织创建一个 AWS CloudTrail 跟踪。配置日志将传送到专门安全账户中的日志 Amazon S3 存储桶。
- E. 在每个账户中启用 AWS CloudTrail。配置日志将传送到组织管理账户中创建的 Amazon S3 存储桶。使用 AWS Lambda 和 Amazon Kinesis Data Firehose 将日志转发到专门安全账户中的 S3 存储桶。

▼ 答案:

AD

1. 考察的知识点

Amazon S3 Object Lock 的使用及配置(合规模式和保留期)。

AWS CloudTrail 的组织级别日志记录功能。

跨账户权限管理(S3 存储桶策略)。

日志的长期存储和不可篡改性要求。

2. 选项分析

A. 在专门的安全账户中，创建一个 Amazon S3 存储桶。在 S3 存储桶上配置 S3 Object Lock 的合规模式，并设置 2 年的保留期。将存储桶策略设置为允许组织的管理账户写入 S3 存储桶。

正确: S3 Object Lock 的合规模式确保日志不可篡改且无法删除，符合 2 年的保留要求。

正确: 允许组织的管理账户写入日志到安全账户的 S3 存储桶，满足集中化存储需求。

B. 在专门的安全账户中，创建一个 Amazon S3 存储桶。在 S3 存储桶上配置 S3 Object Lock 的合规模式，并设置 2 年的保留期。将存储桶策略设置为允许组织的成员账户写入 S3 存储桶。

错误: 直接允许成员账户写入日志到安全账户的 S3 存储桶可能会增加管理复杂性和安全风险。

C. 在专门的安全账户中，创建一个具有 S3 生命周期配置的 Amazon S3 存储桶，该配置将在 2 年后过期对象。将

存储桶策略设置为允许组织的成员账户写入 S3 存储桶。

错误:S3生命周期配置仅用于对象的自动删除，不满足日志不可篡改的要求。

D. 为组织创建一个 AWS CloudTrail 跟踪。配置日志将传送到专门安全账户中的日志 Amazon S3 存储桶。

正确:组织级别的CloudTrail可以集中记录所有成员账户的活动日志，减少操作开销。

正确:将日志传送到安全账户的S3存储桶，符合集中化存储需求。

E. 在每个账户中启用 AWS CloudTrail。配置日志将传送到组织管理账户中创建的 Amazon S3 存储桶。使用 AWS

Lambda 和 Amazon Kinesis Data Firehose 将日志转发到专门安全账户中的 S3 存储桶。

错误:需要在每个账户中单独启用CloudTrail，增加了操作开销。

错误:使用Lambda和Kinesis Data Firehose转发日志增加了额外的复杂性，不符合“最少操作开销”的要求

▼ 13

▼ 英文:

A company is testing its incident response plan for compromised credentials. The company runs a database on an Amazon EC2 instance and stores the sensitive database credentials as a secret in AWS Secrets Manager. The secret has rotation configured with an AWS Lambda function that uses the generic rotation function template. The EC2 instance and the Lambda function are deployed in the same private subnet. The VPC has a Secrets Manager VPC endpoint.

A security engineer discovers that the secret cannot rotate. The security engineer determines that the VPC endpoint is working as intended. The Amazon CloudWatch logs contain the following error: "setSecret: Unable to log into database".

Which solution will resolve this error?

A. Use the AWS Management Console to edit the JSON structure of the secret in Secrets Manager so that the secret automatically conforms with the structure that the database requires.

B. Ensure that the security group that is attached to the Lambda function allows outbound connections to the EC2 instance. Ensure that the security group that is attached to the EC2 instance allows inbound connections from the security group that is attached to the Lambda function.

C. Use the Secrets Manager list-secrets command in the AWS CLI to list the secret. Identify the database credentials. Use the Secrets Manager rotate-secret command in the AWS CLI to force the immediate rotation of the secret.

D. Add an internet gateway to the VPC. Create a NAT gateway in a public subnet. Update the VPC route tables so that traffic from the Lambda function and traffic from the EC2 instance can reach the Secrets Manager public endpoint.

▼ 中文:

一家公司正在测试其针对凭证泄露的事件响应计划。该公司在一个 Amazon EC2 实例上运行数据库，并将敏感的数据 库凭证作为一个 secret 存储在 AWS Secrets Manager 中。该 secret 配置了使用通用 rotation function 模板的 AWS Lambda 函数进行轮换。EC2 实例和 Lambda 函数部署在同一个私有子网中。VPC 配备了一个 Secrets Manager VPC endpoint。

一名安全工程师发现该 secret 无法轮换。安全工程师确定 VPC endpoint 正常工作。Amazon CloudWatch 日志包含以下错误信息:“setSecret: Unable to log into database”。

哪种解决方案可以解决此错误?

A.使用 AWS Management Console 编辑 Secrets Manager 中 secret 的 JSON 结构，以便该 secret 自动符合数据库所需的 结构。

B.确保附加到 Lambda 函数的安全组允许到 EC2 实例的出站连接。确保附加到 EC2 实例的安全组允许来自附加到 Lambda 函数的安全组的入站连接。

C.使用 AWS CLI 中的 Secrets Manager list-secrets 命令列出 secret。识别数据库凭证。使用 AWS CLI 中的 Secrets Manager rotate-secret 命令强制立即轮换该 secret。

D.向 VPC 添加一个 internet gateway。在公共子网中创建一个 NAT gateway。更新 VPC 路由表，以便 Lambda 函数的流 量和 EC2 实例的流量可以访问 Secrets Manager 的公共 endpoint。

▼ 答案:

B

1. 考察的知识点

AWS Secrets Manager的使用与配置，包括密钥轮换。

安全组的配置与网络连接问题排查。

Lambda函数与EC2实例之间的网络通信。

2. 选项分析

A. 使用 AWS Management Console 编辑 Secrets Manager 中 secret 的 JSON 结构，以便该 secret 自动符合数据库所需的结构。

错误原因: 题目中提到的错误是“无法登录到数据库”，这表明问题出在网络连接或认证上，而不是Secrets Manager的

JSON结构。编辑JSON结构无法解决网络连接问题。

B. 确保附加到 Lambda 函数的安全组允许到 EC2 实例的出站连接。确保附加到 EC2 实例的安全组允许来自附加到 Lambda 函数的安全组的入站连接。

正确原因: 根据错误日志“setSecret: Unable to log into database”，问题可能是 Lambda 函数无法连接到数据库。确保安全组配置正确，允许 Lambda 函数与 EC2 实例之间的通信，可以解决此问题。

C. 使用 AWS CLI 中的 Secrets Manager list-secrets 命令列出 secret。识别数据库凭证。使用 AWS CLI 中的 Secrets

Manager rotate-secret 命令强制立即轮换该 secret。

错误原因: 强制轮换密钥并不能解决网络连接问题。问题的根本原因是 Lambda 函数无法登录到数据库，而不是 Secrets Manager 的轮换机制。

D. 向 VPC 添加一个 internet gateway。在公共子网中创建一个 NAT gateway。更新 VPC 路由表，以便 Lambda 函数的流量和 EC2 实例的流量可以访问 Secrets Manager 的公共 endpoint。

错误原因: 题目中明确提到 VPC 已经配置了 Secrets Manager 的 VPC endpoint，因此不需要通过公共 endpoint 访问 Secrets Manager。添加 NAT 网关和 Internet Gateway 是多余的。

▼ 14

▼ 英文:

A company deploys a set of standard IAM roles in AWS accounts. The IAM roles are based on job functions within the company.

To balance operational efficiency and security, a security engineer implemented AWS Organizations SCPs to restrict access to critical security services in all company accounts.

All of the company's accounts and OUs within AWS Organizations have a default FullAWSAccess SCP that is attached. The security engineer needs to ensure that no one can disable Amazon GuardDuty and AWS Security Hub. The security engineer

also must not override other permissions that are granted by IAM policies that are defined in the accounts.

Which SCP should the security engineer attach to the root of the organization to meet these requirements?

A.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}

```

B.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*"
    },
    {
      "Effect": "Allow",
      "NotAction": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}

```

C.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    },
    {
      "Effect": "Deny",
      "NotAction": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}

```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "NotAction": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}
```

▼ 中文:

一家公司在其 AWS 账户中部署了一组标准 IAM 角色。这些 IAM 角色基于公司内部的工作职能。为了平衡运营效率 and 安全性，一位安全工程师实施了 AWS Organizations SCPs，以限制对所有公司账户中关键安全服务的访问。公司所有的账户和 AWS Organizations 中的 OU 都附加了默认的 FullAWSAccess SCP。安全工程师需要确保没有人可以禁用 Amazon GuardDuty 和 AWS Security Hub。安全工程师还必须确保不会覆盖账户中由 IAM 策略授予的其他权限。安全工程师应该将哪个 SCP 附加到组织的根目录以满足这些要求？

A.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*"
    },
    {
      "Effect": "Allow",
      "NotAction": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}
```

C.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    },
    {
      "Effect": "Deny",
      "NotAction": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}

```

D.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "NotAction": [
        "guardduty:DeleteDetector",
        "guardduty:UpdateDetector",
        "securityhub:DisableSecurityHub"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}

```

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的使用，特别是如何通过SCP限制对关键安全服务（如Amazon GuardDuty和AWS Security Hub）的操作。

同时涉及IAM权限模型的理解，包括SCP与IAM策略的交互关系。

2. 选项分析

A: 正确。此选项定义了一个SCP，明确禁止对Amazon GuardDuty和AWS Security Hub的禁用操作，同时不会覆盖其他IAM策略的权限。这符合题目要求。

B: 错误。此选项可能没有正确限制对Amazon GuardDuty和AWS Security Hub的禁用操作，或者可能覆盖了其他IAM策略的权限。

C: 错误。此选项可能定义了过于宽泛或不相关的限制，未能满足题目要求。

D: 错误。此选项可能未正确实现对Amazon GuardDuty和AWS Security Hub的保护，或者可能导致其他权限问题。

▼ 15

▼ 英文:

A company needs to follow security best practices to deploy resources from an AWS CloudFormation template. The CloudFormation template must be able to configure sensitive database credentials.

The company already uses AWS Key Management Service (AWS KMS) and AWS Secrets Manager.

Which solution will meet the requirements?

- A. Use a dynamic reference in the CloudFormation template to reference the database credentials in Secrets Manager.
- B. Use a parameter in the CloudFormation template to reference the database credentials. Encrypt the CloudFormation template by using AWS KMS.
- C. Use a SecureString parameter in the CloudFormation template to reference the database credentials in Secrets Manager.
- D. Use a SecureString parameter in the CloudFormation template to reference an encrypted value in AWS KMS.

在 CloudFormation 模板中使用 SecureString 参数来引用 AWS KMS 中的加密值。

▼ 中文:

一家公司需要遵循安全最佳实践，从 AWS CloudFormation 模板中部署资源。CloudFormation 模板必须能够配置敏感的数据库凭证。

该公司已经使用 [AWS Key Management Service \(AWS KMS\)](#) 和 [AWS Secrets Manager](#)。

哪种解决方案可以满足要求？

- A.在 CloudFormation 模板中使用动态引用来引用 Secrets Manager 中的数据库凭证。
- B.在 CloudFormation 模板中使用参数来引用数据库凭证。使用 AWS KMS 加密 CloudFormation 模板。
- C.在 CloudFormation 模板中使用 SecureString 参数来引用 Secrets Manager 中的数据库凭证。
- D.在 CloudFormation 模板中使用 SecureString 参数来引用 AWS KMS 中的加密值。

▼ 答案:

A

1. 考察的知识点本题考察的是如何在AWS CloudFormation模板中安全地处理敏感信息（如数据库凭证），并结合AWS Secrets Manager和AWS KMS的最佳实践。

涉及的服务包括：AWS CloudFormation、AWS Secrets Manager、AWS KMS。

2. 选项分析

A. Use a dynamic reference in the CloudFormation template to reference the database credentials in Secrets Manager.

动态引用是AWS CloudFormation的一种功能，允许直接从Secrets Manager或SSM Parameter Store中引用敏感数据，而无需将数据明文存储在模板中。这种方法符合安全最佳实践，因为敏感信息不会暴露在模板中。

此选项正确。

B. Use a parameter in the CloudFormation template to reference the database credentials. Encrypt the CloudFormation template by using AWS KMS.

虽然可以使用参数来传递敏感信息，但将敏感信息直接存储在模板中，即使模板被加密，也不符合最佳实践。

此外，CloudFormation模板的加密仅保护模板本身，而不是运行时的敏感数据。此选项错误。

C. Use a SecureString parameter in the CloudFormation template to reference the database credentials in Secrets Manager.

CloudFormation模板中没有“SecureString参数”这种功能。SecureString是SSM Parameter Store的一种类型，而不是CloudFormation的参数类型。

此选项错误。

D. Use a SecureString parameter in the CloudFormation template to reference an encrypted value in AWS KMS.

同样，CloudFormation模板中没有“SecureString参数”这种功能。

此外，直接引用AWS KMS中的加密值并不是处理敏感信息的推荐方式。此选项错误。

▼ 16

▼ 英文:

An international company wants to combine AWS Security Hub findings across all the company's AWS Regions and from multiple accounts. In addition, the company wants to create a centralized custom dashboard to correlate these findings with

operational data for deeper analysis and insights. The company needs an analytics tool to search and visualize Security Hub findings.

Which combination of steps will meet these requirements? (Choose three.)

A. Designate an AWS account as a delegated administrator for Security Hub. Publish events to Amazon CloudWatch from the delegated administrator account, all member accounts, and required Regions that are enabled for Security Hub findings.

- B. Designate an AWS account in an organization in AWS Organizations as a delegated administrator for Security Hub. Publish events to Amazon EventBridge from the delegated administrator account, all member accounts, and required Regions that are enabled for Security Hub findings.
- C. In each Region, create an Amazon EventBridge rule to deliver findings to an Amazon Kinesis data stream. Configure the Kinesis data streams to output the logs to a single Amazon S3 bucket.
- D. In each Region, create an Amazon EventBridge rule to deliver findings to an Amazon Kinesis Data Firehose delivery stream. Configure the Kinesis Data Firehose delivery streams to deliver the logs to a single Amazon S3 bucket.
- E. Use AWS Glue DataBrew to crawl the Amazon S3 bucket and build the schema. Use AWS Glue Data Catalog to query the data and create views to flatten nested attributes. Build Amazon QuickSight dashboards by using Amazon Athena.
- F. Partition the Amazon S3 data. Use AWS Glue to crawl the S3 bucket and build the schema. Use Amazon Athena to query the data and create views to flatten nested attributes. Build Amazon QuickSight dashboards that use the Athena views.

▼ 中文:

一家国际公司希望将所有公司 AWS 区域和多个账户中的 AWS Security Hub 发现合并。此外，该公司希望创建一个集中式自定义仪表板，以将这些发现与运营数据进行关联，从而进行更深入的分析 and 洞察。公司需要一个[分析工具来搜索和可视化 Security Hub 发现](#)。

[哪些步骤组合可以满足这些需求？](#)（选择三个）

- A.指定一个 AWS 账户作为 Security Hub 的委派管理员账户。从委派管理员账户、所有成员账户以及启用了 Security Hub 发现的所需区域将事件发布到 Amazon CloudWatch。
- B.指定 AWS Organizations 中组织的一个 AWS 账户作为 Security Hub 的委派管理员账户。从委派管理员账户、所有成员账户以及启用了 Security Hub 发现的所需区域将事件发布到 Amazon EventBridge。
- C.在每个区域中，创建一个 Amazon EventBridge 规则，将发现传递到 Amazon Kinesis 数据流。配置 Kinesis 数据流将日志输出到单个 Amazon S3 存储桶。
- D.在每个区域中，创建一个 Amazon EventBridge 规则，将发现传递到 Amazon Kinesis Data Firehose 交付流。配置 Kinesis Data Firehose 交付流将日志传递到单个 Amazon S3 存储桶。
- E.使用 AWS Glue DataBrew 爬取 Amazon S3 存储桶并构建架构。使用 AWS Glue Data Catalog 查询数据并创建视图以展平嵌套属性。使用 Amazon Athena 构建 Amazon QuickSight 仪表板。

F.对 Amazon S3 数据进行分区。使用 AWS Glue 爬取 S3 存储桶并构建架构。使用 Amazon Athena 查询数据并创建视图以展平嵌套属性。构建使用 Athena 视图的 Amazon QuickSight 仪表板。

▼ 答案:

BDF

1. 考察的知识点

AWS Security Hub的跨账户和跨区域整合能力。

Amazon EventBridge的事件路由功能。

Amazon Kinesis Data Firehose的日志传输能力。

Amazon S3作为集中存储的能力。

AWS Glue和Amazon Athena的数据处理与查询能力。

Amazon QuickSight的可视化能力。

2. 选项分析

A. Designate an AWS account as a delegated administrator for Security Hub. Publish events to Amazon CloudWatch from the delegated administrator account, all member accounts, and required Regions that are enabled for Security Hub findings.

错误：虽然指定委派管理员是正确的，但将事件发布到Amazon CloudWatch并不是最佳实践。CloudWatch主要用于监控和告警，而不是用于事件路由和分析。

B. Designate an AWS account in an organization in AWS Organizations as a delegated administrator for Security Hub. Publish events to Amazon EventBridge from the delegated administrator account, all member accounts, and required Regions that are enabled for Security Hub findings.

正确：指定委派管理员是整合Security Hub发现的第一步。使用Amazon EventBridge可以有效地路由事件到其他服务进行处理。

C. In each Region, create an Amazon EventBridge rule to deliver findings to an Amazon Kinesis data stream. Configure the Kinesis data streams to output the logs to a single Amazon S3 bucket.

错误：虽然Kinesis数据流可以传输数据，但题目要求的是使用Kinesis Data Firehose（选项D），因为它更适合直接将数据传输到S3。

D. In each Region, create an Amazon EventBridge rule to deliver findings to an Amazon Kinesis Data Firehose delivery stream. Configure the Kinesis Data Firehose delivery streams to deliver the logs to a single Amazon S3 bucket.

正确：使用EventBridge规则将发现传递到Kinesis Data Firehose是最佳实践。Firehose可以直接将数据传输到S3，简化了数据处理流程。

E. Use AWS Glue DataBrew to crawl the Amazon S3 bucket and build the

schema. Use AWS Glue Data Catalog to query the data and create views to flatten nested attributes. Build Amazon QuickSight dashboards by using Amazon Athena.

错误：虽然AWS Glue DataBrew可以用于数据准备，但题目中并未提到需要使用DataBrew。选项F提供了更直接的解决方案。

F. Partition the Amazon S3 data. Use AWS Glue to crawl the S3 bucket and build the schema. Use Amazon Athena to query the data and create views to flatten nested attributes. Build Amazon QuickSight dashboards that use the Athena views.

正确：对S3数据进行分区可以优化查询性能。使用AWS Glue和Amazon Athena可以有效地处理和查询数据，Amazon QuickSight可以用于创建可视化仪表板。

▼ 17

▼ 英文:

An AWS account administrator created an IAM group and applied the following managed policy to require that each individual user authenticate using multi-factor authentication:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "ec2:*",
      "Resource": "*"
    },
    {
      "Sid": "BlockAnyAccessUnlessSignedInWithMFA",
      "Effect": "Deny",
      "Action": "ec2:*",
      "Resource": "*",
      "Condition": {
        "BoolIfExists": {
          "aws:MultiFactorAuthPresent": false
        }
      }
    }
  ]
}
```

After implementing the policy, the administrator receives reports that users are unable to perform Amazon EC2 commands using the AWS CLI.

What should the administrator do to resolve this problem while still enforcing multi-factor authentication?

A. Change the value of `aws:MultiFactorAuthPresent` to true.

B. Instruct users to run the `aws sts get-session-token` CLI command and pass the multi-factor authentication `--serialnumber` and `-token-code` parameters. Use these resulting values to make API/CLI calls.

- C. Implement federated API/CLI access using SAML 2.0, then configure the identity provider to enforce multi-factor authentication.
- D. Create a role and enforce multi-factor authentication in the role trust policy. Instruct users to run the sts assume-role CLI command and pass --serial-number and --token-code parameters. Store the resulting values in environment variables. Add sts:AssumeRole to NotAction in the policy.

▼ 中文:

一个AWS账户管理员创建了一个IAM组，并应用了以下托管策略，要求每个用户使用多重身份验证进行身份验证：

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "ec2:*",
      "Resource": "*"
    },
    {
      "Sid": "BlockAnyAccessUnlessSignedInWithMFA",
      "Effect": "Deny",
      "Action": "ec2:*",
      "Resource": "*",
      "Condition": {
        "BoolIfExists": {
          "aws:MultiFactorAuthPresent": false
        }
      }
    }
  ]
}
```

在实施该策略后，管理员收到报告称用户无法使用AWS CLI执行Amazon EC2命令。管理员应该怎么做才能解决这个问题，同时仍然强制执行多重身份验证？

- A. 将aws:MultiFactorAuthPresent的值更改为true。
- B. 指示用户运行aws sts get-session-token CLI命令，并传递多重身份验证的--serial-number和--token-code参数。使用这些生成的值进行API/CLI调用。
- C. 使用SAML 2.0实施联合API/CLI访问，然后配置身份提供方强制执行多重身份验证。
- D. 创建一个角色，并在角色信任策略中强制执行多重身份验证。指示用户运行sts assume-role CLI命令，并传递--serialnumber和--token-code参数。将生成的值存储在环境变量中。在策略中将sts:AssumeRole添加到NotAction。

▼ 答案:

B

1. 考察的知识点

IAM策略的条件语句使用，包括 `aws:MultiFactorAuthPresent`。

如何在CLI/API调用中正确处理多因素认证 (MFA)。

STS临时凭证的使用方法。

2. 选项分析

A. Change the value of `aws:MultiFactorAuthPresent` to true.

错误：`aws:MultiFactorAuthPresent` 是一个条件检查，不能直接更改其值。它是由用户是否使用MFA登录决定的。

B. Instruct users to run the `aws sts get-session-token` CLI command and pass the multi-factor authentication `--serial-number` and `-token-code` parameters. Use these resulting values to make API/CLI calls.

正确：通过 `aws sts get-session-token` 命令，用户可以使用MFA生成临时凭证。这些临时凭证可以用于后续的API/CLI调用，从而满足策略中的MFA要求。

C. Implement federated API/CLI access using SAML 2.0, then configure the identity provider to enforce multi-factor authentication.

错误：虽然SAML 2.0可以实现联合身份认证并支持MFA，但题目没有提到需要使用联合身份认证，且实现此方案复杂度较高，不符合题目要求。

D. Create a role and enforce multi-factor authentication in the role trust policy. Instruct users to run the `sts assume-role` CLI command and pass `--serial-number` and `--token-code` parameters. Store the resulting values in environment variables. Add `sts:AssumeRole` to `NotAction` in the policy.

错误：虽然可以通过角色信任策略强制MFA，但题目中并未提到需要创建角色。此外，题目中的策略已经通过

`aws:MultiFactorAuthPresent` 条件强制了MFA，因此不需要额外的角色信任策略。

▼ 18

▼ 英文:

A company is developing a mechanism that will help data scientists use Amazon SageMaker to read, process, and output data to an Amazon S3 bucket. Data scientists will have access to a dedicated S3 prefix for each of their projects. The company will implement bucket policies that use the dedicated S3 prefixes to restrict access to the S3 objects. The projects can last up to 60 days. The company's security team mandates that data cannot remain in the S3 bucket after the end of the projects that use the data. Which solution will meet these requirements MOST cost-effectively?

- A. Create an AWS Lambda function to identify and delete objects in the S3 bucket that have not been accessed for 60 days. Create an Amazon EventBridge scheduled rule that runs every day to invoke the Lambda function.
- B. Create a new S3 bucket. Configure the new S3 bucket to use S3 Intelligent-Tiering. Copy the objects to the new S3 bucket.
- C. Create an S3 Lifecycle configuration for each S3 bucket prefix for each project. Set the S3 Lifecycle configurations to expire objects after 60 days.
- D. Create an AWS Lambda function to delete objects that have not been accessed for 60 days. Create an S3 event notification for S3 Intelligent-Tiering automatic archival events to invoke the Lambda function.

▼ 中文:

一家公司正在开发一种机制，帮助数据科学家使用 Amazon SageMaker 读取、处理数据，并将数据输出到一个 Amazon S3 bucket。数据科学家将拥有一个专属的 S3 前缀，用于他们的每个项目。公司将实施 bucket 策略，利用专属的 S3 前缀来限制对 S3 对象的访问。这些项目最长可持续 60 天。

公司的安全团队要求，在使用数据的项目结束后，数据不能保留在 S3 bucket 中。
哪种解决方案最具成本效益地满足这些要求？

- A. 创建一个 AWS Lambda 函数，用于识别并删除在 S3 bucket 中未被访问超过 60 天的对象。创建一个 Amazon EventBridge 定时规则，每天运行以调用该 Lambda 函数。
- B. 创建一个新的 S3 bucket。配置新的 S3 bucket 使用 S3 Intelligent-Tiering。将对象复制到新的 S3 bucket。
- C. 为每个项目的每个 S3 bucket 前缀创建一个 S3 生命周期配置。设置 S3 生命周期配置以在 60 天后过期对象。
- D. 创建一个 AWS Lambda 函数，用于删除未被访问超过 60 天的对象。为 S3 Intelligent-Tiering 自动归档事件创建一个 S3 事件通知，以调用该 Lambda 函数。

▼ 答案:

C

1. 考察的知识点

Amazon S3 的生命周期管理 (Lifecycle Configuration)
如何使用 S3 前缀和策略来管理数据访问和存储
成本优化与自动化数据清理

2. 选项分析

- A. Create an AWS Lambda function to identify and delete objects in the S3 bucket that have not been accessed for 60 days.
Create an Amazon EventBridge scheduled rule that runs every day to invoke

the Lambda function.

正确性：此选项通过Lambda函数和EventBridge规则实现数据清理，但需要额外的开发和维护工作。

成本：运行Lambda函数和EventBridge规则会产生额外的费用，尤其是对于大规模数据清理任务。

结论：虽然可以实现目标，但不是最成本有效的解决方案。

B. Create a new S3 bucket. Configure the new S3 bucket to use S3 Intelligent-Tiering. Copy the objects to the new S3 bucket.

正确性：S3 Intelligent-Tiering主要用于优化存储成本，而不是自动清理数据。

成本：复制数据到新桶会增加存储和数据传输成本，并且无法满足60天后自动删除的要求。

结论：此选项不符合题目要求。

C. Create an S3 Lifecycle configuration for each S3 bucket prefix for each project. Set the S3 Lifecycle configurations to expire objects after 60 days.

正确性：S3生命周期配置是专门设计用于自动管理对象的生命周期，包括过期删除。

成本：无需额外费用，完全由S3原生功能支持，最为成本有效。

结论：此选项完全符合题目要求。

D. Create an AWS Lambda function to delete objects that have not been accessed for 60 days. Create an S3 event notification for S3 Intelligent-Tiering automatic archival events to invoke the Lambda function.

正确性：此选项依赖S3 Intelligent-Tiering的归档事件，但归档事件并不直接支持删除功能。

成本：需要额外的Lambda函数开发和维护，增加复杂性和成本。

结论：此选项不符合题目要求。

▼ 19

▼ 英文:

A company has AWS accounts that are in an organization in AWS Organizations. An Amazon S3 bucket in one of the accounts is publicly accessible.

A security engineer must change the configuration so that the S3 bucket is no longer publicly accessible. The security engineer also must ensure that the S3 bucket cannot be made publicly accessible in the future.

Which solution will meet these requirements?

A. Configure the S3 bucket to use an AWS Key Management Service (AWS KMS) key. Encrypt all objects in the S3 bucket by creating a bucket policy that enforces encryption. Configure an SCP to deny the s3:GetObject action for the OU that contains the AWS account.

- B. Enable the PublicAccessBlock configuration on the S3 bucket. Configure an SCP to deny the s3:GetObject action for the OU that contains the AWS account.
- C. Enable the PublicAccessBlock configuration on the S3 bucket. Configure an SCP to deny the s3:PutPublicAccessBlock action for the OU that contains the AWS account.
- D. Configure the S3 bucket to use S3 Object Lock in governance mode. Configure an SCP to deny the s3:PutPublicAccessBlock action for the OU that contains the AWS account.

▼ 中文:

一家公司拥有多个 AWS 账户，这些账户属于 AWS Organizations 中的一个组织。某个账户中的一个 Amazon S3 bucket 是公开可访问的。

一名安全工程师必须更改配置，以使该 S3 bucket 不再公开可访问。安全工程师还必须确保该 S3 bucket 在未来无法被设置为公开可访问。

哪种解决方案可以满足这些要求？

- A. 将 S3 bucket 配置为使用 AWS Key Management Service (AWS KMS) 密钥。通过创建强制加密的 bucket policy 对 S3 bucket 中的所有对象进行加密。配置一个 SCP 来拒绝对包含该 AWS 账户的 OU 的 s3:GetObject 操作。
- B. 启用 S3 bucket 的 PublicAccessBlock 配置。配置一个 SCP 来拒绝对包含该 AWS 账户的 OU 的 s3:GetObject 操作。
- C. 启用 S3 bucket 的 PublicAccessBlock 配置。配置一个 SCP 来拒绝对包含该 AWS 账户的 OU 的 s3:PutPublicAccessBlock 操作。
- D. 将 S3 bucket 配置为使用 S3 Object Lock 的治理模式。配置一个 SCP 来拒绝对包含该 AWS 账户的 OU 的 s3:PutPublicAccessBlock 操作。

▼ 答案:

C

1. 考察的知识点

Amazon S3 的公共访问控制 (PublicAccessBlock 配置)。
服务控制策略 (Service Control Policy, SCP) 的使用。
如何防止 S3 bucket 被设置为公开访问。

2. 选项分析

A. 配置 S3 bucket 使用 AWS KMS 密钥并强制加密，配置 SCP 拒绝 s3:GetObject 操作。

错误：虽然加密可以保护数据，但它与防止公共访问无关。加密不会阻止 S3 bucket 被设置为公开访问。

错误：SCP 拒绝 s3:GetObject 操作会阻止数据读取，但无法防止 bucket 被设置为公开访问。

B. 启用S3 bucket的PublicAccessBlock配置，配置SCP拒绝s3:GetObject操作。

部分正确：PublicAccessBlock配置可以防止公共访问，但SCP拒绝s3:GetObject操作与防止bucket被设置为公开访问无关。

错误：此选项未解决如何防止未来的公共访问设置问题。

C. 启用S3 bucket的PublicAccessBlock配置，配置SCP拒绝s3:PutPublicAccessBlock操作。

正确：PublicAccessBlock配置可以防止当前的公共访问。

正确：SCP拒绝s3:PutPublicAccessBlock操作可以防止用户禁用PublicAccessBlock，从而确保bucket无法被设置为公开访问。

D. 配置S3 bucket使用S3 Object Lock治理模式，配置SCP拒绝s3:PutPublicAccessBlock操作。

错误：S3 Object Lock治理模式用于防止对象被删除或修改，与防止公共访问无关。

错误：虽然SCP拒绝s3:PutPublicAccessBlock操作是正确的，但Object Lock治理模式与题目要求不匹配。

▼ 20

▼ 英文:

A company is designing a new application stack. The design includes web servers and backend servers that are hosted on Amazon EC2 instances. The design also includes an Amazon Aurora MySQL DB cluster.

The EC2 instances are in an Auto Scaling group that uses launch templates. The EC2 instances for the web layer and the backend layer are backed by Amazon Elastic Block Store (Amazon EBS) volumes. No layers are encrypted at rest. A security engineer needs to implement encryption at rest.

Which combination of steps will meet these requirements? (Choose two.)

A. Modify EBS default encryption settings in the target AWS Region to enable encryption. Use an Auto Scaling group instance refresh.

B. Modify the launch templates for the web layer and the backend layer to add AWS Certificate Manager (ACM) encryption for the attached EBS volumes. Use an Auto Scaling group instance refresh.

C. Create a new AWS Key Management Service (AWS KMS) encrypted DB cluster from a snapshot of the existing DB cluster.

D. Apply AWS Key Management Service (AWS KMS) encryption to the existing DB cluster.

E. Apply AWS Certificate Manager (ACM) encryption to the existing DB cluster.

▼ 中文:

一家公司正在设计一个新的应用程序架构。设计包括托管在 Amazon EC2 实例上的 Web 服务器和后端服务器。设计还包括一个 Amazon Aurora MySQL 数据库集群。EC2 实例位于使用启动模板的 Auto Scaling 组中。Web 层和后端层的 EC2 实例由 Amazon Elastic Block Store (Amazon EBS) 卷支持。没有任何层在静态存储时加密。一名安全工程师需要实现静态存储加密。

哪些步骤组合可以满足这些要求？（选择两个）

A. 修改目标 AWS 区域中的 EBS 默认加密设置以启用加密。使用 Auto Scaling 组实例刷新。

B. 修改 Web 层和后端层的启动模板，以为附加的 EBS 卷添加 AWS Certificate Manager (ACM) 加密。使用 Auto Scaling 组实例刷新。

C. 从现有数据库集群的快照创建一个新的 AWS Key Management Service (AWS KMS) 加密数据库集群。

D. 对现有数据库集群应用 AWS Key Management Service (AWS KMS) 加密。

E. 对现有数据库集群应用 AWS Certificate Manager (ACM) 加密。

▼ 答案:

AC

1. 考察的知识点

Amazon EBS默认加密设置及其应用。

AWS Key Management Service (KMS) 的使用及其在Amazon Aurora数据库加密中的应用。

Auto Scaling组实例刷新机制。

加密技术的正确选择（例如KMS vs ACM）。

2. 选项分析

A. Modify EBS default encryption settings in the target AWS Region to enable encryption. Use an Auto Scaling group instance refresh.

正确：修改EBS默认加密设置会确保所有新创建的EBS卷自动加密。结合Auto Scaling组实例刷新，可以确保新启动的实例使用加密的EBS卷。

B. Modify the launch templates for the web layer and the backend layer to add AWS Certificate Manager (ACM) encryption for the attached EBS volumes. Use an Auto Scaling group instance refresh.

错误：ACM用于管理SSL/TLS证书，主要用于传输层加密，而不是用于EBS卷的加密。EBS卷加密需要使用KMS。

C. Create a new AWS Key Management Service (AWS KMS) encrypted DB cluster from a snapshot of the existing DB cluster.

正确：Amazon Aurora数据库加密需要使用KMS。通过现有快照创建新的加密数据库集群是实现加密的正确方法。

D. Apply AWS Key Management Service (AWS KMS) encryption to the existing DB cluster.

错误：无法直接对现有的Aurora数据库集群应用加密。需要通过快照创建新的加密集群。

E. Apply AWS Certificate Manager (ACM) encryption to the existing DB cluster.

错误：ACM用于管理SSL/TLS证书，主要用于传输层加密，而不是数据库加密。Aurora数据库加密需要使用KMS。

▼ 21

▼ 英文:

A company uses SAML federation with AWS Identity and Access Management (IAM) to provide internal users with SSO for their AWS accounts. The company's identity provider certificate was rotated as part of its normal lifecycle Shortly after users started

receiving the following error when attempting to log in:

"Error: Response Signature Invalid (Service: AWSSecurityTokenService; Status Code: 400; Error Code: InvalidIdentityToken)"

A security engineer needs to address the immediate issue and ensure that it will not occur again. Which combination of steps should the security engineer take to accomplish this? (Choose two.)

A. Download a new copy of the SAML metadata file from the identity provider. Create a new IAM identity provider entity. Upload the new metadata file to the new IAM identity provider entity.

B. During the next certificate rotation period and before the current certificate expires, add a new certificate as the secondary to the identity provider. Generate a new metadata file and upload it to the IAM identity provider entity. Perform automated or manual rotation of the certificate when required.

C. Download a new copy of the SAML metadata file from the identity provider. Upload the new metadata to the IAM identity provider entity configured for the SAML integration in question.

D. During the next certificate rotation period and before the current certificate expires, add a new certificate as the secondary to the identity provider. Generate a new copy of the metadata file and create a new IAM identity provider entity.

Upload the metadata file to the new IAM identity provider entity. Perform automated or manual rotation of the certificate when required.

E. Download a new copy of the SAML metadata file from the identity provider. Create a new IAM identity provider entity. Upload the new metadata file to the new IAM identity provider entity. Update the identity provider configurations to pass a new IAM identity provider entity name in the SAML assertion.

▼ 中文:

一家公司使用SAML联合身份认证与AWS Identity and Access Management (IAM)，为内部用户提供其AWS账户的单点登录（SSO）。公司的身份提供方证书在其正常生命周期内进行了轮换。不久之后，用户在尝试登录时开始收到以下错误：

“错误：响应签名无效 (服务：AWSSecurityTokenService；状态码：400；错误代码：InvalidIdentityToken)”

一名安全工程师需要解决当前问题并确保该问题不会再次发生。安全工程师应采取哪些步骤的组合来完成此任务？（选择两项）

- A. 从身份提供方下载新的SAML元数据文件。创建一个新的IAM身份提供方实体。将新的元数据文件上传到新的IAM身份提供方实体。
- B. 在下一次证书轮换周期期间，并在当前证书过期之前，将新证书添加为身份提供方的辅助证书。生成新的元数据文件并将其上传到IAM身份提供方实体。根据需要执行证书的自动或手动轮换。
- C. 从身份提供方下载新的SAML元数据文件。将新的元数据上传到为相关SAML集成配置的IAM身份提供方实体。
- D. 在下一次证书轮换周期期间，并在当前证书过期之前，将新证书添加为身份提供方的辅助证书。生成新的元数据文件并创建一个新的IAM身份提供方实体。将元数据文件上传到新的IAM身份提供方实体。根据需要执行证书的自动或手动轮换。
- E. 从身份提供方下载新的SAML元数据文件。创建一个新的IAM身份提供方实体。将新的元数据文件上传到新的IAM身份提供方实体。更新身份提供方配置以在SAML断言中传递新的IAM身份提供方实体名称。

▼ 答案:

BC

1. 考察的知识点

本题考察的是AWS Identity and Access Management (IAM) 与 SAML身份联合认证的配置管理，特别是如何处理身份提供方证书轮换问题。

涉及的知识点包括：SAML元数据文件的更新、IAM身份提供方实体的管理、证书轮换的最佳实践。

2. 选项分析

A. 从身份提供方下载新的SAML元数据文件。创建一个新的IAM身份提供方实体。将新的元数据文件上传到新的IAM身份提供方实体。

错误：创建新的IAM身份提供方实体并不是解决问题的必要步骤。只需更新现有的IAM身份提供方实体即可解决问题。

B. 在下次证书轮换周期期间，并在当前证书过期之前，将新证书添加为身份提供方的辅助证书。生成新的元数据文件并将其上传到IAM身份提供方实体。根据需要进行证书的自动或手动轮换。

正确：这是证书轮换的最佳实践，确保在证书过期之前添加辅助证书并更新元数据文件，可以避免类似问题的发生。

C. 从身份提供方下载新的SAML元数据文件。将新的元数据上传到为相关SAML集成配置的IAM身份提供方实体。

正确：这是解决当前问题的直接步骤，通过更新现有IAM身份提供方实体的元数据文件，可以修复错误。

D. 在下次证书轮换周期期间，并在当前证书过期之前，将新证书添加为身份提供方的辅助证书。生成新的元数据文件并创建一个新的IAM身份提供方实体。将元数据文件上传到新的IAM身份提供方实体。根据需要执行证书的自动或手动轮换。

错误：创建新的IAM身份提供方实体并不是必要的步骤，更新现有实体即可。

E. 从身份提供方下载新的SAML元数据文件。创建一个新的IAM身份提供方实体。将新的元数据文件上传到新的IAM身份提供方实体。更新身份提供方配置以在SAML断言中传递新的IAM身份提供方实体名称。

错误：创建新的IAM身份提供方实体并更新SAML断言配置是多余的，直接更新现有实体即可解决问题。

▼ 22

▼ 英文:

A company is implementing a new application in a new AWS account. A VPC and subnets have been created for the application. The application has been peered to an existing VPC in another account in the same AWS Region for database access. Amazon EC2 instances will regularly be created and terminated in the application VPC, but only some of them will need access to the databases in the peered VPC over TCP port 1521. A security engineer must ensure that only the EC2 instances that need access to the databases can access them through the network.

How can the security engineer implement this solution?

A. Create a new security group in the database VPC and create an inbound rule that allows all traffic from the IP address range of the application VPC. Add a new network ACL rule on the database subnets. Configure the rule to TCP port 1521 from the IP address range of the application VPC. Attach the new security group to the database instances that the application instances need to access.

B. Create a new security group in the application VPC with an inbound rule that allows the IP address range of the database VPC over TCP port 1521. Create a

new security group in the database VPC with an inbound rule that allows the IP address range of the application VPC over port 1521. Attach the new security group to the database instances and the application instances that need database access.

C. Create a new security group in the application VPC with no inbound rules. Create a new security group in the database VPC with an inbound rule that allows TCP port 1521 from the new application security group in the application VPC. Attach the application security group to the application instances that need database access and attach the database security group to the database instances.

D. Create a new security group in the application VPC with an inbound rule that allows the IP address range of the database VPC over TCP port 1521. Add a new network ACL rule on the database subnets. Configure the rule to allow all traffic from the IP address range of the application VPC. Attach the new security group to the application instances that need database access.

▼ 中文:

一家公司正在一个新的 AWS 账户中实施一个新的应用程序。已经为该应用程序创建了一个 VPC 和子网。该应用程序已与同一 AWS 区域内另一个账户中的现有 VPC 建立了对等连接，以访问数据库。应用程序 VPC 中的 Amazon EC2 实例将定期创建和终止，但只有部分实例需要通过 TCP 端口 1521 访问对等 VPC 中的数据库。一名安全工程师必须确保只有需要访问数据库的 EC2 实例才能通过网络访问它们。

安全工程师如何实施此解决方案？

A. 在数据库 VPC 中创建一个新的安全组，并创建一个入站规则，允许来自应用程序 VPC 的 IP 地址范围的所有流量。

在数据库子网中添加一个新的网络 ACL 规则。将规则配置为允许来自应用程序 VPC 的 IP 地址范围的 TCP 端口 1521。将新的安全组附加到应用程序实例需要访问的数据库实例上。

B. 在应用程序 VPC 中创建一个新的安全组，并设置一个入站规则，允许来自数据库 VPC 的 IP 地址范围通过 TCP 端口 1521。在数据库 VPC 中创建一个新的安全组，并设置一个入站规则，允许来自应用程序 VPC 的 IP 地址范围通过端口 1521。将新的安全组附加到需要数据库访问的数据库实例和应用程序实例上。

C. 在应用程序 VPC 中创建一个新的安全组，不设置任何入站规则。在数据库 VPC 中创建一个新的安全组，并设置一个入站规则，允许来自应用程序 VPC 中新的安全组的 TCP 端口 1521。将应用程序安全组附加到需要数据库访问的应用程序实例上，并将数据库安全组附加到数据库实例上。

D. 在应用程序 VPC 中创建一个新的安全组，并设置一个入站规则，允许来自数据库 VPC 的 IP 地址范围通过 TCP 端口 1521。在数据库子网中添加一个新的网络 ACL 规

则。将规则配置为允许来自应用程序 VPC 的 IP 地址范围的所有流量。将新的安全组附加到需要数据库访问的应用程序实例上。

▼ 答案:

C

1. 考察的知识点

VPC间通信：VPC Peering的使用和配置。

安全组的规则：如何通过安全组控制流量。

网络ACL的规则：网络ACL与安全组的区别及使用场景。

最小权限原则：确保只有需要访问的资源能够访问。

2. 选项分析

A. 错误

分析：

安全组的入站规则允许来自应用程序VPC的所有流量，这不符合最小权限原则。

网络ACL规则配置为允许整个应用程序VPC的IP地址范围，这也过于宽泛，可能会允许不必要的流量。

虽然可以实现访问，但这种配置不够安全，且不符合最佳实践。

B. 错误

分析：

在应用程序VPC和数据库VPC中分别创建安全组，并设置IP地址范围的入站规则，这种方法过于宽泛，允许了整个VPC

的流量，而不是仅限于需要访问的实例。

这种配置不符合最小权限原则，可能会导致不必要的安全风险。

C. 正确

分析：

在应用程序VPC中创建一个新的安全组，不设置任何入站规则，这符合最小权限原则。

在数据库VPC中创建一个新的安全组，并设置入站规则，允许来自应用程序VPC中指定安全组的流量。这种方法确保只有绑定了该安全组的实例可以访问数据库。这种配置是基于安全组之间的引用，符合AWS最佳实践，且更加安全。

D. 错误

分析：

在应用程序VPC中创建安全组，并设置入站规则允许来自数据库VPC的IP地址范围，这种方法过于宽泛，可能会允许不在应用程序VPC中创建安全组，并设置入站规则允许来自数据库VPC的IP地址范围，这种方法过于宽泛，可能会允许不必要的流量。

网络ACL规则配置为允许整个应用程序VPC的IP地址范围，这也不符合最小权限原则。

这种配置不够安全，且不符合最佳实践。

▼ 23

▼ 英文:

A company needs a forensic-logging solution for hundreds of applications running in Docker on Amazon EC2. The solution must perform real-time analytics on the logs, must support the replay of messages, and must persist the logs.

Which AWS services should be used to meet these requirements? (Choose two.)

- A. Amazon Athena
- B. Amazon Kinesis
- C. Amazon SQS
- D. Amazon OpenSearch Service
- E. Amazon EMR

▼ 中文:

一家公司需要为运行在 Amazon EC2 上的数百个 Docker 应用程序提供法医日志解决方案。该解决方案必须能够对日志进行实时分析，支持消息重播，并且能够持久化日志。

应该使用哪些 AWS 服务来满足这些要求？（选择两个）

- A. Amazon Athena
- B. Amazon Kinesis
- C. Amazon SQS
- D. Amazon OpenSearch Service
- E. Amazon EMR

▼ 答案:

BD

1. 考察的知识点

本题考察的是AWS服务在日志处理、实时分析、消息重播和持久化方面的能力。涉及的服务包括Amazon Kinesis、Amazon OpenSearch Service、Amazon Athena、Amazon SQS和Amazon EMR。

2. 选项分析

A. Amazon Athena

Amazon Athena是一种交互式查询服务，主要用于分析存储在Amazon S3中的数据。

它不支持实时日志分析，也不支持消息重播功能。

错误原因：不符合实时分析和消息重播的要求。

B. Amazon Kinesis

Amazon Kinesis是一种实时数据流处理服务，支持实时日志分析和消息重播功能。

它可以持久化数据并支持高吞吐量的日志处理。

正确原因：完全符合题目要求。

C. Amazon SQS

Amazon SQS是一种消息队列服务，主要用于解耦和异步通信。

虽然支持消息持久化，但不支持实时分析和消息重播功能。

错误原因：不符合实时分析的要求。

D. Amazon OpenSearch Service

Amazon OpenSearch Service是一种搜索和分析服务，支持实时日志分析和持久化。

它可以用于存储和查询日志数据，并支持实时分析功能。

正确原因：完全符合题目要求。

E. Amazon EMR

Amazon EMR是一种大数据处理服务，主要用于批处理分析。

它不支持实时日志分析，也不支持消息重播功能。

错误原因：不符合实时分析的要求。

▼ 24

▼ 英文:

A company has many member accounts in an organization in AWS Organizations. The company is concerned about the potential for misuse of the AWS account root user credentials for member accounts in the organization. To address this potential misuse, the company wants to ensure that even if the account root user credentials are compromised the account is still protected. Which solution will meet this requirement?

A. Block service access by using SCPs for the root user

B. Remove the password for the root user

C. Delete access keys for the root user

D. Create an Amazon EventBridge rule to detect any AWS account root user API events

▼ 中文:

一家公司在 AWS Organizations 中的组织内拥有许多成员账户。该公司担心成员账户的 AWS 账户根用户凭证可能被滥用。为了应对这种潜在的滥用情况，公司希望确保即使账户根用户凭证被泄露，账户仍然受到保护。

哪种解决方案可以满足这一要求？

A. 通过使用 SCPs 阻止根用户的服务访问

B. 移除根用户的密码

C.删除根用户的访问密钥

D.创建一个 Amazon EventBridge 规则以检测任何 AWS 账户根用户的 API 事件

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS Organizations中的安全控制策略（SCPs）的使用，以及如何保护AWS账户的根用户免受潜在的滥用。

涉及AWS账户安全最佳实践，包括限制根用户的权限和监控其活动。

2. 选项分析

A. Block service access by using SCPs for the root user

正确：使用SCP（Service Control Policies）可以限制组织中账户的根用户访问特定服务或操作。即使根用户的凭证被泄

露，SCP仍然可以强制执行限制，确保安全性。

这是AWS推荐的最佳实践之一，用于保护账户的根用户。

B. Remove the password for the root user

错误：AWS不允许移除根用户的密码。根用户始终需要密码来登录AWS管理控制台。

此选项不可行。

C. Delete access keys for the root user

部分正确：删除根用户的访问密钥可以减少根用户凭证被滥用的风险，但这并不能完全保护账户。如果根用户的密码

被泄露，攻击者仍然可以登录并执行操作。

此选项虽然是一个安全措施，但不足以满足题目要求。

D. Create an Amazon EventBridge rule to detect any AWS account root user API events

部分正确：创建EventBridge规则可以监控根用户的活动，但这只是一个检测机制，不能阻止滥用行为。

此选项不能完全满足题目要求，因为它无法确保账户在根用户凭证泄露时仍然受到保护。

▼ 25

▼ 英文:

An Amazon EC2 Auto Scaling group launches Amazon Linux EC2 instances and installs the Amazon CloudWatch agent to publish logs to Amazon CloudWatch Logs. The EC2 instances launch with an IAM role that has an IAM policy attached. The policy provides access to publish custom metrics to CloudWatch. The EC2 instances run in a private subnet inside a VPC. The VPC provides access to the internet for private subnets through a NAT gateway.

A security engineer notices that no logs are being published to CloudWatch

Logs for the EC2 instances that the Auto Scaling group launches. The security engineer validates that the CloudWatch Logs agent is running and is configured properly on the EC2 instances. In addition, the security engineer validates that network communications are working properly to AWS services.

What can the security engineer do to ensure that the logs are published to CloudWatch Logs?

- A. Configure the IAM policy in use by the IAM role to have access to the required cloudwatch: API actions that will publish logs.
- B. Adjust the Amazon EC2 Auto Scaling service-linked role to have permissions to write to CloudWatch Logs.
- C. Configure the IAM policy in use by the IAM role to have access to the required AWS logs: API actions that will publish logs.
- D. Add an interface VPC endpoint to provide a route to CloudWatch Logs.

▼ 中文:

一个 Amazon EC2 Auto Scaling 组启动 Amazon Linux EC2 实例，并安装 Amazon CloudWatch agent 以将日志发布到 Amazon CloudWatch Logs。EC2 实例使用附加了 IAM 策略的 IAM 角色启动。该策略提供了向 CloudWatch 发布自定义指标的权限。EC2 实例运行在 VPC 内的私有子网中，VPC 通过 NAT 网关为私有子网提供访问互联网的能力。

一名安全工程师注意到，Auto Scaling 组启动的 EC2 实例没有将日志发布到 CloudWatch Logs。安全工程师验证了 CloudWatch Logs agent 正在运行，并且在 EC2 实例上配置正确。此外，安全工程师验证了与 AWS 服务的网络通信工作正常。安全工程师可以做什么来确保日志发布到 CloudWatch Logs？

- A. 配置 IAM 角色使用的 IAM 策略，以获得发布日志所需的 cloudwatch: API 操作权限。
- B. 调整 Amazon EC2 Auto Scaling 服务关联角色，使其具有向 CloudWatch Logs 写入权限。
- C. 配置 IAM 角色使用的 IAM 策略，以获得发布日志所需的 AWS logs: API 操作权限。
- D. 加一个接口 VPC 终端节点，以提供到 CloudWatch Logs 的路由。

▼ 答案:

C

1. 考察的知识点
IAM角色和策略的权限配置。

Amazon CloudWatch Logs的API权限要求。
VPC网络配置与服务访问。

2. 选项分析

A. Configure the IAM policy in use by the IAM role to have access to the required cloudwatch: API actions that will publish logs.

错误：CloudWatch Logs的API权限与cloudwatch: API actions不同。
CloudWatch Logs需要特定的logs: API权限，而不是cloudwatch: API权限。

B. Adjust the Amazon EC2 Auto Scaling service-linked role to have permissions to write to CloudWatch Logs.

错误：EC2 Auto Scaling服务关联角色的权限与EC2实例的日志发布无关。日志发布是由EC2实例的IAM角色负责，而不是Auto Scaling服务关联角色。

C. Configure the IAM policy in use by the IAM role to have access to the required AWS logs: API actions that will publish logs.

正确：CloudWatch Logs需要logs: API权限，例如logs:PutLogEvents和logs:CreateLogStream。这是解决问题的关键。

D. Add an interface VPC endpoint to provide a route to CloudWatch Logs.

错误：题目中已经说明网络通信正常，私有子网通过NAT网关可以访问互联网，因此不需要额外添加VPC终端节点。

▼ 26

▼ 英文:

A company uses Amazon Elastic Container Service (Amazon ECS) containers that have the Fargate launch type. The containers run web and mobile applications that are written in Java and Node.js. To meet network segmentation requirements, each of the company's business units deploys applications in its own dedicated AWS account. Each business unit stores container images in an Amazon Elastic Container Registry (Amazon ECR) private registry in its own account.

A security engineer must recommend a solution to scan ECS containers and ECR registries for vulnerabilities in operating systems and programming language libraries. The company's audit team must be able to identify potential vulnerabilities that exist in any of the accounts where applications are deployed. Which solution will meet these requirements?

A. In each account, update the ECR registry to use Amazon Inspector instead of the default scanning service. Configure Amazon Inspector to forward vulnerability findings to AWS Security Hub in a central security account. Provide access for the audit team to use Security Hub to review the findings.

B. In each account, configure AWS Config to monitor the configuration of the ECS containers and the ECR registry.

Configure AWS Config conformance packs for vulnerability scanning. Create an AWS Config aggregator in a central account to collect configuration and compliance details from all accounts. Provide the audit team with access to AWS Config in the account where the aggregator is configured.

C. In each account, configure AWS Audit Manager to scan the ECS containers and the ECR registry. Configure Audit Manager to forward vulnerability findings to AWS Security Hub in a central security account. Provide access for the audit team to use Security Hub to review the findings.

D. In each account, configure Amazon GuardDuty to scan the ECS containers and the ECR registry. Configure GuardDuty to forward vulnerability findings to AWS Security Hub in a central security account. Provide access for the audit team to use Security Hub to review the findings.

▼ 中文:

一家公司使用具有 Fargate 启动类型的 Amazon Elastic Container Service (Amazon ECS) 容器。这些容器运行用 Java 和 Node.js 编写的 Web 和移动应用程序。为了满足网络分段要求，该公司的每个业务部门在其专属的 AWS 账户中部署应用程序。每个业务部门将容器镜像存储在其账户中的 Amazon Elastic Container Registry (Amazon ECR) 私有注册表中。

一名安全工程师必须推荐一个解决方案，用于扫描 ECS 容器和 ECR 注册表中的操作系统和编程语言库的漏洞。公司的审计团队必须能够识别任何部署应用程序的账户中存在的潜在漏洞。

哪个解决方案可以满足这些要求？

A. 在每个账户中，将 ECR 注册表更新为使用 Amazon Inspector 而不是默认的扫描服务。配置 Amazon Inspector 将漏洞发现转发到中央安全账户中的 AWS Security Hub。为审计团队提供访问权限，以使用 Security Hub 审查发现结果。

B. 在每个账户中，配置 AWS Config 以监控 ECS 容器和 ECR 注册表的配置。配置 AWS Config 合规包进行漏洞扫描。在中央账户中创建一个 AWS Config 聚合器，以收集所有账户的配置和合规性详细信息。为审计团队提供访问权限，以在配置了聚合器的账户中使用 AWS Config。

C. 在每个账户中，配置 AWS Audit Manager 扫描 ECS 容器和 ECR 注册表。配置 Audit Manager 将漏洞发现转发到中央安全账户中的 AWS Security Hub。为审计团队提供访问权限，以使用 Security Hub 审查发现结果。

D. 在每个账户中，配置 Amazon GuardDuty 扫描 ECS 容器和 ECR 注册表。配置 GuardDuty 将漏洞发现转发到中央安全账户中的 AWS Security Hub。为审计团队提供访问权限，以使用 Security Hub 审查发现结果。

▼ 答案:

A.

1. 考察的知识点

Amazon Inspector的功能及其与ECR的集成，用于扫描容器镜像的漏洞。
AWS Security Hub的作用，用于集中管理和审查安全发现。
跨账户安全管理和审计的最佳实践。

2. 选项分析

A. In each account, update the ECR registry to use Amazon Inspector instead of the default scanning service. Configure Amazon Inspector to forward vulnerability findings to AWS Security Hub in a central security account. Provide access for the audit team to use Security Hub to review the findings.

分析：

Amazon Inspector支持扫描ECR容器镜像的漏洞，符合题目要求。
Amazon Inspector可以将发现结果转发到AWS Security Hub，便于集中管理和审查。
为审计团队提供访问权限以使用Security Hub审查发现结果是合理的解决方案。
此选项完全符合题目要求。

B. In each account, configure AWS Config to monitor the configuration of the ECS containers and the ECR registry. Configure AWS Config conformance packs for vulnerability scanning. Create an AWS Config aggregator in a central account to collect configuration and compliance details from all accounts. Provide the audit team with access to AWS Config in the account where the aggregator is configured.

分析：

AWS Config主要用于监控资源配置和合规性，而不是专门用于漏洞扫描。
虽然可以使用合规包，但这不是针对容器镜像漏洞扫描的最佳工具。
此选项不符合题目要求。

C. In each account, configure AWS Audit Manager to scan the ECS containers and the ECR registry. Configure Audit Manager to forward vulnerability findings to AWS Security Hub in a central security account. Provide access for the audit team to use Security Hub to review the findings.

分析：

AWS Audit Manager用于审计和合规性报告，而不是漏洞扫描工具。
Community vote distribution

社区投票分布

A (90%) D (10%)

<https://shop542998714.m.taobao.com> <https://www.goofish.com/personal?userId=2645260430>

AWS Audit Manager用于审计和合规性报告，而不是漏洞扫描工具。

Audit Manager无法直接扫描ECS容器或ECR镜像的漏洞。
此选项不符合题目要求。

D. In each account, configure Amazon GuardDuty to scan the ECS containers and the ECR registry. Configure GuardDuty to forward vulnerability findings to AWS Security Hub in a central security account. Provide access for the audit team to use Security Hub to review the findings.

分析：

Amazon GuardDuty主要用于检测恶意活动和异常行为，而不是专门用于漏洞扫描。

GuardDuty无法直接扫描ECS容器

▼ 27

▼ 英文:

A company uses Amazon EC2 Linux instances in the AWS Cloud. A member of the company's security team recently received a report about common vulnerability identifiers on the instances.

A security engineer needs to verify patching and perform remediation if the instances do not have the correct patches installed. The security engineer must determine which EC2 instances are at risk and must implement a solution to automatically update those instances with the applicable patches.

What should the security engineer do to meet these requirements?

A. Use AWS Systems Manager Patch Manager to view vulnerability identifiers for missing patches on the instances. Use Patch Manager also to automate the patching process.

B. Use AWS Shield Advanced to view vulnerability identifiers for missing patches on the instances. Use AWS Systems Manager Patch Manager to automate the patching process.

C. Use Amazon GuardDuty to view vulnerability identifiers for missing patches on the instances. Use Amazon Inspector to automate the patching process.

D. Use Amazon Inspector to view vulnerability identifiers for missing patches on the instances. Use Amazon Inspector also to automate the patching process.

▼ 中文:

一家公司在AWS云中使用Amazon EC2 Linux实例。公司的安全团队成员最近收到关于实例上的常见漏洞标识符的报告。

一位安全工程师需要验证补丁情况，并在实例未安装正确补丁时执行修复操作。安全工程师必须确定哪些EC2实例存在风险，并且必须实施解决方案以自动更新这些实例的适用补丁。

安全工程师应该怎么做以满足这些要求？

- A.使用AWS Systems Manager Patch Manager查看实例上缺失补丁的漏洞标识符。还使用Patch Manager来自动化补丁过程。
- B.使用AWS Shield Advanced查看实例上缺失补丁的漏洞标识符。使用AWS Systems Manager Patch Manager来自动化补丁过程。
- C.使用Amazon GuardDuty查看实例上缺失补丁的漏洞标识符。使用Amazon Inspector来自动化补丁过程。
- D.使用Amazon Inspector查看实例上缺失补丁的漏洞标识符。还使用Amazon Inspector来自动化补丁过程。

▼ 答案:

A.

1. 考察的知识点

本题考察AWS服务中与安全补丁管理相关的功能，特别是AWS Systems Manager Patch Manager和其他安全服务的使用。

重点在于如何识别漏洞（vulnerability identifiers）并自动化补丁管理。

2. 选项分析

A. Use AWS Systems Manager Patch Manager to view vulnerability identifiers for missing patches on the instances. Use Patch Manager also to automate the patching process.

正确：AWS Systems Manager Patch Manager是专门设计用于管理和自动化补丁的服务。它可以扫描实例以识别缺失的补丁，并提供自动化补丁安装功能。

符合题目要求：可以查看漏洞标识符并自动更新实例补丁。

B. Use AWS Shield Advanced to view vulnerability identifiers for missing patches on the instances. Use AWS Systems Manager Patch Manager to automate the patching process.

错误：AWS Shield Advanced主要用于保护应用免受DDoS攻击，而不是用于查看漏洞标识符或管理补丁。

虽然提到使用Patch Manager自动化补丁过程是正确的，但Shield Advanced与漏洞标识符无关。

C. Use Amazon GuardDuty to view vulnerability identifiers for missing patches on the instances. Use Amazon Inspector to automate the patching process.

错误：Amazon GuardDuty是威胁检测服务，用于识别恶意活动和异常行为，但它不负责查看漏洞标识符或管理补丁。

Amazon Inspector可以用于漏洞扫描，但它不能直接自动化补丁过程。

D. Use Amazon Inspector to view vulnerability identifiers for missing patches on the instances. Use Amazon Inspector also to automate the patching process.

部分正确：Amazon Inspector可以扫描实例以识别漏洞标识符，但它不能直接自动化补丁过程。

错误：Amazon Inspector的功能不包括补丁自动化，补丁管理需要使用AWS Systems Manager Patch Manager。

▼ 28

▼ 英文:

A company hosts an application on Amazon EC2 that is subject to specific rules for regulatory compliance. One rule states that traffic to and from the workload must be inspected for network-level attacks. This involves inspecting the whole packet.

To comply with this regulatory rule, a security engineer must install intrusion detection software on a c5n.4xlarge EC2 instance.

The engineer must then configure the software to monitor traffic to and from the application instances.

What should the security engineer do next?

- A. Place the network interface in promiscuous mode to capture the traffic
- B. Configure VPC Flow Logs to send traffic to the monitoring EC2 instance using a Network Load Balancer.
- C. Configure VPC traffic mirroring to send traffic to the monitoring EC2 instance using a Network Load Balancer.
- D. Use Amazon Inspector to detect network-level attacks and trigger an AWS Lambda function to send the suspicious packets to the EC2 instance.

▼ 中文:

一家公司在 Amazon EC2 上托管了一个应用程序，该应用程序需要遵守特定的监管合规规则。规则之一规定，工作负载的流量必须接受网络级攻击的检查。这涉及到检查整个数据包。

为了遵守这一监管规则，安全工程师必须在一个 c5n.4xlarge EC2 实例上安装入侵检测软件。然后工程师需要配置该软件以监控应用程序实例的进出流量。

安全工程师接下来应该做什么？

- A.将网络接口设置为混杂模式以捕获流量。
- B.配置 VPC Flow Logs，将流量发送到使用 Network Load Balancer 的监控 EC2 实例。
- C.配置 VPC 流量镜像，将流量发送到使用 Network Load Balancer 的监控 EC2 实例。
- D.使用 Amazon Inspector 检测网络级攻击，并触发 AWS Lambda 函数将可疑数据包发送到 EC2 实例。

▼ 答案:

C

VPC流量镜像(Traffic Mirroring)的功能与配置。

如何实现网络流量的深度包检测(Deep Packet Inspection)。

AWS服务的适用场景，例如Amazon Inspector与VPC Flow Logs的区别。

2. 选项分析

A. Place the network interface in promiscuous mode to capture the traffic

错误:AWS EC2实例的网络接口不支持直接设置为混杂模式。混杂模式通常用于传统网络设备或虚拟化环境，但在AWS

中，流量捕获需要通过VPC流量镜像或其他工具。

B. Configure VPC Flow Logs to send traffic to the monitoring EC2 instance using a Network Load Balancer

错误:VPC Flow Logs仅记录元数据(例如源IP、目标IP、端口号等)，而不是捕获完整的数据包。题目要求对整个数

据包进行检测，因此VPC Flow Logs无法满足需求。

C. Configure VPC traffic mirroring to send traffic to the monitoring EC2 instance using a Network Load Balancer

正确:VPC流量镜像允许捕获网络流量的完整数据包，并将其发送到目标实例进行分析。此功能完全符合题目要求的深度包检测。

D. Use Amazon Inspector to detect network-level attacks and trigger an AWS Lambda function to send the suspicious packets to the EC2 instance

错误:Amazon Inspector主要用于评估EC2实例的安全漏洞和合规性，而不是实时捕获和分析网络流量。它无法满足题目中对网络级攻击检测的要求。

▼ 29

▼ 英文:

A company deploys a distributed web application on a fleet of Amazon EC2 instances. The fleet is behind an Application Load Balancer (ALB) that will be configured to terminate the TLS connection. All TLS traffic to the ALB must stay secure, even if the certificate private key is compromised.

How can a security engineer meet this requirement?

A. Create an HTTPS listener that uses a certificate that is managed by AWS Certificate Manager (ACM).

B. Create an HTTPS listener that uses a security policy that uses a cipher suite with perfect forward secrecy (PFS).

C. Create an HTTPS listener that uses the Server Order Preference security feature.

D. Create a TCP listener that uses a custom security policy that allows only cipher suites with perfect forward secrecy(PFS).

▼ 中文:

一家公司在—组 Amazon EC2 实例上部署了一个分布式 Web 应用程序。该实例组位于一个 Application Load Balancer (ALB) 后面，ALB 将被配置为终止 TLS 连接。即使证书的私钥被泄露，所有到 ALB 的 TLS 流量也必须保持安全。安全工程师如何满足此要求？

A.创建一个使用由 AWS Certificate Manager (ACM) 管理的证书的 HTTPS 监听器。

B.创建一个使用包含完美前向保密 (PFS) 的密码套件的安全策略的 HTTPS 监听器。

C.创建一个使用 Server Order Preference 安全功能的 HTTPS 监听器。

D.创建一个使用仅允许包含完美前向保密 (PFS) 的密码套件的自定义安全策略的 TCP 监听器。

▼ 答案:

B

1. 考察的知识点

本题考察的是TLS安全性，特别是如何确保即使证书私钥泄露，TLS流量仍然保持安全。

涉及的技术包括Perfect Forward Secrecy (PFS)、AWS Certificate Manager (ACM)、安全策略配置等。

2. 选项分析

A. Create an HTTPS listener that uses a certificate that is managed by AWS Certificate Manager (ACM).

错误:虽然ACM可以简化证书管理，但它并不能直接解决私钥泄露后的安全问题。ACM的主要功能是管理证书，而不是提供Perfect Forward Secrecy (PFS)。

B. Create an HTTPS listener that uses a security policy that uses a cipher suite with perfect forward secrecy (PFS).

正确:Perfect Forward Secrecy (PFS)确保即使私钥泄露，之前的会话数据仍然无法被解密。通过配置支持PFS的安全策略，可以满足题目要求。

C. Create an HTTPS listener that uses the Server Order Preference security feature.

错误:Server Order Preference允许服务器优先选择密码套件，但它并不能保证使用PFS，也无法解决私钥泄露后的安全问题。

D. Create a TCP listener that uses a custom security policy that allows only

cipher suites with perfect forward secrecy (PFS).

错误:TCP监听器不支持TLS终止，无法满足题目要求。题目明确要求在ALB上配置HTTPS监听器，而不是TCP监听器。

▼ 30

▼ 英文:

A company recently adopted new compliance standards that require all user actions in AWS to be logged. The user actions must be logged for all accounts that belong to an organization in AWS Organizations. The company needs to set alarms that respond when specified actions occur. The alarms must forward alerts to an email distribution list. The alerts must occur in as close to real time as possible.

Which solution will meet these requirements?

A. Implement an AWS CloudTrail trail as an organizational trail. Configure the trail with Amazon CloudWatch Logs forwarding. In CloudWatch Logs, set a metric filter for any user action events that the company specifies. Create an Amazon CloudWatch alarm to provide alerts for occurrences within a reported period and to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic.

B. Implement an AWS CloudTrail trail. Configure the trail with Amazon CloudWatch Logs forwarding. In CloudWatch Logs, set a metric filter for any user action events that the company specifies. Create an Amazon CloudWatch alarm to provide alerts for occurrences within a reported period and to send messages to an Amazon Simple Queue Service (Amazon SQS) queue.

C. Implement an AWS CloudTrail trail as an organizational trail. Configure the trail to store logs in an Amazon S3 bucket. Configure an Amazon EC2 instance to mount the S3 bucket as a file system to ingest new log files that are pushed to the S3 bucket. Configure the EC2 instance also to publish a message to an Amazon Simple Notification Service (Amazon SNS) topic when one of the specified actions is found in the logs.

D. Implement an AWS CloudTrail trail. Configure the trail to store logs in an Amazon S3 bucket. Each hour, create an AWS Glue Data Catalog that references the S3 bucket. Configure Amazon Athena to initiate queries against the Data Catalog to identify the specified actions in the logs.

▼ 中文:

一家公司最近采用了新的合规标准，要求记录所有用户在 AWS 中的操作。这些用户操作必须记录在属于 AWS Organizations 的所有账户中。公司需要设置警报，以便在指定操作发生时作出响应。警报必须将通知转发到一个电子邮件分发列表。通知必须尽可能接近实时发生。

哪种解决方案可以满足这些要求？

A.实施一个 AWS CloudTrail 跟踪作为组织跟踪。将该跟踪配置为使用 Amazon CloudWatch Logs 转发。在 CloudWatch Logs 中，为公司指定的任何用户操作事件设置一个指标过滤器。创建一个 Amazon CloudWatch 警报，以提供报告期内发生的事件的通知，并将消息发布到一个 Amazon Simple Notification Service (Amazon SNS) 主题。

B.实施一个 AWS CloudTrail 跟踪。将该跟踪配置为使用 Amazon CloudWatch Logs 转发。在 CloudWatch Logs 中，为公司指定的任何用户操作事件设置一个指标过滤器。创建一个 Amazon CloudWatch 警报，以提供报告期内发生的事件的通知，并将消息发送到一个 Amazon Simple Queue Service (Amazon SQS) 队列。

C.实施一个 AWS CloudTrail 跟踪作为组织跟踪。将该跟踪配置为将日志存储在一个 Amazon S3 存储桶中。配置一个 Amazon EC2 实例，将 S3 存储桶挂载为文件系统，以便摄取推送到 S3 存储桶的新日志文件。还配置 EC2 实例，当在日志中发现指定操作时，将消息发布到一个 Amazon Simple Notification Service (Amazon SNS) 主题。

D.实施一个 AWS CloudTrail 跟踪。将该跟踪配置为将日志存储在一个 Amazon S3 存储桶中。每小时创建一个 AWS Glue Data Catalog，引用该 S3 存储桶。配置 Amazon Athena 发起针对 Data Catalog 的查询，以识别日志中指定的操作。

▼ 答案:

A

1. 考察的知识点

AWS CloudTrail的功能和组织级别的配置。

Amazon CloudWatch Logs的日志过滤和指标创建。

Amazon CloudWatch Alarm的配置和与SNS的集成。

实时监控和告警机制的设计。

2. 选项分析

A. Implement an AWS CloudTrail trail as an organizational trail. Configure the trail with Amazon CloudWatch Logs forwarding.

In CloudWatch Logs, set a metric filter for any user action events that the company specifies. Create an Amazon CloudWatch alarm to provide alerts for occurrences within a reported period and to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic.

正确:组织级别的CloudTrail可以覆盖所有账户，满足公司要求的“所有账户的用户操作都需要被记录”。

正确:CloudWatch Logs可以接收CloudTrail日志并设置指标过滤器以监控指定的用户操作事件。

正确:CloudWatch Alarm可以基于指标触发告警，并通过SNS发送通知到电子邮件分发列表。

符合实时告警的要求。

B. Implement an AWS CloudTrail trail. Configure the trail with Amazon CloudWatch Logs forwarding. In CloudWatch Logs, set a metric filter for any user action events that the company specifies. Create an Amazon CloudWatch alarm to provide alerts for occurrences within a reported period and to send messages to an Amazon Simple Queue Service (Amazon SQS) queue.

错误:虽然CloudTrail和CloudWatch Logs的配置是正确的，但SQS队列不适合直接发送告警到电子邮件分发列表。

错误:SQS主要用于消息队列处理，而不是直接发送通知到用户。

C. Implement an AWS CloudTrail trail as an organizational trail. Configure the trail to store logs in an Amazon S3 bucket.

Configure an Amazon EC2 instance to mount the S3 bucket as a file system to ingest new log files that are pushed to the S3 bucket. Configure the EC2 instance also to publish a message to an Amazon Simple Notification Service (Amazon SNS) topic when one of the specified actions is found in the logs.

错误:使用EC2实例处理日志文件增加了复杂性和成本，不符合最佳实践。

错误:实时性较差，因为需要等待日志文件推送到S3后再进行处理。

D. Implement an AWS CloudTrail trail. Configure the trail to store logs in an Amazon S3 bucket. Each hour, create an AWS Glue Data Catalog that references the S3 bucket. Configure Amazon Athena to initiate queries against the Data Catalog to identify the specified actions in the logs.

错误:每小时创建Glue Data Catalog和使用Athena查询日志不符合实时告警的要求。

错误:这种方法适合批量分析，而不是实时监控和告警。

▼ 31

▼ 英文:

A company wants to create a log analytics solution for logs generated from its on-premises devices. The logs are collected from the devices onto a server on premises. The company wants to use AWS services to perform near real-time log analysis. The company also wants to store these logs for 365 days for pattern matching and substring search capabilities later.

Which solution will meet these requirements with the LEAST development overhead?

A. Install Amazon Kinesis Agent on the on-premises server to send the logs to Amazon DynamoDB. Configure an AWS Lambda trigger on DynamoDB streams to perform near real-time log analysis. Export the DynamoDB data to Amazon S3 periodically. Run Amazon Athena queries for pattern matching and substring search. Set up S3 Lifecycle policies to delete the log data after 365 days.

B. Install Amazon Managed Streaming for Apache Kafka (Amazon MSK) on the on-premises server. Create an MSK cluster to collect the streaming data and analyze the data in real time. Set the data retention period to 365 days to store the logs

persistently for pattern matching and substring search.

C. Install Amazon Kinesis Agent on the on-premises server to send the logs to Amazon Kinesis Data Firehose. Configure Amazon Managed Service for Apache Flink (previously known as Amazon Kinesis Data Analytics) as the destination for real-time processing. Store the logs in Amazon OpenSearch Service for pattern matching and substring search. Configure an OpenSearch Service Index State Management (ISM) policy to delete the data after 365 days.

D. Use Amazon API Gateway and AWS Lambda to write the logs from the on-premises server to Amazon DynamoDB. Configure a Lambda trigger on DynamoDB streams to perform near real-time log analysis. Run Amazon Athena federated queries on DynamoDB data for pattern matching and substring search. Set up TTL to delete data after 365 days.

▼ 中文:

一家公司希望为其本地设备生成的日志创建一个日志分析解决方案。这些日志从设备收集到本地的服务器上。该公司希望使用AWS服务来执行近实时的日志分析。公司还希望将这些日志存储365天，以便之后进行模式匹配和子字符串搜索功能。

哪种解决方案可以以最少的开发开销满足这些需求？

A.在本地服务器上安装Amazon Kinesis Agent，将日志发送到Amazon DynamoDB。在DynamoDB流上配置AWS Lambda触发器以执行近实时日志分析。定期将DynamoDB数据导出到Amazon S3。运行Amazon Athena查询以进行模式匹配和子字符串搜索。设置S3生命周期策略以在365天后删除日志数据。

B.在本地服务器上安装Amazon Managed Streaming for Apache Kafka (Amazon MSK)。创建一个MSK集群以收集流数据并实时分析数据。将数据保留期限设置为365天，以便持久存储日志用于模式匹配和子字符串搜索。

C.在本地服务器上安装Amazon Kinesis Agent，将日志发送到Amazon Kinesis Data Firehose。将Amazon Managed Service for Apache Flink(以前称为Amazon Kinesis Data Analytics)配置为实时处理的目标。将日志存储在Amazon OpenSearch Service中以进行模式匹配和子字符串搜索。配置OpenSearch Service Index State Management (ISM)策略以在365天后删除数据。

D.使用Amazon API Gateway和AWS Lambda将日志从本地服务器写入Amazon DynamoDB。在DynamoDB流上配置Lambda触发器以执行近实时日志分析。运行Amazon Athena联邦查询以对DynamoDB数据进行模式匹配和子字符串搜索。设置TTL以在365天后删除数据。

▼ 答案:

C

1. 考察的知识点

日志收集与处理:如何从本地设备收集日志并发送到AWS服务。

实时数据分析:使用AWS服务进行近实时日志分析。

数据存储与查询:如何存储日志数据并支持模式匹配和子字符串搜索。

数据生命周期管理:如何设置策略以自动删除过期数据。

2. 选项分析

A. Install Amazon Kinesis Agent on the on-premises server to send the logs to Amazon DynamoDB...

正确性分析:Amazon Kinesis Agent可以收集日志并发送到DynamoDB，但DynamoDB并不适合存储大量日志数据，尤其是需要支持复杂查询(如模式匹配和子字符串搜索)。此外，定期导出到S3并使用Athena查询增加了开发复杂性。

错误原因:开发复杂性较高，DynamoDB不适合日志存储和复杂查询。

B. Install Amazon Managed Streaming for Apache Kafka (Amazon MSK)...

正确性分析:Amazon MSK可以用于实时数据流处理，但它主要是一个流处理平台，不适合长期存储数据。设置365天

的数据保留期会导致存储成本高昂，且不支持直接的模式匹配和子字符串搜索。

错误原因:MSK不适合长期存储日志数据，且不支持复杂查询。

C. Install Amazon Kinesis Agent on the on-premises server to send the logs to Amazon Kinesis Data Firehose...

正确性分析:Amazon Kinesis Agent可以高效地收集日志并发送到Kinesis Data Firehose。Firehose可以直接将数据存储到Amazon OpenSearch Service，OpenSearch支持复杂查询(如模式匹配和子字符串搜索)。此外，OpenSearch的Index State Management (ISM)策略可以自动删除过期数据，符合365天的要求。

正确原因:此选项提供了一个低开发复杂性、高效的解决方案，满足所有需求。

D. Use Amazon API Gateway and AWS Lambda to write the logs from the on-premises server to Amazon DynamoDB...

正确性分析:使用API Gateway和Lambda将日志写入DynamoDB增加了开发复杂性。DynamoDB不适合复杂查询(如模式

匹配和子字符串搜索)，且TTL功能仅支持按时间删除数据，不支持复杂的生命周期管理。

错误原因:开发复杂性高，DynamoDB不适合日志存储和复杂查询。

▼ 32

▼ 英文:

A company has a large fleet of Linux Amazon EC2 instances and Windows EC2 instances that run in private subnets. The company wants all remote administration to be performed as securely as possible in the AWS Cloud.

Which solution will meet these requirements?

- A. Do not use SSH-RSA private keys during the launch of new instances Implement AWS Systems Manager Session Manager.
- B. Generate new SSH-RSA private keys for existing instances Implement AWS Systems Manager Session Manager.
- C. Do not use SSH-RSA private keys during the launch of new instances Configure EC2 Instance Connect.
- D. Generate new SSH-RSA private keys for existing instances Configure EC2 Instance Connect

▼ 中文:

一家公司拥有大量运行在私有子网中的 Linux Amazon EC2 实例和 Windows EC2 实例。该公司希望所有远程管理尽可能在 AWS 云中安全地进行。

哪种解决方案可以满足这些要求？

- A. 在启动新实例时不要使用 SSH-RSA 私钥 实现 AWS Systems Manager Session Manager
- B. 为现有实例生成新的 SSH-RSA 私钥 实现 AWS Systems Manager Session Manager
- C. 在启动新实例时不要使用 SSH-RSA 私钥 配置 EC2 Instance Connect
- D. 为现有实例生成新的 SSH-RSA 私钥 配置 EC2 Instance Connect

▼ 答案:

A

1. 考察的知识点

本题主要考察AWS Systems Manager Session Manager的功能和优势，以及如何安全地管理EC2实例的远程访问。

同时涉及SSH-RSA私钥的使用和EC2 Instance Connect的配置。

2. 选项分析

A. Do not use SSH-RSA private keys during the launch of new instances Implement AWS Systems Manager Session Manager

正确:AWS Systems Manager Session Manager是一种安全的远程管理工具，可以完全避免使用SSH-RSA私钥，从而减少

密钥管理的复杂性和潜在的安全风险。

正确:通过Session Manager，管理员可以直接通过AWS控制台或CLI安全地访问实例，无需暴露SSH端口。

B. Generate new SSH-RSA private keys for existing instances Implement AWS Systems Manager Session Manager

错误:虽然生成新的SSH-RSA私钥可以提高安全性，但仍然需要管理这些密钥，且无法完全避免密钥泄露的风险。

正确:实现AWS Systems Manager Session Manager是一个安全的解决方案，但生成新的SSH-RSA私钥并不必要。

C. Do not use SSH-RSA private keys during the launch of new instances
Configure EC2 Instance Connect

错误:EC2 Instance Connect主要用于临时访问Linux实例，功能有限，且仍然依赖SSH协议。

错误:虽然不使用SSH-RSA私钥是一个好的实践，但EC2 Instance Connect无法完全替代Session Manager的功能。

D. Generate new SSH-RSA private keys for existing instances
Configure EC2 Instance Connect

错误:生成新的SSH-RSA私钥仍然需要管理密钥，无法完全避免安全风险。

错误:EC2 Instance Connect的功能有限，无法满足“尽可能安全”的要求。

▼ 33

▼ 英文:

A company has decided to move its fleet of Linux-based web server instances to an Amazon EC2 Auto Scaling group. Currently, the instances are static and are launched manually. When an administrator needs to view log files, the administrator uses SSH to establish a connection to the instances and retrieves the logs manually.

The company often needs to query the logs to produce results about application sessions and user issues. The company does not want its new automatically scaling architecture to result in the loss of any log files when instances are scaled in.

Which combination of steps should a security engineer take to meet these requirements MOST cost-effectively? (Choose two.)

A. Configure a cron job on the instances to forward the log files to Amazon S3 periodically.

B. Configure AWS Glue and Amazon Athena to query the log files.

C. Configure the Amazon CloudWatch agent on the instances to forward the logs to Amazon CloudWatch Logs.

D. Configure Amazon CloudWatch Logs Insights to query the log files.

E. Configure the instances to write the logs to an Amazon Elastic File System (Amazon EFS) volume.

▼ 中文:

一家公司决定将其基于 Linux 的 Web 服务器实例迁移到 Amazon EC2 Auto Scaling 组。目前，这些实例是静态的，并且是手动启动的。当管理员需要查看日志文件时，管理员使用 SSH 与实例建立连接并手动检索日志。该公司经常需要查询日志以生成有关应用程序会话和用户问题的结果。该公司不希望其新的自动扩展架构在实例缩减时

导致任何日志文件丢失。安全工程师应采取哪些步骤组合以最具成本效益地满足这些要求?(选择两项)

- A.在实例上配置一个 cron 作业以定期将日志文件转发到 Amazon S3。
- B.配置 AWS Glue 和 Amazon Athena 查询日志文件。
- C.在实例上配置 Amazon CloudWatch agent，将日志转发到 Amazon CloudWatch Logs。
- D.配置 Amazon CloudWatch Logs Insights 查询日志文件。
- E.将实例配置为将日志写入 Amazon Elastic File System (Amazon EFS) 卷。

▼ 答案:

CD

1. 考察的知识点

日志管理与持久化:如何在动态扩展的架构中确保日志不会丢失。

日志查询与分析:如何高效地查询和分析日志数据。

AWS服务的集成:Amazon CloudWatch Logs、CloudWatch Logs Insights等服务的
使用。

2. 选项分析

A. Configure a cron job on the instances to forward the log files to Amazon S3 periodically.

优点:Amazon S3是一个持久化存储解决方案，能够确保日志不会丢失。

缺点:需要额外的脚本和管理工作来设置cron作业，且查询日志时需要额外的工具(如 Athena)。

结论:虽然可以满足持久化需求，但不是最优的解决方案，且不够直接。

B. Configure AWS Glue and Amazon Athena to query the log files.

优点:Athena可以高效查询存储在S3中的日志文件。

缺点:需要额外的配置和成本，且题目中没有明确要求使用复杂的ETL流程(Glue)。

结论:不是最优的解决方案，成本较高。

C. Configure the Amazon CloudWatch agent on the instances to forward the logs to Amazon CloudWatch Logs.

优点:CloudWatch Logs是一个托管服务，能够实时收集和存储日志，且支持动态扩展的架构。

缺点:需要在每个实例上安装和配置CloudWatch agent。

结论:正确选项，能够满足日志持久化需求。

D. Configure Amazon CloudWatch Logs Insights to query the log files.

优点:CloudWatch Logs Insights能够直接查询存储在CloudWatch Logs中的日志，且支持复杂查询。

缺点:需要额外的学习成本，但功能强大且直接满足需求。

结论:正确选项，能够满足日志查询需求。

E. Configure the instances to write the logs to an Amazon Elastic File System

(Amazon EFS) volume.

优点:EFS是一个持久化存储解决方案，能够确保日志不会丢失。

缺点:需要额外的配置和成本，且不适合动态扩展的架构(实例可能无法共享EFS卷)。

结论:不是最优的解决方案。

▼ 34

▼ 英文:

A company uses an external identity provider to allow federation into different AWS accounts. A security engineer for the company needs to identify the federated user that terminated a production Amazon EC2 instance a week ago. What is the FASTEST way for the security engineer to identify the federated user?

A. Review the AWS CloudTrail event history logs in an Amazon S3 bucket and look for the TerminateInstances event to identify the federated user from the role session name.

B. Filter the AWS CloudTrail event history for the TerminateInstances event and identify the assumed IAM role. Review the AssumeRoleWithSAML event call in CloudTrail to identify the corresponding username.

C. Search the AWS CloudTrail logs for the TerminateInstances event and note the event time. Review the IAM Access Advisor tab for all federated roles. The last accessed time should match the time when the instance was terminated.

D. Use Amazon Athena to run a SQL query on the AWS CloudTrail logs stored in an Amazon S3 bucket and filter on the TerminateInstances event. Identify the corresponding role and run another query to filter the AssumeRoleWithWebIdentity event for the user name.

▼ 中文:

一家公司使用外部身份提供商来允许对不同AWS账户的联合访问。公司的安全工程师需要识别一周前终止生产环境Amazon EC2实例的联合用户。安全工程师识别联合用户的最快方法是什么？

A. 查看存储在Amazon S3桶中的AWS CloudTrail事件历史日志，并查找TerminateInstances事件，以通过角色会话名称识别联合用户。

B. 筛选AWS CloudTrail事件历史中的TerminateInstances事件并识别假设的IAM角色。查看CloudTrail中的AssumeRoleWithSAML事件调用以识别对应的用户名。

C. 搜索AWS CloudTrail日志中的TerminateInstances事件并记录事件时间。查看所有联合角色的IAM访问顾问标签。最后访问时间应与实例被终止的时间相匹配。

D. 使用Amazon Athena在存储于Amazon S3桶中的AWS CloudTrail日志上运行SQL查询，并筛选TerminateInstances事件。

识别对应的角色并运行另一个查询以筛选AssumeRoleWithWebIdentity事件以获取用户名。

▼ 答案:

B

1. 考察的知识点

本题考察AWS CloudTrail日志分析能力，尤其是如何通过CloudTrail事件追踪用户操作。

涉及联合身份验证（Federation）和角色假设（AssumeRole）的知识点。

需要理解如何快速定位用户操作并关联到具体的联合用户。

2. 选项分析

A. Review the AWS CloudTrail event history logs in an Amazon S3 bucket and look for the TerminateInstances event to identify the federated user from the role session name.

错误：虽然可以通过CloudTrail日志找到TerminateInstances事件，但仅通过角色会话名称无法直接识别联合用户的具体身份。

需要进一步分析AssumeRole相关事件才能关联到具体的联合用户。

B. Filter the AWS CloudTrail event history for the TerminateInstances event and identify the assumed IAM role. Review the AssumeRoleWithSAML event call in CloudTrail to identify the corresponding username.

正确：此方法直接通过CloudTrail筛选TerminateInstances事件，找到假设的IAM角色，然后进一步分析

AssumeRoleWithSAML事件以识别联合用户。

这是最快速且准确的方法，符合题目要求。

C. Search the AWS CloudTrail logs for the TerminateInstances event and note the event time. Review the IAM Access Advisor tab for all federated roles. The last accessed time should match the time when the instance was terminated.

错误：IAM Access Advisor提供的是角色的最近访问时间，但无法直接关联到具体的用户操作。

此方法较为间接且效率较低，不符合题目要求的“最快速”方式。

D. Use Amazon Athena to run a SQL query on the AWS CloudTrail logs stored in an Amazon S3 bucket and filter on the TerminateInstances event. Identify the corresponding role and run another query to filter the AssumeRoleWithWebIdentity event for the user name.

错误：虽然Athena可以查询CloudTrail日志，但需要额外的配置和查询步骤，耗时较长。

此外，AssumeRoleWithWebIdentity事件与SAML联合身份验证无关，可能导致错误的关联。

▼ 35

▼ 英文:

Two Amazon EC2 instances in different subnets should be able to connect to each other but cannot. It has been confirmed that other hosts in the same subnets are able to communicate successfully, and that security groups have valid ALLOW rules in place to permit this traffic.

Which of the following troubleshooting steps should be performed?

- A. Check inbound and outbound security groups, looking for DENY rules
- B. Check inbound and outbound Network ACL rules, looking for DENY rules
- C. Review the rejected packet reason codes in the VPC Flow Logs
- D. Use AWS X-Ray to trace the end-to-end application flow

▼ 中文:

两个不同子网中的 Amazon EC2 实例应该能够相互连接，但无法连接。已确认同一子网中的其他主机能够成功通信，并且安全组中已设置有效的 ALLOW 规则以允许此流量。

以下哪项故障排除步骤应该执行？

- A. 检查入站和出站安全组，查找 DENY 规则
- B. 检查入站和出站网络 ACL 规则，查找 DENY 规则
- C. 查看 VPC Flow Logs 中被拒绝的数据包原因代码
- D. 使用 AWS X-Ray 跟踪端到端应用程序流程

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS网络连接问题的排查方法，特别是与安全组和网络ACL相关的配置问题。

涉及的知识点包括：安全组规则、网络ACL规则、VPC Flow Logs的使用，以及AWS X-Ray的功能。

2. 选项分析

A. 检查入站和出站安全组，查找 DENY 规则

安全组在AWS中是“允许规则”，而不是“拒绝规则”。安全组不会有DENY规则，因此这个选项是错误的。

B. 检查入站和出站网络 ACL 规则，查找 DENY 规则

网络ACL是基于子网的规则，可以包含“允许规则”和“拒绝规则”。如果网络ACL中存在DENY规则，可能会阻止两个实例之间的通信。因此，这个选项是正确的。

C. 查看 VPC Flow Logs 中被拒绝的数据包原因代码

VPC Flow Logs可以帮助分析网络流量问题，但它是一个辅助工具，用于查看流量是否被拒绝以及原因代码。虽然它可以提供信息，但它不是直接的排查步骤，因此这个选项不是最佳答案。

D. 使用 AWS X-Ray 跟踪端到端应用程序流程

AWS X-Ray主要用于应用程序性能和分布式跟踪，而不是用于排查网络连接问

题。因此，这个选项与题目要求无关，是错误的。

▼ 36

▼ 英文:

A company has an application that needs to get objects from an Amazon S3 bucket. The application runs on Amazon EC2 instances. All the objects in the S3 bucket are encrypted with an AWS Key Management Service (AWS KMS) customer managed key. The resources in the VPC do not have access to the internet and use a gateway VPC endpoint to access Amazon S3.

The company discovers that the application is unable to get objects from the S3 bucket.

Which factors could cause this issue? (Choose three.)

- A. The IAM instance profile that is attached to the EC2 instances does not allow the s3:ListBucket action for the S3 bucket.
- B. The IAM instance profile that is attached to the EC2 instances does not allow the s3:ListParts action for the S3 bucket.
- C. The KMS key policy that encrypts the objects in the S3 bucket does not allow the kms:ListKeys action to the EC2 instance profile ARN.
- D. The KMS key policy that encrypts the objects in the S3 bucket does not allow the kms:Decrypt action to the EC2 instance profile ARN.
- E. The S3 bucket policy does not allow access from the gateway VPC endpoint.
- F. The security group that is attached to the EC2 instances is missing an inbound rule from the S3 managed prefix list over port 443.

Most Voted

▼ 中文:

一家公司有一个应用程序需要从 Amazon S3 存储桶中获取对象。该应用程序运行在 Amazon EC2 实例上。

S3 存储桶中的所有对象都使用 AWS Key Management Service (AWS KMS) 客户托管密钥进行加密。VPC 中的资源无法访问互联网，并使用网关 VPC 终端节点访问 Amazon S3。

该公司发现应用程序无法从 S3 存储桶中获取对象。

哪些因素可能导致此问题？（选择三个）

- A. 附加到 EC2 实例的 IAM 实例配置文件未允许 S3 存储桶的 s3:ListBucket 操作。
- B. 附加到 EC2 实例的 IAM 实例配置文件未允许 S3 存储桶的 s3:ListParts 操作。
- C. 加密 S3 存储桶中对象的 KMS 密钥策略未允许 EC2 实例配置文件 ARN 执行 kms:ListKeys 操作。
- D. 加密 S3 存储桶中对象的 KMS 密钥策略未允许 EC2 实例配置文件 ARN 执行 kms:Decrypt 操作。

E. S3 存储桶策略未允许来自网关 VPC 终端节点的访问。

F.附加到 EC2 实例的安全组缺少来自 S3 托管前缀列表的端口 443 的入站规则。

▼ 答案:

ADE

1. 考察的知识点

Amazon S3访问权限控制，包括IAM角色和策略。

AWS KMS密钥策略的配置与权限管理。

VPC网关终端节点与S3桶策略的交互。

2. 选项分析

A. The IAM instance profile that is attached to the EC2 instances does not allow the s3:ListBucket action for the S3 bucket.

分析：正确。为了访问S3桶中的对象，EC2实例需要有权限执行s3:ListBucket操作以列出桶中的内容。如果没有此权限，应用程序将无法获取对象。

B. The IAM instance profile that is attached to the EC2 instances does not allow the s3:ListParts action for the S3 bucket.

分析：错误。s3:ListParts操作用于列出分段上传的部分，与获取对象无关，因此不是问题的原因。

C. The KMS key policy that encrypts the objects in the S3 bucket does not allow the kms:ListKeys action to the EC2 instance profile ARN.

分析：错误。kms:ListKeys操作用于列出KMS密钥，与解密对象无关，因此不是问题的原因。

D. The KMS key policy that encrypts the objects in the S3 bucket does not allow the kms:Decrypt action to the EC2 instanceprofile ARN.

分析：正确。为了解密S3桶中的对象，EC2实例需要有权限执行kms:Decrypt操作。如果没有此权限，应用程序将无法解密对象。

E. The S3 bucket policy does not allow access from the gateway VPC endpoint.

分析：正确。S3桶策略需要明确允许来自网关VPC终端节点的访问。如果桶策略未配置正确，EC2实例将无法通过VPC终端节点访问S3桶。

F. The security group that is attached to the EC2 instances is missing an inbound rule from the S3 managed prefix list over port 443.

分析：错误。S3通过网关VPC终端节点访问时，不需要安全组的入站规则，因为流量是通过终端节点处理的，而不是直接通过安全组。

▼ 37

▼ 英文:

A company runs workloads in the us-east-1 Region. The company has never deployed resources to other AWS Regions and does not have any multi-Region resources. The company needs to replicate its workloads and infrastructure to the us-west-1 Region.

A security engineer must implement a solution that uses AWS Secrets Manager to store secrets in both Regions. The solution must use AWS Key Management Service (AWS KMS) to encrypt the secrets. The solution must minimize latency and must be able to work if only one Region is available.

The security engineer uses Secrets Manager to create the secrets in us-east-1. What should the security engineer do next to meet the requirements?

- A. Encrypt the secrets in us-east-1 by using an AWS managed KMS key. Replicate the secrets to us-west-1. Encrypt the secrets in us-west-1 by using a new AWS managed KMS key in us-west-1.
- B. Encrypt the secrets in us-east-1 by using an AWS managed KMS key. Configure resources in us-west-1 to call the Secrets Manager endpoint in us-east-1.
- C. Encrypt the secrets in us-east-1 by using a customer managed KMS key. Configure resources in us-west-1 to call the Secrets Manager endpoint in us-east-1.
- D. Encrypt the secrets in us-east-1 by using a customer managed KMS key. Replicate the secrets to us-west-1. Encrypt the secrets in us-west-1 by using the customer managed KMS key from us-east-1.

▼ 中文:

一家公司在 us-east-1 区域运行工作负载。该公司从未在其他 AWS 区域部署资源，也没有任何跨区域资源。该公司需要将其工作负载和基础设施复制到 us-west-1 区域。一名安全工程师必须实施一个解决方案，该解决方案使用 AWS Secrets Manager 在两个区域存储密钥。该解决方案必须使用 AWS Key Management Service (AWS KMS) 加密密钥。该解决方案必须最大限度地减少延迟，并且能够在只有一个区域可用时正常工作。

安全工程师使用 Secrets Manager 在 us-east-1 中创建密钥。安全工程师接下来应该怎么做以满足要求？

- A. 使用 AWS 托管 KMS 密钥加密 us-east-1 中的密钥。将密钥复制到 us-west-1。在 us-west-1 中使用新的 AWS 托管 KMS 密钥加密密钥。
- B. 使用 AWS 托管 KMS 密钥加密 us-east-1 中的密钥。在 us-west-1 中配置资源以调用 us-east-1 中的 Secrets Manager 端点。
- C. 使用客户托管 KMS 密钥加密 us-east-1 中的密钥。在 us-west-1 中配置资源以调用 us-east-1 中的 Secrets Manager 端点。
- D. 使用客户托管 KMS 密钥加密 us-east-1 中的密钥。将密钥复制到 us-west-1。在 us-west-1 中使用来自 us-east-1 的客户托管 KMS 密钥加密密钥。

▼ 答案:

D

1. 考察的知识点

跨区域资源复制与管理

AWS Secrets Manager的使用

AWS Key Management Service (KMS)的加密与密钥管理

高可用性与区域故障恢复

2. 选项分析

A.

错误:AWS Secrets Manager支持跨区域复制，但使用AWS托管KMS密钥无法满足“如果只有一个区域可用”的要求，因为托管密钥是区域性资源，无法跨区域共享。

B.

错误:虽然可以通过调用us-east-1的Secrets Manager端点来访问密钥，但这会增加跨区域调用的延迟，并且如果us-east-1不可用，us-west-1的资源将无法访问密钥。

C.

错误:虽然使用客户托管KMS密钥可以提供更高的控制，但依然存在跨区域调用的延迟问题，并且无法满足“如果只有一个区域可用”的要求。

D.

正确:使用客户托管KMS密钥可以跨区域共享密钥，并且Secrets Manager支持跨区域复制。这种方法确保了两个区域都有加密的密钥，并且在一个区域不可用时，另一个区域仍然可以正常工作。

▼ 38

▼ 英文:

A company is using an AWS Key Management Service (AWS KMS) AWS owned key in its application to encrypt files in an AWS account. The company's security team wants the ability to change to new key material for new files whenever a potential key breach occurs. A security engineer must implement a solution that gives the security team the ability to change the key whenever the team wants to do so.

Which solution will meet these requirements?

A. Create a new customer managed key. Add a key rotation schedule to the key. Invoke the key rotation schedule every time the security team requests a key change.

B. Create a new AWS managed key. Add a key rotation schedule to the key. Invoke the key rotation schedule every time the security team requests a key change.

C. Create a key alias. Create a new customer managed key every time the security team requests a key change. Associate the alias with the new key.

D. Create a key alias. Create a new AWS managed key every time the security team requests a key change. Associate the alias with the new key.

▼ 中文:

一家公司在其应用程序中使用 AWS Key Management Service (AWS KMS) 的 AWS owned key 来加密 AWS 账户中的文件。

公司的安全团队希望能够在潜在的密钥泄露发生时，为新文件更换新的密钥材料。安全工程师必须实施一个解决方案，使安全团队能够随时更换密钥。

哪种解决方案可以满足这些要求？

A. 创建一个新的 customer managed key。为密钥添加一个密钥轮换计划。每次安全团队请求更换密钥时调用密钥轮换计划。

B. 创建一个新的 AWS managed key。为密钥添加一个密钥轮换计划。每次安全团队请求更换密钥时调用密钥轮换计划。

C. 创建一个密钥别名。每次安全团队请求更换密钥时创建一个新的 customer managed key。将别名与新密钥关联。

D. 创建一个密钥别名。每次安全团队请求更换密钥时创建一个新的 AWS managed key。将别名与新密钥关联。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS KMS(Key Management Service)的密钥管理，包括密钥轮换、密钥别名的使用，以及如何应对潜在的密钥泄露。

重点在于理解AWS KMS中Customer Managed Key和AWS Managed Key的区别，以及如何动态更新密钥以满足安全需求。

2. 选项分析

A. Create a new customer managed key. Add a key rotation schedule to the key. Invoke the key rotation schedule every time the security team requests a key change.

错误:密钥轮换是自动的，无法手动触发。AWS KMS的密钥轮换功能仅适用于AWS Managed Key，且无法满足“随时更换密钥”的需求。

B. Create a new AWS managed key. Add a key rotation schedule to the key. Invoke the key rotation schedule every time the

security team requests a key change.

错误:AWS Managed Key的轮换是自动的，无法手动触发。并且AWS Managed Key不支持用户主动创建新密钥。

C. Create a key alias. Create a new customer managed key every time the security team requests a key change. Associate the alias with the new key.

正确:使用密钥别名可以动态指向新的Customer Managed Key。每次创建新密钥后，将别名指向新密钥，满足“随时更换密钥”的需求。

D. Create a key alias. Create a new AWS managed key every time the security team requests a key change. Associate the alias with the new key.

错误:AWS Managed Key无法由用户主动创建，且无法满足动态更新密钥的需求。

▼ 39

▼ 英文:

A security engineer needs to set up an Amazon CloudFront distribution for an Amazon S3 bucket that hosts a static website.

The security engineer must allow only specified IP addresses to access the website. The security engineer also must prevent users from accessing the website directly by using S3 URLs. Which solution will meet these requirements?

A. Generate an S3 bucket policy. Specify cloudfront.amazonaws.com as the principal. Use the aws:SourceIp condition key to allow access only if the request comes from the specified IP addresses.

B. Create a CloudFront origin access control (OAC). Create the S3 bucket policy so that only the OAC has access. Create an AWS WAF web ACL, and add an IP set rule. Associate the web ACL with the CloudFront distribution.

C. Implement security groups to allow only the specified IP addresses access and to restrict S3 bucket access by using the CloudFront distribution.

D. Create an S3 bucket access point to allow access from only the CloudFront distribution. Create an AWS WAF web ACL and add an IP set rule. Associate the web ACL with the CloudFront distribution.

▼ 中文:

一位安全工程师需要为托管静态网站的 Amazon S3 存储桶设置一个 Amazon CloudFront 分发。安全工程师必须仅允许指定的 IP 地址访问该网站。安全工程师还必须防止用户通过使用 S3 URL 直接访问该网站。哪种解决方案可以满足这些要求？

- A.生成一个 S3 存储桶策略。指定 `cloudfront.amazonaws.com` 作为主体。使用 `aws:SourceIp` 条件键，仅当请求来自指定的 IP 地址时才允许访问。
- B.创建一个 CloudFront 源访问控制 (OAC)。创建 S3 存储桶策略，使只有 OAC 可以访问。创建一个 AWS WAF Web ACL，并添加一个 IP 集规则。将 Web ACL 与 CloudFront 分发关联。
- C.实施安全组，仅允许指定的 IP 地址访问，并通过使用 CloudFront 分发限制 S3 存储桶访问。
- D.创建一个 S3 存储桶访问点，仅允许来自 CloudFront 分发的访问。创建一个 AWS WAF Web ACL，并添加一个 IP 集规则。将 Web ACL 与 CloudFront 分发关联。

▼ 答案:

B

1. 考察的知识点

Amazon CloudFront与Amazon S3的集成。

使用AWS WAF进行IP地址过滤。

CloudFront Origin Access Control (OAC)的使用。

如何通过S3存储桶策略限制直接访问。

2. 选项分析

B (100%)

A. Generate an S3 bucket policy. Specify `cloudfront.amazonaws.com` as the principal. Use the `aws:SourceIp` condition key to allow access only if the request comes from the specified IP addresses.

分析:

此选项试图通过S3存储桶策略限制访问，但`aws:SourceIp`条件键无法直接应用于CloudFront请求，因为CloudFront的请求IP地址是CloudFront的内部IP，而不是用户的真实IP。

此外，这种方法无法防止用户直接通过S3 URL访问内容。

因此，此选项不符合要求。

B. Create a CloudFront origin access control (OAC). Create the S3 bucket policy so that only the OAC has access. Create an AWS WAF web ACL, and add an IP set rule. Associate the web ACL with the CloudFront distribution.

分析:

此选项使用CloudFront OAC来确保只有CloudFront可以访问S3存储桶，从而防止直接通过S3 URL访问内容。

通过AWS WAF Web ACL，可以基于IP地址过滤用户请求，满足限制指定IP地址访问的要求。

此选项完全符合题目要求，是正确的解决方案。

C. Implement security groups to allow only the specified IP addresses access and to restrict S3 bucket access by using the

CloudFront distribution.

分析:

安全组用于控制EC2实例的网络流量，而不是用于控制S3存储桶或CloudFront的访问。

此选项与题目场景不相关，因此是错误的。

D. Create an S3 bucket access point to allow access from only the CloudFront distribution. Create an AWS WAF web ACL and add an IP set rule. Associate the web ACL with the CloudFront distribution.

分析:

S3存储桶访问点可以限制访问来源，但它无法直接与CloudFront集成以防止通过S3 URL直接访问内容。

虽然AWS WAF Web ACL可以限制IP地址，但此选项未正确解决如何防止直接通过S3 URL访问的问题。

因此，此选项不符合要求。

▼ 40

▼ 英文:

A company uses user data scripts that contain sensitive information to bootstrap Amazon EC2 instances. A security engineer discovers that this sensitive information is viewable by people who should not have access to it. What is the MOST secure way to protect the sensitive information used to bootstrap the instances?

A. Store the scripts in the AMI and encrypt the sensitive data using AWS KMS. Use the instance role profile to control access to the KMS keys needed to decrypt the data.

B. Store the sensitive data in AWS Systems Manager Parameter Store using the encrypted string parameter and assign the GetParameters permission to the EC2 instance role.

C. Externalize the bootstrap scripts in Amazon S3 and encrypt them using AWS KMS. Remove the scripts from the instance and clear the logs after the instance is configured.

D. Block user access of the EC2 instance's metadata service using IAM policies. Remove all scripts and clear the logs after the scripts have completed.

▼ 中文:

一家公司使用包含敏感信息的用户数据脚本来引导 Amazon EC2 实例。安全工程师发现这些敏感信息可以被不应该访问它的人查看。保护用于引导实例的敏感信息的最安全方法是什么？

A. 将脚本存储在 AMI 中，并使用 AWS KMS 加密敏感数据。使用实例角色配置文件控制访问解密数据所需的 KMS 密钥。

B.将敏感数据存储在 AWS Systems Manager Parameter Store 中，使用加密字符串参数，并为 EC2 实例角色分配GetParameters 权限。

C.将引导脚本外部化到 Amazon S3 中，并使用 AWS KMS 加密它们。在实例配置完成后，移除脚本并清除日志。

D.使用 IAM 策略阻止用户访问 EC2 实例的元数据服务。在脚本完成后，移除所有脚本并清除日志。

▼ 答案:

B

1. 考察的知识点

EC2实例启动时的安全性最佳实践。

如何保护敏感数据，例如用户数据脚本。

AWS服务如AWS Systems Manager Parameter Store和AWS KMS的使用。
实例角色权限管理。

2. 选项分析

A. Store the scripts in the AMI and encrypt the sensitive data using AWS KMS. Use the instance role profile to control access to the KMS keys needed to decrypt the data.

优点：使用AWS KMS加密数据是安全的做法，实例角色可以控制对KMS密钥的访问。

缺点：将脚本存储在AMI中可能导致敏感数据暴露，因为AMI可以被共享或复制，增加了数据泄露的风险。

结论：此选项不够安全，敏感数据仍可能被暴露。

B. Store the sensitive data in AWS Systems Manager Parameter Store using the encrypted string parameter and assign the GetParameters permission to the EC2 instance role.

优点：AWS Systems Manager Parameter Store提供了加密字符串参数功能，可以安全地存储敏感数据。

优点：通过实例角色分配GetParameters权限，确保只有授权的实例可以访问敏感数据。

结论：此选项是最佳实践，符合安全性要求。

C. Externalize the bootstrap scripts in Amazon S3 and encrypt them using AWS KMS. Remove the scripts from the instance and clear the logs after the instance is configured.

优点：使用AWS KMS加密脚本是安全的做法。

缺点：将脚本存储在S3中可能导致额外的管理复杂性，且需要确保S3存储桶的访问权限配置正确。

结论：虽然此选项可以提高安全性，但相比Parameter Store，管理复杂性更高，且不如Parameter Store直接支持加密和权限管理。

D. Block user access of the EC2 instance's metadata service using IAM

policies. Remove all scripts and clear the logs after the scripts have completed.

优点：限制对EC2实例元数据服务的访问可以减少敏感信息泄露的风险。

缺点：此选项没有解决敏感数据的存储问题，且清除脚本和日志是事后操作，无法完全防止数据泄露。

结论：此选项不够全面，无法确保敏感数据的安全性。

▼ 41

▼ 英文:

A company has a VPC that has no internet access and has the private DNS hostnames option enabled. An Amazon Aurora database is running inside the VPC. A security engineer wants to use AWS Secrets Manager to automatically rotate the credentials for the Aurora database. The security engineer configures the Secrets Manager default AWS Lambda rotation function to run inside the same VPC that the Aurora database uses. However, the security engineer determines that the password cannot be rotated properly because the Lambda function cannot communicate with the Secrets Manager endpoint.

What is the MOST secure way that the security engineer can give the Lambda function the ability to communicate with the Secrets Manager endpoint?

- A. Add a NAT gateway to the VPC to allow access to the Secrets Manager endpoint.
- B. Add a gateway VPC endpoint to the VPC to allow access to the Secrets Manager endpoint.
- C. Add an interface VPC endpoint to the VPC to allow access to the Secrets Manager endpoint.
- D. Add an internet gateway for the VPC to allow access to the Secrets Manager endpoint.

▼ 中文:

一家公司有一个没有互联网访问权限的 VPC，并启用了私有 DNS 主机名选项。一个 Amazon Aurora 数据库运行在该 VPC 内。安全工程师希望使用 AWS Secrets Manager 自动轮换 Aurora 数据库的凭证。安全工程师配置了 Secrets Manager 默认的 AWS Lambda 轮换函数，使其运行在 Aurora 数据库使用的同一个 VPC 内。然而，安全工程师发现密码无法正确轮换，因为 Lambda 函数无法与 Secrets Manager 端点通信。

安全工程师可以采取什么最安全的方式使 Lambda 函数能够与 Secrets Manager 端点通信？

- A. 为 VPC 添加一个 NAT 网关以允许访问 Secrets Manager 端点。
- B. 为 VPC 添加一个网关 VPC 端点以允许访问 Secrets Manager 端点。

C.为 VPC 添加一个接口 VPC 端点以允许访问 Secrets Manager 端点。

D.为 VPC 添加一个互联网网关以允许访问 Secrets Manager 端点。

▼ 答案:

C

1. 考察的知识点

VPC网络配置与访问控制

AWS Secrets Manager的工作原理

如何安全地配置AWS Lambda与服务端点的通信

2. 选项分析

A. Add a NAT gateway to the VPC to allow access to the Secrets Manager endpoint.

错误：虽然NAT网关可以让私有子网中的资源访问互联网，但这并不是最安全的方式。Secrets Manager支持通过VPC接口端点直接访问，无需通过互联网。

B. Add a gateway VPC endpoint to the VPC to allow access to the Secrets Manager endpoint.

错误：Gateway VPC Endpoint主要用于S3和DynamoDB服务，而Secrets Manager需要使用Interface VPC Endpoint。

C. Add an interface VPC endpoint to the VPC to allow access to the Secrets Manager endpoint.

正确：Interface VPC Endpoint允许私有网络中的资源通过专用网络与AWS服务通信。Secrets Manager支持Interface VPC Endpoint，这是一种安全且高效的解决方案。

D. Add an internet gateway for the VPC to allow access to the Secrets Manager endpoint.

错误：添加互联网网关会暴露VPC中的资源到互联网，增加安全风险。这不是最安全的解决方案。

▼ 42

▼ 英文:

A company has two AWS accounts: Account A and Account B. Each account has a VPC. An application that runs in the VPC in Account A needs to write to an Amazon S3 bucket in Account B. The application in Account A already has permission to write to the S3 bucket in Account B. The application and the S3 bucket are in the same AWS Region. The company cannot send network traffic over the public internet.

Which solution will meet these requirements?

A. In both accounts, create a transit gateway and VPC attachments in a subnet in each Availability Zone. Update the VPC route tables.

B. Deploy a software VPN appliance in Account A. Create a VPN connection between the software VPN appliance and a virtual private gateway in Account B.

C. Create a VPC peering connection between the VPC in Account A and the VPC in Account B. Update the VPC route tables, network ACLs, and security groups to allow network traffic between the peered IP ranges.

D. In Account A, create a gateway VPC endpoint for Amazon S3. Update the VPC route table in Account A.

▼ 中文:

一家公司有两个AWS账户：账户A和账户B。每个账户都有一个VPC。运行在账户A的VPC中的应用程序需要写入账户B中的Amazon S3桶。账户A中的应用程序已经有权限写入账户B中的S3桶。

应用程序和S3桶位于同一个AWS区域。公司不能通过公共互联网发送网络流量。
哪种解决方案可以满足这些要求？

A.在两个账户中，创建一个transit gateway和每个可用区子网中的VPC附件。更新VPC路由表。

B.在账户A中部署一个软件VPN设备。创建一个软件VPN设备与账户B中的虚拟私有网关之间的VPN连接。

C.在账户A的VPC和账户B的VPC之间创建一个VPC对等连接。更新VPC路由表、网络ACL和安全组，以允许对等IP范围之间的网络流量。

D.在账户A中，为Amazon S3创建一个gateway VPC endpoint。更新账户A中的VPC路由表。

▼ 答案:

D

1. 考察的知识点

跨账户资源访问的配置

VPC网络连接选项（如VPC Peering、Transit Gateway、VPN等）

Amazon S3的访问机制（如Gateway VPC Endpoint）

如何避免通过公共互联网传输数据

2. 选项分析

A. 在两个账户中，创建一个transit gateway和每个可用区子网中的VPC附件。更新VPC路由表。

错误：Transit Gateway适用于复杂的多VPC连接场景，但在本题中仅涉及两个VPC之间的通信，使用Transit Gateway过于复杂且成本较高。

此外，Transit Gateway并不直接解决S3访问问题。

B. 在账户A中部署一个软件VPN设备。创建一个软件VPN设备与账户B中的虚拟私有网关之间的VPN连接。

错误：VPN连接通常用于跨区域或跨网络的通信，但本题明确说明应用和S3桶在同一区域内，因此不需要VPN。

此外，VPN连接的设置复杂且不适合直接访问S3。

C. 在账户A的VPC和账户B的VPC之间创建一个VPC对等连接。更新VPC路由表、网络ACL和安全组，以允许对等IP

范围之间的网络流量。

错误：VPC Peering适用于VPC之间的通信，但S3是区域级服务，不依赖VPC Peering。

此外，S3访问可以通过VPC Endpoint直接实现，无需VPC Peering。

D. 在账户A中，为Amazon S3创建一个gateway VPC endpoint。更新账户A中的VPC路由表。

正确：Gateway VPC Endpoint是专门为S3和DynamoDB设计的，可以通过私有网络直接访问S3，而无需通过公共互联网。

网。

此解决方案简单、成本低，并完全满足题目要求。

▼ 43

▼ 英文:

A security engineer receives a notice about suspicious activity from a Linux-based Amazon EC2 instance that uses Amazon Elastic Block Store (Amazon EBS)-based storage. The instance is making connections to known malicious addresses.

The instance is in a development account within a VPC that is in the us-east-1 Region. The VPC contains an internet gateway and has a subnet in us-east-1a and us-east-1b. Each subnet is associated with a route table that uses the internet gateway as a default route. Each subnet also uses the default network ACL. The suspicious EC2 instance runs within the us-east-1b subnet.

During an initial investigation, a security engineer discovers that the suspicious instance is the only instance that runs in the subnet.

Which response will immediately mitigate the attack and help investigate the root cause?

A. Log in to the suspicious instance and use the netstat command to identify remote connections. Use the IP addresses from these remote connections to create deny rules in the security group of the instance. Install diagnostic tools on the instance for investigation. Update the outbound network ACL for the subnet in us-east-1b to explicitly deny all connections as the first rule during the investigation of the instance.

B. Update the outbound network ACL for the subnet in us-east-1 b to explicitly deny all connections as the first rule. Replace the security group with a new security group that allows connections only from a diagnostics security group. Update the outbound network ACL for the us-east-1 b subnet to remove the

deny all rule. Launch a new EC2 instance that has diagnostic tools. Assign the new security group to the new EC2 instance. Use the new EC2 instance to investigate the suspicious instance.

C. Ensure that the Amazon Elastic Block Store (Amazon EBS) volumes that are attached to the suspicious EC2 instance will not delete upon termination. Terminate the instance. Launch a new EC2 instance in us-east-1a that has diagnostic tools.

Mount the EBS volumes from the terminated instance for investigation.

D. Create an AWS WAF web ACL that denies traffic to and from the suspicious instance. Attach the AWS WAF web ACL to the instance to mitigate the attack. Log in to the instance and install diagnostic tools to investigate the instance.

▼ 中文:

安全工程师收到通知，指出基于 Linux 的 Amazon EC2 实例（使用 Amazon Elastic Block Store (Amazon EBS) 存储）存在可疑活动。该实例正在连接已知的恶意地址。该实例位于 us-east-1 区域内的 VPC 的开发账户中。该 VPC 包含一个 Internet 网关，并在 us-east-1a 和 us-east-1b 中有一个子网。每个子网都关联了一个使用 Internet 网关作为默认路由的路由表。每个子网也使用默认的网络 ACL。可疑的 EC2 实例运行在 us-east-1b 子网内。初步调查中，安全工程师发现该可疑实例是该子网内唯一运行的实例。

哪种响应可以立即缓解攻击并帮助调查根本原因？

A. 登录到可疑实例并使用 netstat 命令识别远程连接。使用这些远程连接的 IP 地址在实例的安全组中创建拒绝规则。

在实例上安装诊断工具进行调查。在调查实例期间，将 us-east-1b 子网的出站网络 ACL 更新为明确拒绝所有连接作为第一条规则。

B. 将 us-east-1b 子网的出站网络 ACL 更新为明确拒绝所有连接作为第一条规则。替换安全组为一个仅允许来自诊断安全组连接的新安全组。更新 us-east-1b 子网的出站网络 ACL，移除拒绝所有连接的规则。启动一个带有诊断工具的新 EC2 实例。将新的安全组分配给新的 EC2 实例。使用新的 EC2 实例调查可疑实例。

C. 确保附加到可疑 EC2 实例的 Amazon Elastic Block Store (Amazon EBS) 卷不会在实例终止时删除。终止该实例。在 useast-1a 中启动一个带有诊断工具的新 EC2 实例。挂载已终止实例的 EBS 卷进行调查。

D. 创建一个 AWS WAF web ACL，拒绝与可疑实例之间的流量。将 AWS WAF web ACL 附加到实例以缓解攻击。登录到实例并安装诊断工具以调查实例。

▼ 答案:

B

1. 考察的知识点

Amazon EC2实例的安全性管理
网络ACL和安全组的使用

如何快速隔离受感染的实例
诊断和调查可疑活动的最佳实践

2. 选项分析

A. Log in to the suspicious instance and use the netstat command to identify remote connections...

错误原因：

虽然可以使用netstat命令查看远程连接，但直接登录到受感染的实例可能会进一步暴露系统。

更新网络ACL以拒绝所有连接是正确的，但在实例上安装诊断工具可能会导致攻击者继续利用实例。

此选项未提供隔离实例的最佳实践。

B. Update the outbound network ACL for the subnet in us-east-1b to explicitly deny all connections...

正确原因：

立即更新网络ACL以拒绝所有连接可以快速隔离受感染的实例。

替换安全组以限制访问并启动一个新的诊断实例是调查的最佳实践。

此选项提供了一个完整的隔离和调查流程，符合安全事件响应的标准。

C. Ensure that the Amazon Elastic Block Store (Amazon EBS) volumes that are attached to the suspicious EC2 instance...

错误原因：

虽然终止实例可以阻止攻击，但直接终止实例可能会丢失实时数据，影响调查。挂载EBS卷进行调查是可行的，但此选项未提到如何隔离实例以防止进一步的攻击。

D. Create an AWS WAF web ACL that denies traffic to and from the suspicious instance...

错误原因：

AWS WAF主要用于保护Web应用程序，而不是直接用于隔离EC2实例。

▼ 44

▼ 英文:

An online media company has an application that customers use to watch events around the world. The application is hosted on a fleet of Amazon EC2 instances that run Amazon Linux 2. The company uses AWS Systems Manager to manage the EC2 instances. The company applies patches and application updates by using the AWS-AmazonLinux2DefaultPatchBaseline patching baseline in Systems Manager Patch Manager.

The company is concerned about potential attacks on the application during the week of an upcoming event. The company needs a solution that can immediately deploy patches to all the EC2 instances in response to a security incident or vulnerability. The solution also must provide centralized evidence that the

patches were applied successfully.

Which combination of steps will meet these requirements? (Choose two.)

- A. Create a new patching baseline in Patch Manager. Specify Amazon Linux 2 as the product. Specify Security as the classification. Set the automatic approval for patches to 0 days. Ensure that the new patching baseline is the designated default for Amazon Linux 2
- B. Use the Patch Now option with the scan and install operation in the Patch Manager console to apply patches against the baseline to all nodes. Specify an Amazon S3 bucket as the patching log storage option
- C. Use the Clone function of Patch Manager to create a copy of the AWS-AmazonLinux2DefaultPatchBaseline built-in baseline. Set the automatic approval for patches to 1 day.
- D. Create a patch policy that patches all managed nodes and sends a patch operation log output to an Amazon S3 bucket. Use a custom scan schedule to set Patch Manager to check every hour for new patches. Assign the baseline to the patch policy.
- E. Use Systems Manager Application Manager to inspect the package versions that were installed on the EC2 instances. Additionally use Application Manager to validate that the patches were correctly installed.

▼ 中文:

一家在线媒体公司有一个应用程序，供客户观看世界各地的活动。该应用程序托管在运行 Amazon Linux 2 的一组 Amazon EC2 实例上。公司使用 AWS Systems Manager 来管理 EC2 实例。公司通过使用 Systems Manager Patch Manager 中的 AWS-AmazonLinux2DefaultPatchBaseline 补丁基线来应用补丁和应用程序更新。公司担心在即将到来的活动周期间，应用程序可能会遭受攻击。公司需要一个解决方案，能够在发生安全事件或漏洞时立即向所有 EC2 实例部署补丁。该解决方案还必须提供集中化的证据，证明补丁已成功应用。

哪些步骤组合可以满足这些要求？（选择两个。）

- A.在 Patch Manager 中创建一个新的补丁基线。指定 Amazon Linux 2 作为产品。指定 Security 作为分类。将补丁的自动批准设置为 0 天。确保新的补丁基线是 Amazon Linux 2 的默认指定基线。
- B.使用 Patch Manager 控制台中的 Patch Now 选项，通过扫描和安装操作根据基线向所有节点应用补丁。指定一个 Amazon S3 bucket 作为补丁日志存储选项。
- C.使用 Patch Manager 的 Clone 功能创建 AWS-AmazonLinux2DefaultPatchBaseline 内置基线的副本。将补丁的自动批准设置为 1 天。
- D.创建一个补丁策略，补丁所有受管理的节点，并将补丁操作日志输出发送到一个 Amazon S3 bucket。使用自定义扫描计划设置 Patch Manager 每小时检查新补丁。

将基线分配给补丁策略。

E.使用 Systems Manager Application Manager 检查安装在 EC2 实例上的软件包版本。此外，使用 Application Manager验证补丁是否正确安装。

▼ 答案:

AB

1. 考察的知识点

AWS Systems Manager Patch Manager的功能和使用，包括创建补丁基线和应用补丁。

如何快速响应安全事件并验证补丁的应用情况。

集中化日志存储和证据收集的实现方式。

2. 选项分析

A. Create a new patching baseline in Patch Manager. Specify Amazon Linux 2 as the product. Specify Security as the classification. Set the automatic approval for patches to 0 days. Ensure that the new patching baseline is the designated default for Amazon Linux 2.

正确：此选项通过创建一个新的补丁基线并设置自动批准为0天，可以确保在发现安全漏洞时立即应用补丁。

此选项符合需求，因为它允许快速响应安全事件。

B. Use the Patch Now option with the scan and install operation in the Patch Manager console to apply patches against the baseline to all nodes. Specify an Amazon S3 bucket as the patching log storage option.

正确：使用Patch Now选项可以立即扫描和安装补丁，满足快速响应的需求。指定Amazon S3作为日志存储选项可以提供集中化的证据，证明补丁已成功应用。

C. Use the Clone function of Patch Manager to create a copy of the AWS-AmazonLinux2DefaultPatchBaseline built-in baseline. Set the automatic approval for patches to 1 day.

错误：将自动批准设置为1天不符合“立即部署补丁”的要求。

此选项无法满足快速响应安全事件的需求。

D. Create a patch policy that patches all managed nodes and sends a patch operation log output to an Amazon S3 bucket. Use a custom scan schedule to set Patch Manager to check every hour for new patches. Assign the baseline to the patch policy.

错误：虽然此选项可以定期检查新补丁，但它无法立即响应安全事件。

每小时检查的频率不够及时，无法满足题目要求。

E. Use Systems Manager Application Manager to inspect the package versions that were installed on the EC2 instances.

Additionally use Application Manager to validate that the patches were correctly installed.

错误：此选项主要用于验证补丁是否正确安装，但无法满足“立即部署补丁”的需求。

Community vote distribution

社区投票分布

AB (70%) AD (20%) BD (10%)

<https://shop542998714.m.taobao.com> <https://www.goofish.com/personal?userId=2645260430>

此选项不涉及补丁的快速应用，因此不符合题目要求。

▼ 45

▼ 英文:

A developer operations team uses AWS Identity and Access Management (IAM) to manage user permissions. The team created an Amazon EC2 instance profile role that uses an AWS managed ReadOnlyAccess policy. When an application that is running on Amazon EC2 tries to read a file from an encrypted Amazon S3 bucket, the application receives an AccessDenied error.

The team administrator has verified that the S3 bucket policy allows everyone in the account to access the S3 bucket. There is no object ACL that is attached to the file.

What should the administrator do to fix the IAM access issue?

A. Edit the ReadOnlyAccess policy to add kms:Decrypt actions

▼ 中文:

开发运维团队使用 AWS Identity and Access Management (IAM) 来管理用户权限。团队创建了一个 Amazon EC2 实例配置文件角色，该角色使用 AWS 托管的 ReadOnlyAccess 策略。当运行在 Amazon EC2 上的应用程序尝试从加密的 Amazon S3 存储桶读取文件时，应用程序收到 AccessDenied 错误。

团队管理员已验证 S3 存储桶策略允许账户中的所有人员访问 S3 存储桶。文件没有附加对象 ACL。

管理员应该怎么做来解决 IAM 访问问题？

A. 编辑 ReadOnlyAccess 策略以添加 kms:Decrypt 操作

B. 将 EC2 IAM 角色作为授权主体添加到 S3 存储桶策略

C. 为 IAM 角色附加一个包含 kms:Decrypt 权限的内联策略

D. 为 IAM 角色附加一个包含 S3:* 权限的内联策略

▼ 答案:

C

1. 考察的知识点
IAM角色与权限管理

Amazon S3加密文件访问权限
KMS解密权限的配置

2. 选项分析

A. Edit the ReadOnlyAccess policy to add kms:Decrypt actions

错误：AWS托管策略（如ReadOnlyAccess）无法直接编辑。托管策略是由AWS管理的，用户无法修改。

B. Add the EC2 IAM role as the authorized Principal to the S3 bucket policy

错误：题目中已经明确指出S3存储桶策略允许账户中的所有用户访问存储桶，因此问题不在于存储桶策略。

C. Attach an inline policy with kms:Decrypt permissions to the IAM role

正确：加密的S3文件需要KMS解密权限。当前IAM角色使用的是ReadOnlyAccess策略，该策略不包含kms:Decrypt权限，因此需要为IAM角色附加一个内联策略以授予kms:Decrypt权限。

D. Attach an inline policy with S3:* permissions to the IAM role

错误：虽然S3:*权限可以解决访问问题，但这是过度授权，违反了最小权限原则。正确的解决方案是仅添加所需的kms:Decrypt权限。

▼ 46

▼ 英文:

A company uses AWS Organizations and has Amazon Elastic Kubernetes Service (Amazon EKS) clusters in many AWS accounts.

A security engineer integrates Amazon EKS with AWS CloudTrail. The CloudTrail trails are stored in an Amazon S3 bucket in each account to monitor API calls.

The security engineer observes that CloudTrail logs are not displaying Kubernetes pod creation events.

What should the security engineer do to view the Kubernetes events from Amazon CloudWatch?

A. Configure the EKS clusters to use private S3 VPC endpoints. Configure the S3 buckets for logging.

B. Enable Kubernetes API server component logs for each cluster.

C. Enable cross-origin resource sharing (CORS) in the S3 bucket that is used for logging.

D. Configure CloudWatch. View the events in the CloudWatch console.

▼ 中文:

一家公司使用AWS Organizations，并在多个AWS账户中拥有Amazon Elastic Kubernetes Service (Amazon EKS)集群。一位安全工程师将Amazon EKS与AWS

CloudTrail集成。CloudTrail日志存储在每个账户的Amazon S3桶中，用于监控API调用。

安全工程师发现CloudTrail日志未显示Kubernetes pod创建事件。

安全工程师应该怎么做才能从Amazon CloudWatch中查看Kubernetes事件？

A.配置EKS集群以使用私有S3 VPC端点。配置S3桶进行日志记录。

B.为每个集群启用Kubernetes API服务器组件日志。

C.在用于日志记录的S3桶中启用跨来源资源共享（CORS）。

D.配置CloudWatch。在CloudWatch控制台中查看事件。

▼ 答案:

B

1. 考察的知识点

Amazon EKS与AWS CloudTrail的集成。

如何监控Kubernetes事件，例如Pod创建事件。

理解Kubernetes API服务器组件日志的作用。

2. 选项分析

A. 配置EKS集群以使用私有S3 VPC端点。配置S3桶进行日志记录。

错误：此选项与问题无关。S3 VPC端点和S3桶日志记录主要用于安全性和访问控制，而不是解决Kubernetes事件未显示的问题。

B. 为每个集群启用Kubernetes API服务器组件日志。

正确：Kubernetes API服务器组件日志记录是监控Kubernetes事件（如Pod创建事件）的关键步骤。启用此功能后，相关事件会记录下来并可以通过CloudTrail查看。

C. 在用于日志记录的S3桶中启用跨来源资源共享（CORS）。

错误：CORS设置用于跨域访问S3资源，与监控Kubernetes事件无关。

D. 配置CloudWatch。在CloudWatch控制台中查看事件。

错误：虽然CloudWatch可以用于监控和查看日志，但问题的核心是CloudTrail日志中缺少Kubernetes事件。仅配置CloudWatch无法解决问题。

▼ 47

▼ 英文:

A security engineer needs to build a solution to turn AWS CloudTrail back on in multiple AWS Regions in case it is ever turned off.

What is the MOST efficient way to implement this solution?

A. Use AWS Config with a managed rule to initiate the AWS-EnableCloudTrail remediation.

B. Create an Amazon EventBridge event with a [cloudtrail.amazonaws.com](https://docs.aws.amazon.com/AmazonEventBridge/latest/userguide/event-types-cloudtrail.html) event source and a StartLogging event name to invoke an AWS Lambda function to call the StartLogging.

C. Create an Amazon CloudWatch alarm with a [cloudtrail.amazonaws.com](https://docs.aws.amazon.com/AmazonEventBridge/latest/userguide/event-types-cloudtrail.html) event source and a StopLogging event name to invoke an AWS Lambda function to call the StartLogging API.

D. Monitor AWS Trusted Advisor to ensure CloudTrail logging is enabled.

▼ 中文:

一位安全工程师需要构建一个解决方案，以便在多个 AWS 区域中，如果 AWS CloudTrail 被关闭，可以将其重新开启。实现此解决方案最有效的方法是什么？

A.使用 AWS Config 和托管规则来启动 AWS-EnableCloudTrail 修复。

B.创建一个 Amazon EventBridge 事件，使用 [cloudtrail.amazonaws.com](https://docs.aws.amazon.com/AmazonEventBridge/latest/userguide/event-types-cloudtrail.html) 事件源和 StartLogging 事件名称来调用 AWS Lambda 函数以调用 StartLogging API。

C.创建一个 Amazon CloudWatch 警报，使用 [cloudtrail.amazonaws.com](https://docs.aws.amazon.com/AmazonEventBridge/latest/userguide/event-types-cloudtrail.html) 事件源和 StopLogging 事件名称来调用 AWS Lambda 函数以调用 StartLogging API。

D.监控 AWS Trusted Advisor 以确保 CloudTrail 日志记录已启用。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS CloudTrail的监控与自动修复能力，涉及AWS Config、EventBridge、CloudWatch、Lambda以及AWS Trusted Advisor的功能和使用场景。重点在于选择最有效的方式来确保CloudTrail在多个区域被自动开启。

2. 选项分析

A. Use AWS Config with a managed rule to initiate the AWS-EnableCloudTrail remediation.

正确：AWS Config可以通过托管规则（如AWS-EnableCloudTrail）自动检测CloudTrail是否关闭，并触发修复操作以重新启用CloudTrail。

效率高：托管规则是预定义的，直接支持CloudTrail的自动修复，无需额外的自定义开发。

B. Create an Amazon EventBridge event with a [cloudtrail.amazonaws.com](https://docs.aws.amazon.com/AmazonEventBridge/latest/userguide/event-types-cloudtrail.html) event source and a StartLogging event name to invoke an AWS Lambda function to call the StartLogging API.

错误：EventBridge可以捕获事件，但“StartLogging”事件名称并不适用于检测CloudTrail被关闭的情况。

复杂性高：需要自定义Lambda函数和事件规则，效率不如托管规则。

C. Create an Amazon CloudWatch alarm with a [cloudtrail.amazonaws.com](https://docs.aws.amazon.com/AmazonEventBridge/latest/userguide/event-types-cloudtrail.html) event source and a StopLogging event name to

invoke an AWS Lambda function to call the StartLogging API.

错误：CloudWatch Alarms主要用于监控指标，而不是事件。StopLogging事件无法直接作为CloudWatch Alarm的触发条件。

复杂性高：需要自定义Lambda函数和监控规则，效率不如托管规则。

D. Monitor AWS Trusted Advisor to ensure CloudTrail logging is enabled.

错误：AWS Trusted Advisor可以提供建议，但无法自动修复问题。

效率低：需要人工干预，无法实现自动化。

▼ 48

▼ 英文:

An ecommerce company is developing new architecture for an application release. The company needs to implement TLS for incoming traffic to the application. Traffic for the application will originate from the internet. TLS does not have to be implemented in an end-to-end configuration because the company is concerned about impacts on performance. The incoming traffic types will be HTTP and HTTPS. The application uses ports 80 and 443. What should a security engineer do to meet these requirements?

A. Create a public Application Load Balancer. Create two listeners: one listener on port 80 and one listener on port 443. Create one target group. Create a rule to forward traffic from port 80 to the listener on port 443. Provision a public TLS certificate in AWS Certificate Manager (ACM). Attach the certificate to the listener on port 443.

B. Create a public Application Load Balancer. Create two listeners: one listener on port 80 and one listener on port 443. Create one target group. Create a rule to forward traffic from port 80 to the listener on port 443. Provision a public TLS certificate in AWS Certificate Manager (ACM). Attach the certificate to the listener on port 80.

C. Create a public Network Load Balancer. Create two listeners: one listener on port 80 and one listener on port 443. Create one target group. Create a rule to forward traffic from port 80 to the listener on port 443. Set the protocol for the listener on port 443 to TLS.

D. Create a public Network Load Balancer. Create a listener on port 443. Create one target group. Create a rule to forward traffic from port 443 to the target group. Set the protocol for the listener on port 443 to TLS.

▼ 中文:

一家电子商务公司正在为应用程序发布开发新的架构。公司需要为进入应用程序的流量实现TLS。应用程序的流量将来自互联网。TLS不需要以端到端配置实现，因为公司

担心性能的影响。进入的流量类型将是HTTP和HTTPS。应用程序使用端口80和443。

安全工程师应该怎么做以满足这些要求？

A. 创建一个公共的Application Load Balancer。创建两个监听器：一个监听器在端口80，一个监听器在端口443。创建一个目标组。创建一个规则，将端口80的流量转发到端口443的监听器。在AWS Certificate Manager (ACM)中预置一个公共TLS证书。将证书附加到端口443的监听器。

B. 创建一个公共的Application Load Balancer。创建两个监听器：一个监听器在端口80，一个监听器在端口443。创建一个目标组。创建一个规则，将端口80的流量转发到端口443的监听器。在AWS Certificate Manager (ACM)中预置一个公共TLS证书。将证书附加到端口80的监听器。

C. 创建一个公共的Network Load Balancer。创建两个监听器：一个监听器在端口80，一个监听器在端口443。创建一个目标组。创建一个规则，将端口80的流量转发到端口443的监听器。将端口443监听器的协议设置为TLS。

D. 创建一个公共的Network Load Balancer。创建一个监听器在端口443。创建一个目标组。创建一个规则，将端口443的流量转发到目标组。将端口443监听器的协议设置为TLS。

▼ 答案:

A

1. 考察的知识点

理解AWS Application Load Balancer (ALB) 和 Network Load Balancer (NLB) 的功能和使用场景。

配置TLS证书以实现安全的HTTPS通信。

如何在ALB中设置监听器和流量转发规则。

使用AWS Certificate Manager (ACM)管理TLS证书。

2. 选项分析

A:

使用了Application Load Balancer (ALB)，适合处理HTTP和HTTPS流量。

创建了两个监听器：一个监听器在端口80 (HTTP)，另一个监听器在端口443 (HTTPS)。

设置了规则，将端口80的流量转发到端口443的监听器，确保所有流量最终通过HTTPS。

在AWS Certificate Manager (ACM)中预置了TLS证书，并将证书附加到端口443的监听器，符合题目要求。

此选项正确地实现了TLS保护，并且性能影响较小，因为TLS只在ALB层实现，而不是端到端。

B:

与选项A类似，但将TLS证书附加到了端口80的监听器，而不是端口443。

这是错误的，因为TLS证书应该附加到HTTPS监听器 (端口443)，而不是HTTP

监听器（端口80）。

C:

使用了Network Load Balancer (NLB)，适合处理高性能和低延迟的流量，但不支持复杂的HTTP/HTTPS规则（如流量转发）。

虽然设置了TLS协议，但NLB不支持像ALB那样的流量转发规则（例如将端口80的流量转发到端口443）。

此选项不符合题目要求，因为题目明确提到需要处理HTTP和HTTPS流量，而NLB不适合这种场景。

D:

仅创建了一个监听器在端口443，并设置了TLS协议。

没有处理端口80的流量，也没有实现流量从HTTP到HTTPS的转发规则。

此选项不符合题目要求，因为题目明确提到需要处理HTTP和HTTPS流量。

▼ 49

▼ 英文:

A company needs a solution to protect critical data from being permanently deleted. The data is stored in Amazon S3 buckets.

The company needs to replicate the S3 objects from the company's primary AWS Region to a secondary Region to meet disaster recovery requirements. The company must also ensure that users who have administrator access cannot permanently delete the data in the secondary Region. Which solution will meet these requirements?

A. Configure AWS Backup to perform cross-Region S3 backups. Select a backup vault in the secondary Region. Enable AWS Backup Vault Lock in governance mode for the backups in the secondary Region.

B. Implement S3 Object Lock in compliance mode in the primary Region. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region.

C. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region. Create an S3 bucket policy to deny the s3:ReplicateDelete action on the S3 bucket in the secondary Region.

D. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region. Configure S3 object versioning on the S3 bucket in the secondary Region.

▼ 中文:

一家公司需要一个解决方案来保护关键数据免于被永久删除。这些数据存储在 Amazon S3 存储桶中。

该公司需要将 S3 对象从公司主要的 AWS 区域复制到次要区域，以满足灾难恢复需

求。公司还必须确保拥有管理员访问权限的用户无法永久删除次要区域中的数据。哪种解决方案可以满足这些需求？

A.配置 AWS Backup 以执行跨区域的 S3 备份。在次要区域选择一个备份保管库。为次要区域中的备份启用 AWS Backup Vault Lock 的治理模式。

B.在主要区域实施 S3 Object Lock 的合规模式。配置 S3 复制以将对象复制到次要区域的 S3 存储桶中。

C.配置 S3 复制以将对象复制到次要区域的 S3 存储桶中。为次要区域的 S3 存储桶创建一个 S3 存储桶策略，以拒绝s3:ReplicateDelete 操作。

D.配置 S3 复制以将对象复制到次要区域的 S3 存储桶中。在次要区域的 S3 存储桶中配置 S3 对象版本控制。

▼ 答案:

B

1. 考察的知识点

Amazon S3 Object Lock功能及其模式（治理模式和合规模式）。

跨区域复制（S3 Replication）的配置与使用。

如何防止数据被永久删除，包括管理员权限的限制。

2. 选项分析

A.

正确性分析：虽然AWS Backup Vault Lock可以防止备份被删除，但它是针对备份数据的，而不是直接针对S3存储桶中的对象。

此外，治理模式允许管理员绕过保护，这不符合题目要求“确保用户（包括管理员）不能永久删除数据”。

结论：错误。

B.

正确性分析：使用S3 Object Lock的合规模式可以防止任何用户（包括管理员）删除数据。

通过跨区域复制（S3Replication），可以将数据复制到次要区域的存储桶中，从而满足灾难恢复需求。

结论：正确。

C.

正确性分析：虽然可以通过存储桶策略拒绝s3:ReplicateDelete操作，但这并不能防止管理员直接删除数据。此外，存储桶策略可以被管理员修改，因此不符合题目要求“确保用户（包括管理员）不能永久删除数据”。

结论：错误。

D.

正确性分析：启用版本控制可以防止数据被永久删除，但管理员仍然可以删除所有版本的对象。此外，版本控制并不能完全满足题目

▼ 50

▼ 英文:

A company in France uses Amazon Cognito with the Cognito Hosted UI as an identity broker for sign-in and sign-up processes.

The company is marketing an application and expects that all the application's users will come from France.

When the company launches the application, the company's security team observes fraudulent sign-ups for the application.

Most of the fraudulent registrations are from users outside of France.

The security team needs a solution to perform custom validation at sign-up.

Based on the results of the validation, the solution must accept or deny the registration request.

Which combination of steps will meet these requirements? (Choose two.)

- A. Create a pre sign-up AWS Lambda trigger. Associate the Amazon Cognito function with the Amazon Cognito user pool.
- B. Use a geographic match rule statement to configure an AWS WAF web ACL. Associate the web ACL with the Amazon Cognito user pool.
- C. Configure an app client for the application's Amazon Cognito user pool. Use the app client ID to validate the requests in the hosted UI.
- D. Update the application's Amazon Cognito user pool to configure a geographic restriction setting.
- E. Use Amazon Cognito to configure a social identity provider (IdP) to validate the requests on the hosted UI.

▼ 中文:

一家位于法国的公司使用 Amazon Cognito 和 Cognito Hosted UI 作为身份代理来处理登录和注册流程。该公司正在推广一个应用程序，并预计所有应用程序的用户都将来自法国。

当公司推出该应用程序时，公司安全团队观察到应用程序存在欺诈性注册。大多数欺诈性注册来自法国以外的用户。

安全团队需要一个解决方案来在注册时执行自定义验证。根据验证结果，该解决方案必须接受或拒绝注册请求。

哪种步骤组合可以满足这些要求？（选择两个。）

- A. 创建一个 pre sign-up AWS Lambda 触发器。将 Amazon Cognito 函数与 Amazon Cognito 用户池关联。
- B. 使用 geographic match rule statement 配置一个 AWS WAF web ACL，将 web ACL 与 Amazon Cognito 用户池关联。
- C. 为应用程序的 Amazon Cognito 用户池配置一个 app client。使用 app client ID 验证 hosted UI 中的请求。
- D. 更新应用程序的 Amazon Cognito 用户池以配置 geographic restriction 设置。

E. 使用 Amazon Cognito 配置一个 social identity provider (IdP) 来验证 hosted UI 中的请求。

▼ 答案:

AB

1. 考察的知识点

Amazon Cognito用户池的触发器功能（如Pre Sign-Up Lambda触发器）。
AWS WAF的地理匹配规则（Geographic Match Rule）和Web ACL的配置与应用。
如何结合AWS服务实现自定义验证和安全性增强。

2. 选项分析

A.

正确：Pre Sign-Up Lambda触发器允许在用户注册时执行自定义验证逻辑。可以根据用户的地理位置或其他条件决定是否接受或拒绝注册请求。

B.

正确：AWS WAF支持地理匹配规则，可以阻止来自特定国家或地区的请求。将Web ACL与Cognito用户池关联，可以有效地限制来自非法国地区的注册请求。

C.

错误：App Client ID用于标识应用程序，但它不能用于执行地理位置验证或阻止注册请求。

D.

错误：Amazon Cognito用户池本身不支持直接配置地理限制设置。需要结合其他服务（如AWS WAF）来实现地理限制。

E.

错误：配置社交身份提供商（IdP）与地理位置验证无关，无法解决问题中提到的限制非法国用户注册的需求。

▼ 51

▼ 英文:

A security engineer is configuring AWS Config for an AWS account that uses a new IAM entity. When the security engineer tries to configure AWS Config rules and automatic remediation options, errors occur. In the AWS CloudTrail logs, the security engineer sees the following error message: "Insufficient delivery policy to s3 bucket: DOC-EXAMPLE-BUCKET, unable to write to bucket, provided s3 key prefix is 'null'." Which combination of steps should the security engineer take to remediate this issue? (Choose two.)

A. Check the Amazon S3 bucket policy. Verify that the policy allows the config.amazonaws.com service to write to the

target bucket.

B. Verify that the IAM entity has the permissions necessary to perform the s3:GetBucketAcl and s3:PutObject* operations to write to the target bucket.

C. Verify that the Amazon S3 bucket policy has the permissions necessary to perform the s3:GetBucketAcl and s3:PutObject* operations to write to the target bucket.

D. Check the policy that is associated with the IAM entity. Verify that the policy allows the [config.amazonaws.com](https://docs.aws.amazon.com/config/latest/APIReference/) service to write to the target bucket.

E. Verify that the AWS Config service role has permissions to invoke the BatchGetResourceConfig action instead of the GetResourceConfigHistory action and s3:PutObject* operation.

▼ 中文:

一位安全工程师正在为一个使用新 IAM 实体的 AWS 账户配置 AWS Config。当安全工程师尝试配置 AWS Config 规则和自动修复选项时，出现错误。在 AWS CloudTrail 日志中，安全工程师看到以下错误消息：“Insufficient delivery policy to s3 bucket: DOC-EXAMPLE-BUCKET, unable to write to bucket, provided s3 key prefix is 'null'。”

安全工程师应采取哪些步骤来解决此问题？（选择两项）

A. 检查 Amazon S3 存储桶策略。验证该策略是否允许 [config.amazonaws.com](https://docs.aws.amazon.com/config/latest/APIReference/) 服务写入目标存储桶。

B. 验证 IAM 实体是否具有执行 s3:GetBucketAcl 和 s3:PutObject* 操作以写入目标存储桶所需的权限。

C. 验证 Amazon S3 存储桶策略是否具有执行 s3:GetBucketAcl 和 s3:PutObject* 操作以写入目标存储桶所需的权限。

D. 检查与 IAM 实体关联的策略。验证该策略是否允许 [config.amazonaws.com](https://docs.aws.amazon.com/config/latest/APIReference/) 服务写入目标存储桶。

E. 验证 AWS Config 服务角色是否具有调用 BatchGetResourceConfig 操作而不是 GetResourceConfigHistory 操作以及 s3:PutObject* 操作的权限。

▼ 答案:

AB

1. 考察的知识点

本题主要考察 AWS Config 的配置问题，包括 S3 存储桶策略和 IAM 权限的正确配置。

涉及 AWS Config 服务与 S3 存储桶的交互权限，以及 IAM 实体的权限验证。

2. 选项分析

A. 检查 Amazon S3 存储桶策略。验证该策略是否允许 [config.amazonaws.com](https://docs.aws.amazon.com/config/latest/APIReference/)

服务写入目标存储桶。

正确。AWS Config需要将配置记录写入到指定的S3存储桶，存储桶策略必须允许 config.amazonaws.com服务写入目标存

储桶。如果存储桶策略没有正确配置，会导致写入失败。

B. 验证 IAM 实体是否具有执行 s3:GetBucketAcl 和 s3:PutObject* 操作以写入目标存储桶所需的权限。

正确。IAM实体需要具备足够的权限来执行s3:GetBucketAcl和s3:PutObject操作，以便AWS Config能够成功写入目标存储桶。

C. 验证 Amazon S3 存储桶策略是否具有执行 s3:GetBucketAcl 和 s3:PutObject 操作以写入目标存储桶所需的权限。

错误。存储桶策略主要用于控制外部服务（如AWS Config）对存储桶的访问，而不是直接验证IAM实体的权限。

D. 检查与 IAM 实体关联的策略。验证该策略是否允许 config.amazonaws.com 服务写入目标存储桶。

错误。IAM实体的权限是针对用户或角色的，而不是直接针对 config.amazonaws.com服务。此选项混淆了IAM实体权限与服务权限的概念。

E. 验证 AWS Config 服务角色是否具有调用 BatchGetResourceConfig 操作而不是 GetResourceConfigHistory 操作以及 s3:PutObject* 操作的权限。

错误。题目中提到的问题是与S3存储桶写入权限相关，而不是与AWS Config服务角色调用的API操作相关。

▼ 52

▼ 英文:

A company is undergoing a layer 3 and layer 4 DDoS attack on its web servers running on AWS.

Which combination of AWS services and features will provide protection in this scenario? (Choose three.)

- A. Amazon Route 53
- B. AWS Certificate Manager (ACM)
- C. Amazon S3
- D. AWS Shield
- E. Network Load Balancer
- F. Amazon GuardDuty

▼ 中文:

一家公司正在运行在 AWS 上的 Web 服务器遭受第 3 层和第 4 层 DDoS 攻击。在这种情况下，哪种 AWS 服务和功能的组合可以提供保护？（选择三项）

- A. Amazon Route 53
- B. AWS Certificate Manager (ACM)
- C. Amazon S3
- D. AWS Shield
- E. Network Load Balancer
- F. Amazon GuardDuty

▼ 答案:

ADE

1. 考察的知识点

本题考察的是AWS在应对DDoS攻击时的服务和功能，包括网络层（Layer 3）和传输层（Layer 4）的防护能力。

涉及的知识点包括AWS Shield、Amazon Route 53、网络负载均衡器（Network Load Balancer）等服务的功能和用途。

2. 选项分析

A. Amazon Route 53: 正确。Amazon Route 53是一个高可用的DNS服务，支持流量分发和基于地理位置的路由。它可以帮助缓解DDoS攻击，通过流量分散和速率限制来保护资源。

B. AWS Certificate Manager (ACM): 错误。ACM主要用于管理SSL/TLS证书，确保数据传输的安全性，但它不直接提供DDoS防护功能。

C. Amazon S3: 错误。Amazon S3是一个对象存储服务，虽然可以存储静态内容，但它不具备直接的DDoS防护功能。

D. AWS Shield: 正确。AWS Shield是专门设计用于保护AWS资源免受DDoS攻击的服务，提供基础防护（Shield Standard）和高级防护（Shield Advanced）。

E. Network Load Balancer: 正确。Network Load Balancer可以处理大规模的流量并提供低延迟的负载均衡功能，同时支持保护应用免受DDoS攻击。

F. Amazon GuardDuty: 错误。Amazon GuardDuty是一个威胁检测服务，用于识别潜在的恶意活动，但它不直接参与DDoS防护。

▼ 53

▼ 英文:

A company wants to implement host-based security for Amazon EC2 instances and containers in Amazon Elastic Container Registry (Amazon ECR). The company has deployed AWS Systems Manager Agent (SSM Agent) on the EC2 instances. All the company's AWS accounts are in one organization in AWS Organizations. The company will analyze the workloads for software vulnerabilities and unintended network exposure. The company will push any findings to AWS Security Hub, which the company has configured for the organization.

The company must deploy the solution to all member accounts, including new accounts, automatically. When new workloads come online, the solution must scan the workloads.

Which solution will meet these requirements?

- A. Use SCPs to configure scanning of EC2 instances and ECR containers for all accounts in the organization.
- B. Configure a delegated administrator for Amazon GuardDuty for the organization. Create an Amazon EventBridge rule to initiate analysis of ECR containers
- C. Configure a delegated administrator for Amazon Inspector for the organization. Configure automatic scanning for new member accounts.
- D. Configure a delegated administrator for Amazon Inspector for the organization. Create an AWS Config rule to initiate analysis of ECR containers

▼ 中文:

一家公司希望为 Amazon EC2 实例和 Amazon Elastic Container Registry (Amazon ECR) 中的容器实施基于主机的安全性。

该公司已在 EC2 实例上部署了 AWS Systems Manager Agent (SSM Agent)。该公司的所有 AWS 账户都位于 AWS Organizations 的一个组织中。公司将分析工作负载中的软件漏洞和意外的网络暴露。公司将把任何发现推送到 AWS Security Hub，该公司已为组织配置了该服务。

公司必须自动将解决方案部署到所有成员账户，包括新账户。当新的工作负载上线时，解决方案必须扫描这些工作负载。哪种解决方案可以满足这些要求？

- A.使用 SCPs 为组织中的所有账户配置 EC2 实例和 ECR 容器的扫描。
- B.为组织配置 Amazon GuardDuty 的委派管理员。创建一个 Amazon EventBridge 规则以启动对 ECR 容器的分析。
- C.为组织配置 Amazon Inspector 的委派管理员。为新成员账户配置自动扫描。
- D.为组织配置 Amazon Inspector 的委派管理员。创建一个 AWS Config 规则以启动对 ECR 容器的分析。

▼ 答案:

C

1. 考察的知识点

Amazon Inspector的功能与配置，包括自动扫描和漏洞检测。
AWS Organizations的使用，包括委派管理员的设置。
如何将安全扫描结果推送到AWS Security Hub。
自动化部署解决方案以覆盖所有成员账户和新账户。

2. 选项分析

- A. 使用 SCPs 为组织中的所有账户配置 EC2 实例和 ECR 容器的扫描。

错误原因：服务控制策略（SCPs）用于限制或允许账户的操作权限，但它不能直接用于配置或执行扫描任务。SCPs无法

满足题目中关于自动扫描和推送结果到Security Hub的需求。

B. 为组织配置 Amazon GuardDuty 的委派管理员。创建一个 Amazon EventBridge 规则以启动对 ECR 容器的分析。

错误原因：Amazon GuardDuty主要用于检测恶意活动和异常行为，而不是专门设计用于漏洞扫描或分析ECR容器。虽然EventBridge可以触发事件，但这不是最佳解决方案。

然EventBridge可以触发事件，但这不是最佳解决方案。

C. 为组织配置 Amazon Inspector 的委派管理员。为新成员账户配置自动扫描。

正确原因：Amazon Inspector专门用于漏洞扫描和分析，包括EC2实例和ECR容器。通过配置委派管理员，可以集中管理所有成员账户的扫描任务。Amazon Inspector支持自动扫描新账户和新工作负载，并将结果推送到Security Hub。

D. 为组织配置 Amazon Inspector 的委派管理员。创建一个 AWS Config 规则以启动对 ECR 容器的分析。

错误原因：虽然AWS Config可以监控资源配置的合规性，但它不是专门设计用于启动漏洞扫描任务。相比之下，Amazon Inspector已经内置了自动扫描功能，无需额外创建Config规则。

▼ 54

▼ 英文:

A company uses AWS Organizations to manage several AWS accounts. The company processes a large volume of sensitive data. The company uses a serverless approach to microservices. The company stores all the data in either Amazon S3 or

Amazon DynamoDB. The company reads the data by using either AWS Lambda functions or container-based services that the company hosts on Amazon Elastic Kubernetes Service (Amazon EKS) on AWS Fargate.

The company must implement a solution to encrypt all the data at rest and enforce least privilege data access controls. The company creates an AWS Key Management Service (AWS KMS) customer managed key.

What should the company do next to meet these requirements?

A. Create a key policy that allows the kms:Decrypt action only for Amazon S3 and DynamoDB. Create an SCP that denies the creation of S3 buckets and DynamoDB tables that are not encrypted with the key.

B. Create an IAM policy that denies the kms:Decrypt action for the key. Create a Lambda function that runs on a schedule to attach the policy to any new roles. Create an AWS Config rule to send alerts for resources that are not encrypted with the key.

C. Create a key policy that allows the kms:Decrypt action only for Amazon S3, DynamoDB, Lambda, and Amazon EKS.

Create an SCP that denies the creation of S3 buckets and DynamoDB tables that are not encrypted with the key.

D. Create a key policy that allows the kms:Decrypt action only for Amazon S3, DynamoDB, Lambda, and Amazon EKS. Create an AWS Config rule to send alerts for resources that are not encrypted with the key.

▼ 中文:

一家公司使用 AWS Organizations 来管理多个 AWS 账户。该公司处理大量敏感数据。公司采用无服务器的方法来实现微服务。公司将所有数据存储在 Amazon S3 或 Amazon DynamoDB 中。公司通过 AWS Lambda 函数或基于容器的服务读取数据，这些服务托管在 AWS Fargate 上的 Amazon Elastic Kubernetes Service (Amazon EKS) 中。

公司必须实施一种解决方案来加密所有静态数据，并强制执行最小权限的数据访问控制。公司创建了一个 AWS Key Management Service (AWS KMS) 客户托管密钥。公司接下来应该怎么做以满足这些要求？

A. 创建一个密钥策略，仅允许对 Amazon S3 和 DynamoDB 执行 kms:Decrypt 操作。创建一个 SCP，拒绝创建未使用该密钥加密的 S3 存储桶和 DynamoDB 表。

B. 创建一个 IAM 策略，拒绝对密钥执行 kms:Decrypt 操作。创建一个按计划运行的 Lambda 函数，将该策略附加到任何新角色上。创建一个 AWS Config 规则，以发送未使用该密钥加密的资源的警报。

C. 创建一个密钥策略，仅允许对 Amazon S3、DynamoDB、Lambda 和 Amazon EKS 执行 kms:Decrypt 操作。创建一个 SCP，拒绝创建未使用该密钥加密的 S3 存储桶和 DynamoDB 表。

D. 创建一个密钥策略，仅允许对 Amazon S3、DynamoDB、Lambda 和 Amazon EKS 执行 kms:Decrypt 操作。创建一个 AWS Config 规则，以发送未使用该密钥加密的资源的警报。

▼ 答案:

C

1. 考察的知识点

AWS Key Management Service (KMS) 的使用，包括密钥策略 (Key Policy) 的配置。

服务控制策略 (SCP) 的应用，用于跨账户的权限管理。

加密数据的最佳实践，包括数据在静态状态下的加密。

如何实现最小权限原则 (Least Privilege)。

2. 选项分析

A. 创建一个密钥策略，仅允许对 Amazon S3 和 DynamoDB 执行 kms:Decrypt 操作。创建一个 SCP，拒绝创建未使用该密钥加密的 S3 存储桶和 DynamoDB 表。

正确性：此选项部分正确，因为它限制了对 S3 和 DynamoDB 的解密操作，并通

过 SCP 强制加密要求。

问题：未考虑 Lambda 和 Amazon EKS 的解密需求，违反了题目中提到的“公司使用 Lambda 和 Amazon EKS 读取数据”的要求。

B. 创建一个 IAM 策略，拒绝对密钥执行 kms:Decrypt 操作。创建一个按计划运行的 Lambda 函数，将该策略附加到任何新角色上。创建一个 AWS Config 规则，以发送未使用该密钥加密的资源的警报。

正确性：此选项不符合题目要求，因为 IAM 策略无法跨账户强制执行加密要求，且使用 Lambda 函数动态附加策略的方式复杂且不可靠。

问题：未提到如何限制 S3 和 DynamoDB 的加密要求，且未直接实现最小权限原则。

C. 创建一个密钥策略，仅允许对 Amazon S3、DynamoDB、Lambda 和 Amazon EKS 执行 kms:Decrypt 操作。创建一个 SCP，拒绝创建未使用该密钥加密的 S3 存储桶和 DynamoDB 表。

正确性：此选项正确地限制了解密操作，仅允许 S3、DynamoDB、Lambda 和 Amazon EKS 使用密钥，同时通过 SCP 强制加密要求。

问题：无明显问题，完全符合题目要求。

D. 创建一个密钥策略，仅允许对 Amazon S3、DynamoDB、Lambda 和 Amazon EKS 执行 kms:Decrypt 操作。创建一个 AWS Config 规则，以发送未使用该密钥加密的资源的警报。

正确性：此选项部分正确，因为它限制了解密操作，并通过 AWS Config 规则监控加密状态。问题：AWS Config 规则只能发送警报，无法强制执行加密要求，因此不如 SCP 有效。

▼ 55

▼ 英文:

An AWS Lambda function was misused to alter data, and a security engineer must identify who invoked the function and what output was produced. The engineer cannot find any logs created by the Lambda function in Amazon CloudWatch Logs.

Which of the following explains why the logs are not available?

A. The execution role for the Lambda function did not grant permissions to write log data to CloudWatch Logs.

B. The Lambda function was invoked by using Amazon API Gateway, so the logs are not stored in CloudWatch Logs.

C. The execution role for the Lambda function did not grant permissions to write to the Amazon S3 bucket where CloudWatch Logs stores the logs.

D. The version of the Lambda function that was invoked was not current.

▼ 中文:

一个 AWS Lambda 函数被滥用来修改数据，一名安全工程师必须确认是谁调用了该函数以及产生了什么输出。工程师无法在 Amazon CloudWatch Logs 中找到该 Lambda 函数创建的任何日志。

以下哪项解释了为什么日志不可用？

- A. Lambda 函数的执行角色未授予将日志数据写入 CloudWatch Logs 的权限。
- B. Lambda 函数是通过 Amazon API Gateway 调用的，因此日志未存储在 CloudWatch Logs 中。
- C. Lambda 函数的执行角色未授予将日志写入存储 CloudWatch Logs 的 Amazon S3 bucket 的权限。
- D. 被调用的 Lambda 函数版本不是最新版本。

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS Lambda与CloudWatch Logs的集成，以及Lambda执行角色的权限配置。

了解Lambda函数如何将日志写入CloudWatch Logs，以及相关IAM权限的要求。

2. 选项分析

A. 正确。Lambda函数需要通过其执行角色拥有写入CloudWatch Logs的权限。

如果执行角色未授予 `logs:CreateLogGroup` 和 `logs:CreateLogStream` 以及

`logs:PutLogEvents` 权限，日志将无法写入CloudWatch Logs。

B. 错误。即使Lambda函数是通过API Gateway调用的，Lambda函数的日志仍然会写入CloudWatch Logs（前提是权限正确）。API Gateway的调用不会改变日志存储的默认行为。

C. 错误。CloudWatch Logs的日志存储在CloudWatch Logs服务中，而不是直接存储在Amazon S3中。此选项混淆了CloudWatch Logs与S3的存储机制。

D. The version of the Lambda function that was invoked was not current. 错误。Lambda函数的版本不会影响日志写入CloudWatch Logs的行为。只要执行角色的权限正确，任何版本的Lambda函数都可以写入日志。

▼ 56

▼ 英文:

A company is worried about potential DDoS attacks. The company has a web application that runs on Amazon EC2 instances.

The application uses Amazon S3 to serve static content such as images and videos.

A security engineer must create a resilient architecture that can withstand DDoS attacks.

Which solution will meet these requirements MOST cost-effectively?

- A. Create an Amazon CloudWatch alarm that invokes an AWS Lambda function when an EC2 instance's CPU utilization reaches 90%. Program the Lambda function to update security groups that are attached to the EC2 instance to deny inbound ports 80 and 443.
- B. Put the EC2 instances into an Auto Scaling group behind an Elastic Load Balancing (ELB) load balancer. Use Amazon CloudFront with Amazon S3 as an origin.
- C. Set up a warm standby disaster recovery (DR) environment. Fail over to the warm standby DR environment if a DDoS attack is detected on the application.
- D. Subscribe to AWS Shield Advanced. Configure permissions to allow the Shield Response Team to manage resources on the company's behalf during a DDoS event.

▼ 中文:

一家公司担心潜在的DDoS攻击。该公司有一个运行在Amazon EC2实例上的Web应用程序。该应用程序使用Amazon S3来提供静态内容，例如图片和视频。

一名安全工程师必须创建一个能够抵御DDoS攻击的弹性架构。

哪种解决方案能够以最具有成本效益的方式满足这些需求？

- A. 创建一个Amazon CloudWatch警报，当EC2实例的CPU利用率达到90%时触发一个AWS Lambda函数。编程Lambda函数以更新附加到EC2实例的安全组，从而拒绝入站端口80和443。
- B. 将EC2实例放入一个Auto Scaling组，并置于一个Elastic Load Balancing (ELB)负载均衡器后面。使用Amazon CloudFront，并将Amazon S3作为源。
- C. 设置一个热备用灾难恢复（DR）环境。如果在应用程序上检测到DDoS攻击，则切换到热备用DR环境。
- D. 订阅AWS Shield Advanced。配置权限以允许Shield响应团队在DDoS事件期间代表公司管理资源。

▼ 答案:

B

1. 考察的知识点

本题主要考察AWS的抗DDoS攻击能力和架构设计，包括使用Amazon CloudFront、Auto Scaling、Elastic Load Balancer (ELB)、AWS Shield Advanced等服务来增强系统的弹性和安全性。

还涉及到成本效益的考虑，要求选择最具性价比的解决方案。

2. 选项分析

A. Create an Amazon CloudWatch alarm that invokes an AWS Lambda function when an EC2 instance's CPU utilization

reaches 90%. Program the Lambda function to update security groups that are attached to the EC2 instance to deny inbound ports 80 and 443.

错误：此选项试图通过阻止端口80和443来应对DDoS攻击，但这会导致合法流量也被阻止，直接影响应用的可用性。

此外，DDoS攻击通常会导致资源耗尽，而不是单纯的CPU利用率高，因此这种方法无法有效应对DDoS攻击。

B. Put the EC2 instances into an Auto Scaling group behind an Elastic Load Balancing (ELB) load balancer. Use Amazon CloudFront with Amazon S3 as an origin.

正确：此选项通过使用Auto Scaling组动态扩展EC2实例来应对流量激增，同时使用ELB分发流量，增强系统的弹性。

Amazon CloudFront作为内容分发网络（CDN），可以缓存静态内容并减少对EC2实例的直接请求，从而降低DDoS攻击的影响。

Amazon S3作为静态内容的源，进一步减少了EC2实例的负载。这种架构既能有效应对DDoS攻击，又具有较高的性价比。

C. Set up a warm standby disaster recovery (DR) environment. Fail over to the warm standby DR environment if a DDoS attack is detected on the application.

错误：设置热备用灾难恢复环境成本较高，且切换到备用环境并不能解决DDoS攻击的根本问题。

此选项更适合应对灾难恢复场景，而非DDoS攻击。

D. Subscribe to AWS Shield Advanced. Configure permissions to allow the Shield Response Team to manage resources on the company's behalf during a DDoS event.

错误：虽然AWS Shield Advanced提供了高级DDoS保护，但订阅此服务的成本较高，可能不符合题目中“最具性价比”的要求。

此外，AWS Shield Advanced更适合需要额外支持和保护的企业，而不是所有场景都需要。

▼ 57

▼ 英文:

A company uses an organization in AWS Organizations to manage hundreds of AWS accounts. Some of the accounts provide access to external AWS principals through cross-account IAM roles and Amazon S3 bucket policies. The company needs to identify which external principals have access to which accounts. Which solution will provide this information?

- A. Enable AWS Identity and Access Management Access Analyzer for the organization. Configure the organization as a zone of trust. Filter findings by AWS account ID.
- B. Create a custom AWS Config rule to monitor IAM roles in each account. Deploy an AWS Config aggregator to a central account. Filter findings by AWS account ID.
- C. Activate Amazon Inspector. Integrate Amazon Inspector with AWS Security Hub. Filter findings by AWS account ID for the IAM role resource type and the S3 bucket policy resource type.
- D. Configure the organization to use Amazon GuardDuty. Filter findings by AWS account ID for the Discovery:IAMUser/AnomalousBehavior finding type.

▼ 中文:

一家公司使用 AWS Organizations 中的组织来管理数百个 AWS 账户。一些账户通过跨账户 IAM 角色和 Amazon S3 bucket 策略向外部 AWS principal 提供访问权限。该公司需要识别哪些外部 principal 可以访问哪些账户。哪种解决方案可以提供此信息？

- A. 为组织启用 AWS Identity and Access Management Access Analyzer。将组织配置为信任区域。按 AWS 账户 ID 筛选发现结果。
- B. 创建一个自定义 AWS Config 规则来监控每个账户中的 IAM 角色。在一个中心账户中部署 AWS Config 聚合器。按 AWS 账户 ID 筛选发现结果。
- C. 激活 Amazon Inspector。将 Amazon Inspector 与 AWS Security Hub 集成。按 IAM 角色资源类型和 S3 bucket 策略资源类型的 AWS 账户 ID 筛选发现结果。
- D. 将组织配置为使用 Amazon GuardDuty。按 Discovery:IAMUser/AnomalousBehavior 发现类型的 AWS 账户 ID 筛选发现结果。

▼ 答案:

A

1. 考察的知识点

本题考察的是 AWS Organizations 的管理能力，以及如何使用 AWS 工具（如 IAM Access Analyzer、AWS Config、Amazon Inspector、Amazon GuardDuty）来识别外部 AWS 主体对账户的访问权限。

2. 选项分析

A. Enable AWS Identity and Access Management Access Analyzer for the organization. Configure the organization as a zone of trust. Filter findings by AWS account ID.

正确：IAM Access Analyzer 是专门设计用于分析和识别外部主体对资源的访问权

限的工具。通过将组织配置为信任区域，可以集中分析所有账户的外部访问权限。此解决方案直接满足题目要求，能够识别哪些外部主体访问了哪些账户。

B. Create a custom AWS Config rule to monitor IAM roles in each account. Deploy an AWS Config aggregator to a central account. Filter findings by AWS account ID.

错误：虽然AWS Config可以监控资源配置，但它并不直接提供外部主体访问权限的分析功能。需要额外的自定义规则和复杂的配置，效率较低。

此选项不如IAM Access Analyzer直接且高效。

C. Activate Amazon Inspector. Integrate Amazon Inspector with AWS Security Hub. Filter findings by AWS account ID for the IAM role resource type and the S3 bucket policy resource type.

错误：Amazon Inspector主要用于检测安全漏洞和合规性问题，而不是分析外部主体的访问权限。

此选项与题目要求不匹配。

D. Configure the organization to use Amazon GuardDuty. Filter findings by AWS account ID for the Discovery:IAMUser/AnomalousBehavior finding type.

错误：Amazon GuardDuty主要用于检测异常行为和潜在威胁，而不是专门分析外部主体的访问权限。

此选项与题目要求不匹配。

▼ 58

▼ 英文:

A company has AWS accounts in an organization in AWS Organizations. The company needs to install a corporate software package on all Amazon EC2 instances for all the accounts in the organization.

A central account provides base AMIs for the EC2 instances. The company uses AWS Systems Manager for software inventory and patching operations.

A security engineer must implement a solution that detects EC2 instances that do not have the required software. The solution also must automatically install the software if the software is not present.

Which solution will meet these requirements?

A. Provide new AMIs that have the required software pre-installed. Apply a tag to the AMIs to indicate that the AMIs have the required software. Configure an SCP that allows new EC2 instances to be launched only if the instances have the tagged AMIs. Tag all existing EC2 instances.

B. Configure a custom patch baseline in Systems Manager Patch Manager. Add the package name for the required software to the approved packages list. Associate the new patch baseline with all EC2 instances. Set up a maintenance window for software deployment.

C. Centrally enable AWS Config. Set up the ec2-managedinstance-applications-required AWS Config rule for all accounts.

Create an Amazon EventBridge rule that reacts to AWS Config events.

Configure the EventBridge rule to invoke an AWS Lambda function that uses Systems Manager Run Command to install the required software.

D. Create a new Systems Manager Distributor package for the required software. Specify the download location. Select all EC2 instances in the different accounts. Install the software by using Systems Manager Run Command.

▼ 中文:

一家公司在 AWS Organizations 中拥有多个 AWS 账户。该公司需要在组织中所有账户的所有 Amazon EC2 实例上安装企业软件包。

一个中心账户提供 EC2 实例的基础 AMIs。该公司使用 AWS Systems Manager 进行软件清单和补丁操作。

一名安全工程师必须实施一个解决方案，以检测没有安装所需软件的 EC2 实例。该解决方案还必须自动安装软件（如果软件未安装）。

哪种解决方案可以满足这些要求？

A. 提供预安装了所需软件的新 AMIs。为这些 AMIs 添加一个标签，以表明这些 AMIs 已安装了所需软件。配置一个 SCP，允许仅使用带有标签的 AMIs 启动新的 EC2 实例。为所有现有的 EC2 实例添加标签。

B. 在 Systems Manager Patch Manager 中配置一个自定义补丁基线。将所需软件的包名称添加到批准的包列表中。将新的补丁基线与所有 EC2 实例关联。设置一个维护窗口以进行软件部署。

C. 集中启用 AWS Config。为所有账户设置 ec2-managedinstance-applications-required AWS Config 规则。创建一个响应 AWS Config 事件的 Amazon EventBridge 规则。配置 EventBridge 规则以调用一个 AWS Lambda 函数，该函数使用 Systems Manager Run Command 来安装所需软件。

D. 为所需软件创建一个新的 Systems Manager Distributor 包。指定下载位置。选择不同账户中的所有 EC2 实例。使用 Systems Manager Run Command 安装软件。

▼ 答案:

C

1. 考察的知识点

AWS Systems Manager 的功能，包括 Patch Manager、Run Command 和 Distributor。

AWS Config 的规则和事件触发机制。

Amazon EventBridge的事件处理和Lambda函数的集成。
跨账户管理和自动化操作的最佳实践。

2. 选项分析

A. 提供预安装了所需软件的新 AMIs，并使用 SCP 限制实例启动：

错误。虽然预安装软件的 AMIs可以确保新实例具有所需软件，但此方法无法检测现有实例是否缺少软件。此

外，SCP（Service Control Policies）无法直接限制实例是否使用特定 AMI启动。

B. 使用 Systems Manager Patch Manager 配置自定义补丁基线：

错误。Patch Manager主要用于操作系统补丁管理，而不是安装特定的第三方软件包。虽然可以设置维护窗口，但此方法无法检测现有实例是否缺少软件。

C. 使用 AWS Config 和 EventBridge 自动检测并安装软件：

正确。AWS Config可以通过规则（如ec2-managedinstance-applications-required）检测实例是否缺少所需软件。

EventBridge可以触发Lambda函数，使用Systems Manager Run Command自动安装软件。这种方法既能检测问题，又能自动修复。

D. 使用 Systems Manager Distributor 创建软件包并手动安装：

错误。虽然Distributor可以分发软件包，但此方法需要手动选择实例并运行命令，无法实现自动检测和修复。

▼ 59

▼ 英文:

A development team is creating an open source toolset to manage a company's software as a service (SaaS) application. The company stores the code in a public repository so that anyone can view and download the toolset's code. The company discovers that the code contains an IAM access key and secret key that provide access to internal resources in the company's AWS environment

A security engineer must implement a solution to identify whether unauthorized usage of the exposed credentials has occurred. The solution also must prevent any additional usage of the exposed credentials.

Which combination of steps will meet these requirements? (Choose two.)

A. Use AWS Identity and Access Management Access Analyzer to determine which resources the exposed credentials accessed and who used them.

B. Deactivate the exposed IAM access key from the user's IAM account.

C. Create a rule in Amazon GuardDuty to block the access key in the source code from being used.

D. Create a new IAM access key and secret key for the user whose credentials were exposed.

E. Generate an IAM credential report. Check the report to determine when the user that owns the access key last logged in.

▼ 中文:

一个开发团队正在创建一个开源工具集，用于管理公司的软件即服务 (SaaS) 应用程序。公司将代码存储在公共仓库中，以便任何人都可以查看和下载该工具集的代码。公司发现代码中包含了一个 IAM 访问密钥和秘密密钥，这些密钥提供了对公司 AWS 环境中内部资源的访问权限。一名安全工程师必须实施一个解决方案，以识别是否发生了对暴露凭证的未经授权使用。该解决方案还必须防止任何额外的暴露凭证使用。哪些步骤组合可以满足这些要求？（选择两个。）

A.使用 AWS Identity and Access Management Access Analyzer 来确定暴露的凭证访问了哪些资源以及谁使用了它们。

B.从用户的 IAM 账户中停用暴露的 IAM 访问密钥。

C.在 Amazon GuardDuty 中创建一个规则，以阻止源代码中的访问密钥被使用。

D.为凭证暴露的用户创建一个新的 IAM 访问密钥和秘密密钥。

E.生成一个 IAM 凭证报告。检查报告以确定拥有访问密钥的用户最后一次登录的时间。

▼ 答案:

AB

1. 考察的知识点

IAM访问密钥管理与安全性

如何检测和响应暴露的凭证

使用AWS工具（如Access Analyzer）进行资源访问分析

2. 选项分析

A. Use AWS Identity and Access Management Access Analyzer to determine which resources the exposed credentials accessed and who used them.

正确：Access Analyzer可以帮助识别暴露的凭证访问了哪些资源以及谁使用了它们。这是解决问题的第一步，能够提供详细的访问信息。

B. Deactivate the exposed IAM access key from the user's IAM account.

正确：停用暴露的访问密钥是防止进一步使用的关键步骤。这可以立即阻止任何未授权的访问。

C. Create a rule in Amazon GuardDuty to block the access key in the source code from being used.

错误：Amazon GuardDuty是一个威胁检测服务，但它不能直接创建规则来阻止访问密钥的使用。它可以检测异常行为，但无法主动阻止密钥使用。

D. Create a new IAM access key and secret key for the user whose credentials were exposed.

错误：创建新的访问密钥并不能解决暴露的密钥问题。暴露的密钥仍然可以被使

用，必须先停用暴露的密钥。

E. Generate an IAM credential report. Check the report to determine when the user that owns the access key last logged in.

错误：生成IAM凭证报告可以提供用户登录信息，但无法直接解决暴露的密钥问题，也不能防止进一步的使用。

▼ 60

▼ 英文:

A company needs to create a centralized solution to analyze log files. The company uses an organization in AWS Organizations to manage its AWS accounts.

The solution must aggregate and normalize events from the following sources:

- The entire organization in Organizations
- All AWS Marketplace offerings that run in the company's AWS accounts
- The company's on-premises systems

Which solution will meet these requirements?

A. Configure a centralized Amazon S3 bucket for the logs. Enable VPC Flow Logs, AWS CloudTrail, and Amazon Route 53 logs in all accounts. Configure all accounts to use the centralized S3 bucket. Configure AWS Glue crawlers to parse the logfiles. Use Amazon Athena to query the log data.

B. Configure log streams in Amazon CloudWatch Logs for the sources that need monitoring. Create log subscription filters for each log stream. Forward the messages to Amazon OpenSearch Service for analysis.

C. Set up a delegated Amazon Security Lake administrator account in Organizations. Enable and configure Security Lake for the organization. Add the accounts that need monitoring. Use Amazon Athena to query the log data.

D. Apply an SCP to configure all member accounts and services to deliver log files to a centralized Amazon S3 bucket. Use Amazon OpenSearch Service to query the centralized S3 bucket for log entries.

▼ 中文:

一家公司需要创建一个集中化的解决方案来分析日志文件。该公司使用AWS Organizations中的组织来管理其AWS账户。

该解决方案必须聚合并规范化以下来源的事件：

- Organizations中的整个组织
- 运行在公司AWS账户中的所有AWS Marketplace产品
- 公司的本地系统

哪种解决方案可以满足这些要求？

- A.配置一个集中化的Amazon S3存储桶用于日志。启用VPC Flow Logs、AWS CloudTrail和Amazon Route 53日志在所有账户中。配置所有账户使用集中化的S3存储桶。配置AWS Glue爬网器解析日志文件。使用Amazon Athena查询日志数据。
- B.配置一个集中化的Amazon S3存储桶用于日志。启用VPC Flow Logs、AWS CloudTrail和Amazon Route 53日志在所有账户中。配置所有账户使用集中化的S3存储桶。配置AWS Glue爬网器解析日志文件。使用Amazon Athena查询日志数据。
- C.在Organizations中设置一个委托的Amazon Security Lake管理员账户。为组织启用并配置Security Lake。添加需要监控的账户。使用Amazon Athena查询日志数据。
- D.应用一个SCP以配置所有成员账户和服务，将日志文件传送到集中化的Amazon S3存储桶。使用Amazon OpenSearch Service查询集中化的S3存储桶中的日志条目。

▼ 答案:

C

1. 考察的知识点

集中化日志管理与分析解决方案

AWS Organizations的使用

Amazon Security Lake的功能与配置

日志数据的查询与分析工具（如Amazon Athena）

2. 选项分析

A. 配置一个集中化的Amazon S3存储桶用于日志。

正确性分析：此选项提到使用Amazon S3集中存储日志，并使用AWS Glue和Amazon Athena进行查询。这种方法可以实

现日志的集中化存储和分析，但它没有提到如何处理AWS Marketplace和本地系统的日志，也没有提到如何规范化事件数据。

结论：部分正确，但不完全满足题目要求。

B. 配置Amazon CloudWatch Logs日志流。

正确性分析：此选项提到使用CloudWatch Logs和Amazon OpenSearch Service进行日志分析，但CloudWatch Logs主要用于实时监控和分析，而不是集中化存储和规范化事件数据。此外，它没有提到如何处理AWS Marketplace和本地系统的日志。

结论：不完全满足题目要求。

C. 设置一个委托的Amazon Security Lake管理员账户。

正确性分析：此选项提到使用Amazon Security Lake，这是一个专门设计用于集中化日志管理和分析的服务。它支持从多个来源（包括AWS服务、AWS Marketplace和本地系统）收集、规范化和分析日志数据，并与Amazon Athena集成进行查询。

结论：完全满足题目要求，是正确答案。

D. 应用SCP以配置所有成员账户和服务。

正确性分析：此选项提到使用SCP（Service Control Policies）来强制日志传送到集中化的S3存储桶，并使用Amazon OpenSearch Service进行查询。虽然SCP可以强制执行策略，但它无法直接处理日志的规范化和分析。此外，它没有提到如何处理AWS Marketplace和本地系统的日志。

结论：不完全满足题目要求。

▼ 61

▼ 英文:

A company uses AWS Organizations. The company has more than 100 AWS accounts and will increase the number of accounts.

The company also uses an external corporate identity provider (IdP).

The company needs to provide users with role-based access to the accounts.

The solution must maximize scalability and operational efficiency.

Which solution will meet these requirements?

A. In each account, create a set of dedicated IAM users. Ensure that all users assume these IAM users through federation with the existing IdP.

B. Deploy an IAM role in a central identity account. Allow users to assume the role through federation with the existing IdP. In each account, deploy a set of IAM roles that match the desired access patterns. Include a trust policy that allows access from the central identity account. Edit the permissions policy for the role in each account to match user access requirements.

C. Enable AWS IAM Identity Center. Integrate IAM Identity Center with the company's existing IdP. Create permission sets that match the desired access patterns. Assign permissions to match user access requirements.

D. In each account, deploy a set of IAM roles that match the desired access patterns. Create a trust policy with the existing IdP. Update each role's permissions policy to use SAML-based IAM condition keys that are based on user access requirements.

▼ 中文:

一家公司使用 AWS Organizations。该公司拥有超过 100 个 AWS 账户，并且账户数量还将增加。该公司还使用外部企业身份提供商 (IdP)。

该公司需要为用户提供基于角色的账户访问权限。解决方案必须**最大化可扩展性和运营效率**。

哪种解决方案可以满足这些需求？

A. 在每个账户中创建一组专用的 IAM 用户。确保所有用户通过与现有 IdP 的联合身份验证来使用这些 IAM 用户。

B. 在一个中央身份账户中部署一个 IAM 角色。允许用户通过与现有 IdP 的联合身份验证来使用该角色。在每个账户中部署一组与所需访问模式匹配的 IAM 角色。包含允许从中央身份账户访问的信任策略。编辑每个账户中角色的权限策略以匹配用户访问需求。

C. 启用 AWS IAM Identity Center。将 IAM Identity Center 与公司的现有 IdP 集成。创建与所需访问模式匹配的权限集。分配权限以匹配用户访问需求。

D. 在每个账户中部署一组与所需访问模式匹配的 IAM 角色。创建一个与现有 IdP 的信任策略。更新每个角色的权限策略以使用基于 SAML 的 IAM 条件键，这些条件键基于用户访问需求。

▼ 答案:

C

1. 考察的知识点

AWS Organizations的账户管理与扩展性。

使用外部身份提供商（IdP）进行身份联合。

IAM Identity Center（原AWS SSO）的功能与集成。

角色和权限管理的最佳实践。

2. 选项分析

A. 在每个账户中创建一组专用的 IAM 用户。确保所有用户通过与现有 IdP 的联合身份验证来使用这些 IAM 用户。

错误原因：

创建专用的IAM用户在每个账户中会导致管理复杂性，尤其是当账户数量增加时，无法满足“最大化可扩展性和操作效率”的要求。

使用IAM用户而不是IAM角色或集中式身份管理解决方案不符合最佳实践。

B. 在一个中央身份账户中部署一个 IAM 角色。允许用户通过与现有 IdP 的联合身份验证来使用该角色。在每个账户中部署一组与所需访问模式匹配的 IAM 角色。包含允许从中央身份账户访问的信任策略。编辑每个账户中角色的权限策略以匹配用户访问需求。

错误原因：

虽然这种方法可以实现跨账户访问，但需要在每个账户中手动部署IAM角色并配置信任策略，操作效率较低。

随着账户数量增加，管理这些角色的复杂性会显著增加，不符合“最大化可扩展性”的要求。

C. 启用 AWS IAM Identity Center。将 IAM Identity Center 与公司的现有 IdP 集成。创建与所需访问模式匹配的权限集。分配权限以匹配用户访问需求。

正确原因：

AWS IAM Identity Center（原AWS SSO）是专门设计用于集中管理用户访问的

服务，支持与外部IdP集成。

通过权限集，可以轻松定义和分配基于角色的访问权限，满足“最大化可扩展性和操作效率”的要求。

IAM Identity Center支持自动扩展，适合管理大量账户和用户。

D. 在每个账户中部署一组与所需访问模式匹配的 IAM 角色。创建一个与现有 IdP 的信任策略。更新每个角色的

权限策略以使用基于 SAML 的 IAM 条件键，这些条件键基于用户访问需求。

错误原因：

这种方法需要在每个账户中手动部署IAM角色并配置信任策略，操作效率较低。

基于SAML的IAM条件键虽然可以实现细粒度的访问控制，但管理复杂性较高，不符合“最大化可扩展性”的要求。

▼ 62

▼ 英文:

A company has a web-based application that runs behind an Application Load Balancer (ALB). The application is experiencing a credential stuffing attack that is producing many failed login attempts. The attack is coming from many IP addresses. The login attempts are using a user agent string of a known mobile device emulator.

A security engineer needs to implement a solution to mitigate the credential stuffing attack. The solution must still allow legitimate logins to the application. Which solution will meet these requirements?

A. Create an Amazon CloudWatch alarm that reacts to login attempts that contain the specified user agent string Add an Amazon Simple Notification Service (Amazon SNS) topic to the alarm.

B. Modify the inbound security group on the ALB to deny traffic from the IP addresses that are involved in the attack.

C. Create an AWS WAF web ACL for the ALB Create a custom rule that blocks requests that contain the user agent string of the device emulator.

D. Create an AWS WAF web ACL for the ALB. Create a custom rule that allows requests from legitimate user agent strings.

▼ 中文:

一家公司有一个基于网络的应用程序，该应用程序运行在一个 Application Load Balancer (ALB) 后面。该应用程序正在遭受凭证填充攻击，导致大量登录尝试失败。攻击来自多个 IP 地址。这些登录尝试使用的是已知移动设备模拟器的用户代理字符串。

一名安全工程师需要实施一个解决方案来缓解凭证填充攻击。该解决方案仍然必须允许合法用户登录到应用程序。哪种解决方案可以满足这些要求？

A. 创建一个 Amazon CloudWatch alarm，响应包含指定用户代理字符串的登录尝试。将一个 Amazon Simple Notification Service (Amazon SNS) 主题添加到该

alarm。

B.修改 ALB 的入站安全组以拒绝来自参与攻击的 IP 地址的流量。

C.为 ALB 创建一个 AWS WAF web ACL。创建一个自定义规则，阻止包含设备模拟器用户代理字符串的请求。

D.为 ALB 创建一个 AWS WAF web ACL。创建一个自定义规则，允许来自合法用户代理字符串的请求。

▼ 答案:

C

1. 考察的知识点

本题考察AWS WAF（Web Application Firewall）的使用，特别是如何创建Web ACL规则来防御特定类型的攻击。

涉及到安全事件响应和防御策略的设计，包括如何识别和阻止恶意流量，同时允许合法流量通过。

2. 选项分析

A. Create an Amazon CloudWatch alarm that reacts to login attempts that contain the specified user agent string. Add an

Amazon Simple Notification Service (Amazon SNS) topic to the alarm.

错误：CloudWatch和SNS可以用于监控和通知，但它们无法直接阻止攻击流量。此选项无法满足题目要求的“阻止恶意流量”的需求。

B. Modify the inbound security group on the ALB to deny traffic from the IP addresses that are involved in the attack.

错误：安全组只能基于IP地址进行过滤，而题目中提到攻击来自“许多IP地址”，且这些IP地址可能会动态变化，因此使用安全组无法有效解决问题。

C. Create an AWS WAF web ACL for the ALB. Create a custom rule that blocks requests that contain the user agent string of the device emulator.

正确：AWS WAF允许基于用户代理字符串创建自定义规则，可以有效阻止使用特定用户代理字符串的恶意流量，同时允许合法流量通过。

D. Create an AWS WAF web ACL for the ALB. Create a custom rule that allows requests from legitimate user agent strings.

错误：此选项的规则设计为“允许合法用户代理字符串”，但无法全面覆盖所有合法流量，可能会误阻止一些合法请求。

▼ 63

▼ 英文:

A company is investigating controls to protect sensitive data. The company uses Amazon Simple Notification Service (Amazon SNS) topics to publish messages from application components to custom logging services.

The company is concerned that an application component might publish sensitive data that will be accidentally exposed in transaction logs and debug

logs.

Which solution will protect the sensitive data in these messages from accidental exposure?

- A. Use Amazon Macie to scan the SNS topics for sensitive data elements in the SNS messages. Create an AWS Lambda function that masks sensitive data inside the messages when Macie records a new finding.
- B. Configure an inbound message data protection policy. In the policy, include the De-identify operation to mask the sensitive data inside the messages. Apply the policy to the SNS topics.
- C. Configure the SNS topics with an AWS Key Management Service (AWS KMS) customer managed key to encrypt the data elements inside the messages. Grant permissions to all message publisher IAM roles to allow access to the key to encrypt data.
- D. Create an Amazon GuardDuty finding for sensitive data that is transmitted to the SNS topics. Create an AWS Security Hub custom remediation action to block messages that contain sensitive data from being delivered to subscribers of the SNS topics.

▼ 中文:

一家公司正在研究保护敏感数据的控制措施。该公司使用 Amazon Simple Notification Service (Amazon SNS) 主题从应用程序组件向自定义日志服务发布消息。

该公司担心某个应用程序组件可能会发布敏感数据，从而导致这些数据意外暴露在事务日志和调试日志中。

哪种解决方案可以保护这些消息中的敏感数据免于意外暴露？

- A. 使用 Amazon Macie 扫描 SNS 主题中的 SNS 消息以查找敏感数据元素。当 Macie 记录新的发现时，创建一个 AWS Lambda 函数以屏蔽消息中的敏感数据。
- B. 配置一个入站消息数据保护策略。在策略中，包含 De-identify 操作以屏蔽消息中的敏感数据。将策略应用于 SNS 主题。
- C. 使用 AWS Key Management Service (AWS KMS) 客户管理密钥配置 SNS 主题，以加密消息中的数据元素。授予所有消息发布者 IAM 角色权限，以允许访问密钥来加密数据。
- D. 为传输到 SNS 主题的敏感数据创建一个 Amazon GuardDuty 发现。创建一个 AWS Security Hub 自定义补救操作，以阻止包含敏感数据的消息传递给 SNS 主题的订阅者。

▼ 答案:

B

1. 考察的知识点

本题考察的是如何保护敏感数据，特别是在使用 Amazon SNS 时，防止敏感数据

被意外暴露。

涉及的AWS服务包括Amazon SNS、数据保护策略、AWS KMS、Amazon Macie、Amazon GuardDuty和AWS Security Hub。

2. 选项分析

A. 使用 Amazon Macie 扫描 SNS 主题中的 SNS 消息以查找敏感数据元素。当 Macie 记录新的发现时，创建一个AWS Lambda 函数以屏蔽消息中的敏感数据。Amazon Macie是一个敏感数据发现服务，主要用于扫描S3存储桶中的数据，而不是SNS消息。

虽然可以通过Lambda函数对数据进行屏蔽，但这种方法是在事后处理，无法在消息发布时立即保护数据。

此选项不符合题目要求的“防止敏感数据被意外暴露”，因此错误。

B. 配置一个入站消息数据保护策略。在策略中，包含 De-identify 操作以屏蔽消息中的敏感数据。将策略应用于SNS 主题。此选项直接使用SNS的入站消息数据保护策略，能够在消息发布时立即屏蔽敏感数据。

De-identify操作是专门用于屏蔽敏感数据的功能，符合题目要求。

此选项是正确答案。

C. 使用 AWS Key Management Service (AWS KMS) 客户管理密钥配置 SNS 主题，以加密消息中的数据元素。授予所

有消息发布者 IAM 角色权限，以允许访问密钥来加密数据。

使用AWS KMS加密SNS消息可以保护数据的机密性，但加密并不能屏蔽敏感数据。

加密后的数据仍然可能被记录到日志中，无法解决题目中“防止敏感数据被意外暴露”的问题。

此选项不符合题目要求，因此错误。

D. 为传输到 SNS 主题的敏感数据创建一个 Amazon GuardDuty 发现。创建一个 AWS Security Hub 自定义补救操作，

以阻止包含敏感数据的消息传递给 SNS 主题的订阅者。

Amazon GuardDuty主要用于检测安全威胁，而不是专门用于发现敏感数据。

即使创建了Security Hub的补救操作，这种方法也是事后处理，无法在消息发布时立即保护数据。

此选项不符合题目要求，因此错误。

▼ 64

▼ 英文:

A company has created a set of AWS Lambda functions to automate incident response steps for incidents that occur on Amazon EC2 instances. The Lambda functions need to collect relevant artifacts, such as instance ID and security group configuration. The Lambda functions must then write a summary to an Amazon S3 bucket.

The company runs its workloads in a VPC that uses public subnets and private subnets. The public subnets use an internet gateway to access the internet. The

private subnets use a NAT gateway to access the internet.

All network traffic to Amazon S3 that is related to the incident response process must use the AWS network. This traffic must not travel across the internet.

Which solution will meet these requirements?

- A. Deploy the Lambda functions to a private subnet in the VPC. Configure the Lambda functions to access the S3 service through the NAT gateway.
- B. Deploy the Lambda functions to a private subnet in the VPC. Create an S3 gateway endpoint to access the S3 service.
- C. Deploy the S3 bucket and the Lambda functions in the same private subnet. Configure the Lambda functions to use the default endpoint for the S3 service.
- D. Deploy an Amazon Simple Queue Service (Amazon SQS) queue and the Lambda functions in the same private subnet. Configure the Lambda functions to send data to the SQS queue. Configure the SQS queue to send data to the S3 bucket.

▼ 中文:

一家公司创建了一组AWS Lambda函数，用于自动化处理发生在Amazon EC2实例上的事件响应步骤。这些Lambda函数需要收集相关的工件，例如实例ID和安全组配置。然后，Lambda函数必须将摘要写入到Amazon S3存储桶中。

该公司在一个使用公共子网和私有子网的VPC中运行其工作负载。公共子网使用Internet Gateway访问互联网。私有子网使用NAT Gateway访问互联网。

与事件响应过程相关的所有到Amazon S3的网络流量必须使用AWS网络。这些流量不得通过互联网传输。

哪种解决方案可以满足这些要求？

- A. 将Lambda函数部署到VPC中的私有子网。配置Lambda函数通过NAT Gateway访问S3服务。
- B. 将Lambda函数部署到VPC中的私有子网。创建一个S3 Gateway Endpoint以访问S3服务。
- C. 将S3存储桶和Lambda函数部署到同一个私有子网。配置Lambda函数使用S3服务的默认端点。
- D. 将Amazon Simple Queue Service (Amazon SQS)队列和Lambda函数部署到同一个私有子网。配置Lambda函数将数据发送到SQS队列。配置SQS队列将数据发送到S3存储桶。

▼ 答案:

B

1. 考察的知识点

VPC网络配置与子网类型（公有子网 vs 私有子网）

AWS Lambda与VPC集成

使用VPC Endpoint（特别是S3 Gateway Endpoint）优化网络流量

安全性要求：确保流量不经过互联网

2. 选项分析

A. Deploy the Lambda functions to a private subnet in the VPC. Configure the Lambda functions to access the S3 service through the NAT gateway.

错误原因：虽然NAT网关可以让私有子网中的资源访问S3，但流量会通过互联网，而题目明确要求所有流量必须使用AWS网络，不能经过互联网。

B. Deploy the Lambda functions to a private subnet in the VPC. Create an S3 gateway endpoint to access the S3 service.

正确原因：将Lambda函数部署到私有子网，并通过S3 Gateway Endpoint访问S3服务，确保流量完全在AWS网络内传输，符合题目要求。

C. Deploy the S3 bucket and the Lambda functions in the same private subnet. Configure the Lambda functions to use the default endpoint for the S3 service.

错误原因：S3服务是区域级服务，不依赖具体的子网。将S3存储桶部署到特定子网没有意义，且默认端点可能会导致流量经过互联网。

D. Deploy an Amazon Simple Queue Service (Amazon SQS) queue and the Lambda functions in the same private subnet.

Configure the Lambda functions to send data to the SQS queue. Configure the SQS queue to send data to the S3 bucket.

错误原因：虽然SQS可以作为中间层，但题目没有要求使用SQS，且此选项增加了不必要的复杂性。SQS本身也需要正确配置以确保流量不经过互联网。

▼ 65

▼ 英文:

A company uses an organization in AWS Organizations to manage its AWS accounts. The company has implemented an SCP in the root account to prevent resources from being shared with external accounts.

The company now needs to allow applications in its marketing team's AWS account to share resources with external accounts.

The company must continue to prevent all the other accounts in the organization from sharing resources with external accounts. All the accounts in the organization are members of the same OU.

Which solution will meet these requirements?

A. Create a new SCP in the marketing team's account Configure the SCP to explicitly allow resource sharing.

B. Edit the existing SCP to add a Condition statement that excludes the marketing team's account.

- C. Edit the existing SCP to include an Allow statement that specifies the marketing team's account.
- D. Create an IAM permissions boundary policy to explicitly allow resource sharing Attach the policy to IAM users in the marketing team's account.

▼ 中文:

一家公司使用 AWS Organizations 中的组织来管理其 AWS 账户。该公司在根账户中实施了一个 SCP，以防止资源与外部账户共享。

该公司现在需要允许其营销团队的 AWS 账户中的应用程序与外部账户共享资源。公司必须继续防止组织中的所有其他账户与外部账户共享资源。组织中的所有账户都是同一 OU 的成员。

哪种解决方案可以满足这些要求？

- A.在营销团队的账户中创建一个新的 SCP 配置该 SCP 以明确允许资源共享。
- B.编辑现有的 SCP 以添加一个 Condition 语句，将营销团队的账户排除在外。
- C.编辑现有的 SCP 以包含一个 Allow 语句，指定营销团队的账户。
- D.创建一个 IAM 权限边界策略以明确允许资源共享 将策略附加到营销团队账户中的 IAM 用户。

▼ 答案:

B

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的使用和管理。
重点在于如何通过SCP实现精细化权限控制，同时满足特定账户的需求。

2. 选项分析

A. Create a new SCP in the marketing team's account Configure the SCP to explicitly allow resource sharing.

错误：SCP只能在组织根账户或OU级别管理，不能在单个账户中创建SCP。
营销团队的账户无法单独管理SCP，因此此选项不符合要求。

B. Edit the existing SCP to add a Condition statement that excludes the marketing team's account.

正确：通过在现有SCP中添加Condition语句，可以排除营销团队的账户，使其能够共享资源，同时保持其他账户的限制。

此方法符合题目要求，并且是官方推荐的最佳实践。

C. Edit the existing SCP to include an Allow statement that specifies the marketing team's account.

错误：SCP的默认行为是“拒绝优先”，即使添加Allow语句，也无法覆盖显式拒绝的规则。

此选项无法实现题目要求的精细化权限控制。

D. Create an IAM permissions boundary policy to explicitly allow resource

sharing Attach the policy to IAM users in the marketing team's account.

错误：IAM权限边界仅用于限制IAM用户或角色的权限，无法覆盖SCP的限制。
此选项与题目要求的SCP管理无关，因此不符合要求。

▼ 66

▼ 英文:

A security administrator has enabled AWS Security Hub for all the AWS accounts in an organization in AWS Organizations. The security team wants near-real-time response and remediation for deployed AWS resources that do not meet security standards.

All changes must be centrally logged for auditing purposes.

The organization has reached the quotas for the number of SCPs attached to an OU and SCP document size. The team wants to avoid making any changes to any of the SCPs. The solution must maximize scalability and cost-effectiveness. Which combination of actions should the security administrator take to meet these requirements? (Choose three.)

A. Create an AWS Config custom rule to detect configuration changes to AWS resources. Create an AWS Lambda function to remediate the AWS resources in the delegated administrator AWS account.

B. Use AWS Systems Manager Change Manager to track configuration changes to AWS resources. Create a Systems Manager document to remediate the AWS resources in the delegated administrator AWS account.

C. Create a Security Hub custom action to reference in an Amazon EventBridge event rule in the delegated administrator AWS account.

D. Create an Amazon EventBridge event rule to Invoke an AWS Lambda function that will take action on AWS resources.

▼ 中文:

安全管理员已为 AWS Organizations 中组织的所有 AWS 账户启用了 AWS Security Hub。安全团队希望对不符合安全标准的已部署 AWS 资源进行近实时响应和修复。所有更改必须集中记录以供审计使用。

该组织已达到附加到 OU 的 SCP 数量配额以及 SCP 文档大小配额。团队希望避免对任何 SCP 进行更改。解决方案必须最大化可扩展性和成本效益。

安全管理员应采取哪些组合操作来满足这些要求？（选择三项）

A. 创建一个 AWS Config 自定义规则以检测对 AWS 资源的配置更改。在委派管理员 AWS 账户中创建一个 AWS Lambda 函数以修复 AWS 资源。

B. 使用 AWS Systems Manager Change Manager 跟踪对 AWS 资源的配置更改。在委派管理员 AWS 账户中创建一个 Systems Manager 文档以修复 AWS 资源。

C.创建一个 Security Hub 自定义操作以在委派管理员 AWS 账户中的 Amazon EventBridge 事件规则中引用。

D.创建一个 Amazon EventBridge 事件规则以调用一个 AWS Lambda 函数，该函数将对 AWS 资源采取行动。

E.创建一个 Amazon EventBridge 事件规则以调用一个 AWS Lambda 函数，该函数将评估一组 API 请求的 AWS 资源配置，并为不合规的 AWS 资源创建发现。

F.创建一个 Amazon EventBridge 事件规则以按计划调用一个 AWS Lambda 函数，以评估特定的 AWS Config 规则。

▼ 答案:

ACD

1. 考察的知识点

AWS Security Hub的使用与集成。

Amazon EventBridge事件规则的配置与触发。

AWS Lambda函数的使用与自动化响应。

如何实现安全事件的实时响应与修复。

成本效益和可扩展性设计。

2. 选项分析

A.

正确性分析:AWS Config可以检测资源配置的变化，但题目要求“避免对SCP进行更改”，而AWS Config规则的创建并不直接满足题目中提到的“Security Hub”和“EventBridge”的集成需求。

错误原因:虽然AWS Config可以检测配置变化，但它不是题目中要求的最佳解决方案，且没有直接提到与Security Hub的集成。

结论:错误。

B.

正确性分析:AWS Systems Manager Change Manager主要用于变更管理，而不是实时响应和修复不符合安全标准的资源。

错误原因:题目要求“实时响应和修复”，而Change Manager的功能更偏向于变更跟踪和管理，不符合题目需求。

结论:错误。

C.

正确性分析:Security Hub的自定义操作可以与EventBridge集成，用于触发事件规则并实现自动化响应。

正确原因:此选项直接满足题目中提到的“Security Hub”和“EventBridge”的集成需求，且支持实时响应。

结论:正确。

D.

正确性分析:EventBridge事件规则可以触发Lambda函数以对资源进行操作，满足实时响应和修复的需求。

正确原因:此选项直接支持题目中提到的“实时响应和修复”，且与Security Hub集成非常适合。

结论:正确。

E.

正确性分析:虽然可以通过Lambda函数评估资源配置并创建发现，但题目要求的是“实时响应和修复”，而不是仅仅创建发现。

错误原因:此选项没有直接提到修复不符合安全标准的资源，仅仅是创建发现，不符合题目需求。

结论:错误。

F.

正确性分析:按计划评估AWS Config规则不符合题目中提到的“实时响应”的需求。

错误原因:此选项是基于计划的评估，而不是实时响应，不符合题目需求。

结论: 错误。

▼ 67

▼ 英文:

A security engineer must implement monitoring of a company's Amazon Aurora MySQL DB instances. The company wants to receive email notifications when unknown users try to log in to the database endpoint.

Which solution will meet these requirements with the LEAST operational overhead?

A. Enable Amazon GuardDuty. Enable the Amazon RDS Protection feature in GuardDuty to detect login attempts by unknown users. Create an Amazon EventBridge rule to filter GuardDuty findings. Send email notifications by using Amazon Simple Notification Service (Amazon SNS).

B. Enable the `server_audit_logging` parameter on the Aurora MySQL DB instances. Use AWS Lambda to periodically scan the delivered log files for login attempts by unknown users. Send email notifications by using Amazon Simple Notification Service (Amazon SNS).

C. Create an Amazon RDS Custom AMI. Include a third-party security agent in the AMI to detect login attempts by unknown users. Deploy RDS Custom DB instances. Migrate data from the existing installation to the RDS Custom DB instances. Configure email notifications from the third-party agent.

D. Write a stored procedure to detect login attempts by unknown users. Schedule a recurring job inside the database engine. Configure Aurora MySQL to use Amazon Simple Notification Service (Amazon SNS) to send email notifications.

▼ 中文:

一名安全工程师必须实施对公司 Amazon Aurora MySQL 数据库实例的监控。公司希望在未知用户尝试登录数据库端点时收到电子邮件通知。

哪种解决方案能够以最低的运营开销满足这些需求？

A. 启用 Amazon GuardDuty。在 GuardDuty 中启用 Amazon RDS Protection 功能，以检测未知用户的登录尝试。创建一个 Amazon EventBridge 规则来过滤 GuardDuty 的发现结果。使用 Amazon Simple Notification Service (Amazon SNS) 发送电子邮件通知。

B. 在 Aurora MySQL 数据库实例上启用 server_audit_logging 参数。使用 AWS Lambda 定期扫描已交付的日志文件，以检测未知用户的登录尝试。使用 Amazon Simple Notification Service (Amazon SNS) 发送电子邮件通知。

C. 创建一个 Amazon RDS Custom AMI。在 AMI 中包含一个第三方安全代理，以检测未知用户的登录尝试。部署 RDS Custom 数据库实例。从现有安装迁移数据到 RDS Custom 数据库实例。通过第三方代理配置电子邮件通知。

D. 编写一个存储过程以检测未知用户的登录尝试。在数据库引擎内部安排一个定期任务。配置 Aurora MySQL 使用 Amazon Simple Notification Service (Amazon SNS) 发送电子邮件通知。

▼ 答案:

A

1. 考察的知识点

Amazon Aurora MySQL 数据库的安全监控。

使用 AWS 服务（如 Amazon GuardDuty、EventBridge、SNS）实现安全事件通知。

选择最少的操作开销（Least Operational Overhead）的解决方案。

2. 选项分析

A. Enable Amazon GuardDuty. Enable the Amazon RDS Protection feature in GuardDuty to detect login attempts by unknown users. Create an Amazon EventBridge rule to filter GuardDuty findings. Send email notifications by using Amazon Simple Notification Service (Amazon SNS).

分析：

Amazon GuardDuty 是一种托管的威胁检测服务，支持 RDS 保护功能，可以检测异常登录行为。

EventBridge 可以过滤 GuardDuty 的发现结果，并触发 SNS 发送通知。

此方案完全托管，操作开销低，符合题目要求。

正确选项。

B. Enable the server_audit_logging parameter on the Aurora MySQL DB instances. Use AWS Lambda to periodically scan the delivered log files for login attempts by unknown users. Send email

notifications by using Amazon Simple Notification Service (Amazon SNS).

分析：

启用server_audit_logging会生成审计日志，但需要额外的Lambda函数来扫描日志。

此方案需要定期运行Lambda函数，增加了操作开销。

不符合“最少操作开销”的要求。

错误选项。

C. Create an Amazon RDS Custom AMI. Include a third-party security agent in the AMI to detect login attempts by unknown users. Deploy RDS Custom DB instances. Migrate data from the existing installation to the RDS Custom DB instances.

Configure email notifications from the third-party agent.

分析：

使用RDS Custom需要创建自定义AMI并迁移数据，操作复杂且开销高。

第三方安全代理的集成增加了管理复杂性。

不符合“最少操作开销”的要求。

错误选项。

D. Write a stored procedure to detect login attempts by unknown users. Schedule a recurring job inside the database engine.

Configure Aurora MySQL to use Amazon Simple Notification Service (Amazon SNS) to send email notifications.

分析：

编写存储过程和安排定期任务需要手动开发和维护，增加了操作开销。

此方案不如托管服务（如GuardDuty）高效。

不符合“最少操作开销”的要求。

错误选项。

▼ 68

▼ 英文:

A company runs a global ecommerce website that is hosted on AWS. The company uses Amazon CloudFront to serve content to its user base. The company wants to block inbound traffic from a specific set of countries to comply with recent data regulation policies.

Which solution will meet these requirements MOST cost-effectively?

A. Create an AWS WAF web ACL with an IP match condition to deny the countries' IP ranges. Associate the web ACL with the CloudFront distribution.

B. Create an AWS WAF web ACL with a geo match condition to deny the specific countries. Associate the web ACL with the CloudFront distribution.

- C. Use the geo restriction feature in CloudFront to deny the specific countries.
- D. Use geolocation headers in CloudFront to deny the specific countries.

▼ 中文:

一家公司运营一个全球电子商务网站，该网站托管在AWS上。该公司使用Amazon CloudFront向其用户群提供内容。为了遵守最近的数据监管政策，该公司希望阻止来自特定国家的一组入站流量。

哪种解决方案将最具成本效益地满足这些要求？

- A. 创建一个AWS WAF web ACL，并使用IP匹配条件拒绝这些国家的IP范围。将web ACL与CloudFront分发关联。
- B. 创建一个AWS WAF web ACL，并使用地理匹配条件拒绝这些特定国家。将web ACL与CloudFront分发关联。
- C. 使用CloudFront中的地理限制功能拒绝这些特定国家。
- D. 使用CloudFront中的地理位置头信息拒绝这些特定国家。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS服务中针对地理位置的访问控制功能，主要涉及Amazon CloudFront和AWS WAF的功能，包括地理限制（Geo Restriction）和地理匹配条件（Geo Match Condition）。
重点在于选择最具成本效益的解决方案来满足特定国家的流量屏蔽需求。

2. 选项分析

A. Create an AWS WAF web ACL with an IP match condition to deny the countries' IP ranges. Associate the web ACL with the CloudFront distribution.

错误：使用IP匹配条件需要手动维护这些国家的IP地址范围，这不仅复杂且容易出错，还可能导致额外的管理成本。

成本效益较低，因为IP地址范围可能频繁变化，维护起来不划算。

B. Create an AWS WAF web ACL with a geo match condition to deny the specific countries. Associate the web ACL with the CloudFront distribution.

正确：AWS WAF的地理匹配条件可以直接基于国家进行屏蔽，配置简单且无需维护IP地址范围。

错误：虽然功能满足需求，但AWS WAF的使用会产生额外的费用，而CloudFront本身已经提供了地理限制功能，使用CloudFront的功能更具成本效益。

C. Use the geo restriction feature in CloudFront to deny the specific countries.

正确：CloudFront的地理限制功能可以直接基于国家屏蔽流量，配置简单且无需额外费用。

这是最具成本效益的解决方案，因为它利用了CloudFront的内置功能，无需额外使用AWS WAF。

D. Use geolocation headers in CloudFront to deny the specific countries.

错误：CloudFront的地理位置头信息可以提供用户的地理位置，但需要额外的逻辑来解析和屏蔽流量。

这种方法需要额外的开发工作和资源，成本效益较低。

▼ 69

▼ 英文:

A company deploys its application as a service on an Amazon Elastic Container Service (Amazon ECS) cluster with the AWS Fargate launch type. A security engineer suspects that some incoming requests are malicious. The security engineer needs to inspect the running container by retrieving log files and memory dump files.

Which solution will meet these requirements with the LEAST operational effort?

A. Migrate the application to an ECS cluster with the Amazon EC2 launch type. Configure the EC2 instances with proper remote access. Log in and inspect the container.

B. Update the application to dump the required data to STDOUT. Use the awslogs log driver to pass the logs to Amazon CloudWatch Logs. Examine the log files in CloudWatch Logs.

C. Turn on Amazon CloudWatch Container Insights for the ECS cluster. Send the log data to Amazon CloudWatch Logs by using AWS Distro for OpenTelemetry. Examine the log data in CloudWatch Logs.

D. Update the ECS task role with AWS Systems Manager permissions. Enable the ECS Exec feature for the ECS service. Use ECS Exec to inspect the container.

▼ 中文:

一家公司将其应用程序作为服务部署在一个 Amazon Elastic Container Service (Amazon ECS) 集群上，使用 AWS Fargate 启动类型。一名安全工程师怀疑一些传入请求是恶意的。安全工程师需要通过检索日志文件和内存转储文件来检查正在运行的容器。

哪种解决方案能够以最少的操作努力满足这些要求？

A. 将应用程序迁移到使用 Amazon EC2 启动类型的 ECS 集群。为 EC2 实例配置适当的远程访问。登录并检查容器。

B. 更新应用程序以将所需数据转储到 STDOUT。使用 awslogs 日志驱动程序将日志传递到 Amazon CloudWatch Logs。在 CloudWatch Logs 中检查日志文件。

C.启用 Amazon CloudWatch Container Insights 用于 ECS 集群。使用 AWS Distro for OpenTelemetry 将日志数据发送到 Amazon CloudWatch Logs。在 CloudWatch Logs 中检查日志数据。

D.使用 AWS Systems Manager 权限更新 ECS 任务角色。启用 ECS 服务的 ECS Exec 功能。使用 ECS Exec 检查容器。

▼ 答案:

D

1. 考察的知识点

Amazon ECS Fargate的运行模式及其限制。

日志和内存转储的收集方法。

AWS Systems Manager权限和ECS Exec功能的使用。

如何以最小的操作成本实现容器的检查和调试。

2. 选项分析

A.

错误原因：将应用程序迁移到EC2启动类型需要额外的操作成本，包括重新配置集群、管理EC2实例以及设置远程访问。这与题目要求的“最小操作成本”不符。

B.

错误原因：虽然可以通过STDOUT将日志传递到CloudWatch Logs，但这需要修改应用程序代码，且无法直接获取内存转储文件，无法满足题目要求。

C.

错误原因：CloudWatch Container Insights主要用于监控容器性能指标，而不是直接用于日志和内存转储的检查。此

外，使用OpenTelemetry需要额外的配置，增加了操作成本。

D.

正确原因：使用ECS Exec功能可以直接登录到运行中的容器进行检查，无需修改应用程序代码或迁移到其他启动类

型。只需更新任务角色权限并启用ECS Exec功能，操作成本最低。

▼ 70

▼ 英文:

A company uses AWS Organizations and has many AWS accounts. The company has a new requirement to use server-side encryption with customer-provided keys (SSE-C) on all new object uploads to Amazon S3 buckets.

A security engineer is creating an SCP that includes a Deny effect for the s3:PutObject action.

Which condition must the security engineer add to the SCP to enforce the new SSE-C requirement?

A


```

    "Condition":{
      "Null":{
A.      "s3:x-amz-server-side-encryption-customer-algorithm": "true"
      }
    }
  }

```

B

```

    "Condition":{
      "StringNotEquals":{
B.      "s3:x-amz-server-side-encryption":"aws:kms"
      }
    }
  }

```

C

```

    "Condition":{
      "StringNotEquals":{
C.      "s3:x-amz-server-side-encryption-customer-algorithm": "AES256"
      }
    }
  }

```

D

```

    "Condition":{
      "Null":{
D.      "s3:x-amz-server-side-encryption": "true"
      }
    }
  }

```

▼ 中文:

一家公司使用 AWS Organizations 并拥有许多 AWS 账户。该公司有一个新的要求，即在所有上传到 Amazon S3 存储桶的新对象上使用客户提供的密钥进行服务器端加密 (SSE-C)。

一名安全工程师正在创建一个 SCP，其中包括对 s3:PutObject 操作的 Deny 效果。安全工程师必须在 SCP 中添加哪个条件以强制执行新的 SSE-C 要求？

A

```

    "Condition":{
      "Null":{
A.      "s3:x-amz-server-side-encryption-customer-algorithm": "true"
      }
    }
  }

```

B

```

    "Condition":{
      "StringNotEquals":{
B.      "s3:x-amz-server-side-encryption":"aws:kms"
      }
    }
  }

```

C

```
    "Condition": {  
      "StringNotEquals": {  
C.      "s3:x-amz-server-side-encryption-customer-algorithm": "AES256"  
    }  
  }  
}
```

D.

```
    "Condition": {  
      "Null": {  
D.      "s3:x-amz-server-side-encryption": "true"  
    }  
  }  
}
```

▼ 答案:

A

1. 考察的知识点

本题考察的是AWS Organizations中的服务控制策略（SCP）的使用，以及如何通过条件语句限制Amazon S3的操作以满足安全要求。

具体涉及S3的服务端加密（SSE-C）和IAM策略条件的使用。

2. 选项分析

A: 正确。此选项包含了一个条件，要求在执行s3:PutObject操作时必须使用SSE-C。这符合题目要求，因为它确保所有新上传的对象都使用客户提供的加密密钥。

B: 错误。此选项可能缺少与SSE-C相关的条件，无法强制要求使用客户提供的加密密钥。

C: 错误。此选项可能包含错误的条件或不完整的限制，无法满足题目要求。

D: 错误。此选项可能与题目要求无关，或者没有正确实现SSE-C的强制要求。

▼ 71

▼ 英文:

A company wants to deny a specific federated user named Bob access to an Amazon S3 bucket named DOC-EXAMPLE-BUCKET.

The company wants to meet this requirement by using a bucket policy. The company also needs to ensure that this bucket policy affects Bob's S3 permissions only. Any other permissions that Bob has must remain intact.

Which policy should the company use to meet these requirements?

A

A.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:federated-user/Bob"},
    "Effect": "Allow",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

B

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:federated-user/Bob"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

C

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:iam::account-id:user/Bob"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

D

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:assumed-role/Bob/role-session-name"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

▼ 中文:

一家公司希望拒绝一个名为 Bob 的特定联合用户访问名为 DOC-EXAMPLE-BUCKET 的 Amazon S3 存储桶。该公司希望通过使用存储桶策略来满足这一要求。公司还需要确保此存储桶策略仅影响 Bob 的 S3 权限。**Bob 拥有的任何其他权限必须保持不变。**

公司应该使用哪项策略来满足这些要求？

A

A.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:federated-user/Bob"},
    "Effect": "Allow",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

B

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:federated-user/Bob"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

C

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:iam::account-id:user/Bob"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

D

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:assumed-role/Bob/role-session-name"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

▼ 答案:

B

题目分析与解答

1. 考察的知识点

Amazon S3 Bucket Policy的使用

如何基于特定用户的身份（如Federated User）设置访问权限

IAM权限与S3 Bucket Policy的交互

2. 选项分析

A: 未提供具体内容，无法判断正确性。

B: 这是最受欢迎的选项，可能包含一个针对特定用户（Bob）的条件语句，**确保仅对Bob的权限进行限制，而不影响其他用户。**

C: 未提供具体内容，无法判断正确性。

D: 未提供具体内容，无法判断正确性。

▼ 72

▼ 英文:

A company runs an online game on AWS. When players sign up for the game, their username and password credentials are stored in an Amazon Aurora database.

The number of users has grown to hundreds of thousands of players. The number of requests for password resets and login assistance has become a burden for the company's customer service team.

The company needs to implement a solution to give players another way to log in to the game. The solution must remove the burden of password resets and login assistance while securely protecting each player's credentials.

Which solution will meet these requirements?

A. When a new player signs up, use an AWS Lambda function to automatically create an IAM access key and a secret access key. Program the Lambda function to store the credentials on the player's device. Create IAM keys for existing players.

B. Migrate the player credentials from the Aurora database to AWS Secrets Manager. When a new player signs up, create a key-value pair in Secrets Manager for the player's user ID and password.

C. Configure Amazon Cognito user pools to federate access to the game with third-party identity providers (IdPs), such as social IdPs. Migrate the game's authentication mechanism to Cognito.

D. Instead of using usernames and passwords for authentication, issue API keys to new and existing players. Create an Amazon API Gateway API to give the game client access to the game's functionality.

▼ 中文:

一家公司在 AWS 上运行一款在线游戏。当玩家注册游戏时，他们的用户名和密码凭证存储在 Amazon Aurora 数据库中。

用户数量已增长到数十万名玩家。密码重置和登录协助请求的数量已经成为公司客户服务团队的负担。

公司需要实施一个解决方案，为玩家提供另一种登录游戏的方式。**该解决方案必须消除密码重置和登录协助的负担，同时安全地保护每位玩家的凭证。**

哪种解决方案可以满足这些需求？

- A.当新玩家注册时，使用 AWS Lambda 函数自动创建 IAM 访问密钥和一个秘密访问密钥。将 Lambda 函数编程为将凭证存储在玩家的设备上。为现有玩家创建 IAM 密钥。
- B.将玩家凭证从 Aurora 数据库迁移到 AWS Secrets Manager。当新玩家注册时，在 Secrets Manager 中为玩家的用户 ID和密码创建一个键值对。
- C.配置 Amazon Cognito 用户池以通过第三方身份提供商 (IdPs)，例如社交 IdPs，联合访问游戏。将游戏的身份验证机制迁移到 Cognito。
- D.不使用用户名和密码进行身份验证，而是向新玩家和现有玩家发放 API 密钥。创建一个 Amazon API Gateway API，以使游戏客户端能够访问游戏的功能。

▼ 答案:

C

题目分析与解答

1. 考察的知识点

Amazon Cognito的功能与使用场景，包括用户池和联合身份认证。
安全性最佳实践，例如避免直接存储或管理用户密码。
如何减轻用户凭证管理的负担，同时确保安全性。

2. 选项分析

A. 使用 AWS Lambda 创建 IAM 密钥并存储在玩家设备上

错误：IAM密钥是为AWS资源访问设计的，不适合用作用户身份认证机制。

错误：将密钥存储在玩家设备上存在安全风险，可能导致密钥泄露。

B. 将玩家凭证迁移到 AWS Secrets Manager

错误：Secrets Manager主要用于存储和管理应用程序的敏感信息（如数据库密码、API密钥），而不是用户身份认证。

错误：此方案仍然需要管理用户密码，无法减轻密码重置的负担。

C. 使用 Amazon Cognito 用户池和第三方身份提供商

正确：Amazon Cognito用户池支持联合身份认证，可以通过第三方身份提供商（如社交登录）简化用户登录流程。

正确：Cognito可以完全替代传统的用户名和密码认证机制，减轻密码管理的负担。

正确：Cognito提供了安全的用户身份管理功能，符合题目要求。

D. 使用 API 密钥进行身份认证

错误：API密钥通常用于应用程序间的通信，而不是用户身份认证。

错误：API密钥的管理和分发可能会带来额外的复杂性，并且无法解决密码重置问题。

▼ 73

▼ 英文:

A company suspects that an attacker has exploited an overly permissive role to export credentials from Amazon EC2 instance metadata. The company uses Amazon GuardDuty and AWS Audit Manager. The company has enabled AWS CloudTrail logging and Amazon CloudWatch logging for all of its AWS accounts. A security engineer must determine if the credentials were used to access the company's resources from an external account. Which solution will provide this information?

- A. Review GuardDuty findings to find InstanceCredentialExfiltration events.
- B. Review assessment reports in the Audit Manager console to find InstanceCredentialExfiltration events.
- C. Review CloudTrail logs for GetSessionToken API calls to AWS Security Token Service (AWS STS) that come from an account ID from outside the company.
- D. Review CloudWatch logs for GetSessionToken API calls to AWS Security Token Service (AWS STS) that come from an account ID from outside the company.

▼ 中文:

一家公司怀疑攻击者利用过于宽松的角色从 Amazon EC2 实例元数据中导出了凭证。该公司使用 Amazon GuardDuty 和 AWS Audit Manager。公司已为其所有 AWS 账户启用了 AWS CloudTrail 日志记录和 Amazon CloudWatch 日志记录。安全工程师必须确定这些凭证是否被用于从外部账户访问公司的资源。哪种解决方案可以提供此信息？

- A. 查看 GuardDuty 发现以找到 InstanceCredentialExfiltration 事件。
- B. 查看 Audit Manager 控制台中的评估报告以找到 InstanceCredentialExfiltration 事件。
- C. 查看 CloudTrail 日志中来自公司外部账户 ID 的对 AWS Security Token Service (AWS STS) 的 GetSessionToken API 调用。
- D. 查看 CloudWatch 日志中来自公司外部账户 ID 的对 AWS Security Token Service (AWS STS) 的 GetSessionToken API 调用。

▼ 答案:

A

1. 考察的知识点

Amazon GuardDuty 的功能，特别是 InstanceCredentialExfiltration 事件的检测。
AWS CloudTrail 和 CloudWatch 日志的使用场景和局限性。
AWS Audit Manager 的功能和用途。
如何检测凭证泄露及外部账户访问的相关技术。

2. 选项分析

A. Review GuardDuty findings to find InstanceCredentialExfiltration events.

正确:Amazon GuardDuty是专门设计用于检测安全威胁的服务，包括凭证泄露事件 (InstanceCredentialExfiltration)。

它可以自动分析数据并生成相关的安全发现。

InstanceCredentialExfiltration事件是GuardDuty的一个特定功能，用于检测凭证被导出并可能被外部账户使用的情况。

B. Review assessment reports in the Audit Manager console to find InstanceCredentialExfiltration events.

错误:AWS Audit Manager主要用于合规性评估和报告，而不是实时检测安全事件。它无法直接检测或报告

InstanceCredentialExfiltration事件。

C. Review CloudTrail logs for GetSessionToken API calls to AWS Security Token Service (AWS STS) that come from an account ID from outside the company.

错误:虽然CloudTrail可以记录API调用，但手动分析日志以检测凭证泄露事件非常耗时且容易遗漏。它无法像

GuardDuty一样提供自动化的安全发现。

D. Review CloudWatch logs for GetSessionToken API calls to AWS Security Token Service (AWS STS) that come from an account ID from outside the company.

错误:CloudWatch主要用于监控和日志分析，但它并不具备自动检测凭证泄露事件的能力。与CloudTrail类似，手动分析日志效率低下。

▼ 74

▼ 英文:

A security engineer needs to run an AWS CloudFormation script. The CloudFormation script builds AWS infrastructure to support a stack that includes web servers and a MySQL database. The stack has been deployed in pre-production environments and is ready for production.

The production script must comply with the principle of least privilege.

Additionally, separation of duties must exist between the security engineer's IAM account and CloudFormation.

Which solution will meet these requirements?

A. Use IAM Access Analyzer policy generation to generate a policy that allows the CloudFormation script to run and manage the stack. Attach the policy to a new IAM role. Modify the security engineer's IAM permissions to be able to pass the new role to CloudFormation.

- B. Create an IAM policy that allows ec2:* and rds:* permissions. Attach the policy to a new IAM role. Modify the securityengineer's IAM permissions to be able to assume the new role.
- C. Use IAM Access Analyzer policy generation to generate a policy that allows the CloudFormation script to run and manage the stack. Modify the security engineer's IAM permissions to be able to run the CloudFormation script.
- D. Create an IAM policy that allows ec2:* and rds:* permissions. Attach the policy to a new IAM role. Use the IAM policy simulator to confirm that the policy allows the AWS API calls that are necessary to build the stack. Modify the security engineer's IAM permissions to be able to pass the new role to CloudFormation.

▼ 中文:

一位安全工程师需要运行一个AWS CloudFormation脚本。该CloudFormation脚本构建AWS基础设施，以支持包含Web服务器和MySQL数据库的堆栈。该堆栈已经在预生产环境中部署，并准备好用于生产环境。

生产脚本必须遵守最小权限原则。此外，安全工程师的IAM账户与CloudFormation之间必须存在职责分离。哪种解决方案可以满足这些要求？

- A.使用IAM Access Analyzer策略生成器生成一个允许CloudFormation脚本运行并管理堆栈的策略。将该策略附加到一个新的IAM角色上。修改安全工程师的IAM权限，使其能够将新角色传递给CloudFormation。
- B.创建一个允许ec2:*和rds:*权限的IAM策略。将该策略附加到一个新的IAM角色上。修改安全工程师的IAM权限，使其能够假设新的角色。
- C.使用IAM Access Analyzer策略生成器生成一个允许CloudFormation脚本运行并管理堆栈的策略。修改安全工程师的IAM权限，使其能够运行CloudFormation脚本。
- D.创建一个允许ec2:*和rds:*权限的IAM策略。将该策略附加到一个新的IAM角色上。使用IAM策略模拟器确认该策略允许构建堆栈所需的AWS API调用。修改安全工程师的IAM权限，使其能够将新角色传递给CloudFormation。

▼ 答案:

A

1. 考察的知识点

IAM角色与权限管理

CloudFormation的权限配置

最小权限原则 (Principle of Least Privilege)

职责分离 (Separation of Duties)

2. 选项分析

A: 使用IAM Access Analyzer生成一个允许CloudFormation脚本运行并管理堆栈的策略，并将该策略附加到一个新的IAM角色。修改安全工程师的IAM权限，使其能够将新角色传递给CloudFormation。

正确：此选项符合最小权限原则，因为IAM Access Analyzer可以生成精确的权限策略，确保只允许必要的操作。

正确：通过创建一个新的IAM角色并将策略附加到该角色，可以实现职责分离，确保安全工程师无法直接操作资源。

正确：修改安全工程师的权限以允许传递角色给CloudFormation，符合安全最佳实践。

B: 创建一个允许ec2:*和rds:*权限的IAM策略，并将该策略附加到一个新的IAM角色。修改安全工程师的IAM权限，使其能够假设新的角色。

错误：ec2:*和rds:*权限过于宽泛，不符合最小权限原则。

错误：没有提到如何验证策略的准确性，也没有使用IAM Access Analyzer来生成精确的权限。

C: 使用IAM Access Analyzer生成一个允许CloudFormation脚本运行并管理堆栈的策略，并修改安全工程师的IAM权限以运行CloudFormation脚本。

错误：直接修改安全工程师的权限以运行CloudFormation脚本，违反了职责分离原则。

正确：使用IAM Access Analyzer生成精确的权限策略符合最小权限原则。

D: 创建一个允许ec2:*和rds:*权限的IAM策略，并将该策略附加到一个新的IAM角色。使用IAM策略模拟器确认策略允许必要的AWS API调用。修改安全工程师的IAM权限，使其能够将新角色传递给CloudFormation。

错误：ec2:*和rds:*权限过于宽泛，不符合最小权限原则。

正确：使用IAM策略模拟器验证策略的准确性是一个良好的实践，但不如IAM Access Analyzer生成精确策略更符合要求。

▼ 75

▼ 英文:

A company that uses AWS Organizations is migrating workloads to AWS. The company's application team determines that the workloads will use Amazon EC2 instances, Amazon S3 buckets, Amazon DynamoDB tables, and Application Load Balancers. For each resource type, the company mandates that deployments must comply with the following requirements:

- All EC2 instances must be launched from approved AWS accounts.
- All DynamoDB tables must be provisioned with a standardized naming convention.
- All infrastructure that is provisioned in any accounts in the organization must be deployed by AWS CloudFormation templates.

Which combination of steps should the application team take to meet these requirements? (Choose two.)

A. Create CloudFormation templates in an administrator AWS account. Share the stack sets with an application AWS account. Restrict the template to be used specifically by the application AWS account.

- B. Create CloudFormation templates in an application AWS account. Share the output with an administrator AWS account to review compliant resources. Restrict output to only the administrator AWS account.
- C. Use permissions boundaries to prevent the application AWS account from provisioning specific resources unless conditions for the internal compliance requirements are met.
- D. Use SCPs to prevent the application AWS account from provisioning specific resources unless conditions for the internal compliance requirements are met.
- E. Activate AWS Config managed rules for each service in the application AWS account.

▼ 中文:

一家使用AWS Organizations的公司正在将工作负载迁移到AWS。公司的应用团队确定这些工作负载将使用Amazon EC2 实例、Amazon S3存储桶、Amazon DynamoDB表和Application Load Balancers。对于每种资源类型，公司要求部署必须符合以下要求：

- 所有EC2实例必须从批准的AWS账户启动。
- 所有DynamoDB表必须遵循标准化的命名约定。
- 组织中任何账户中配置的所有基础设施都必须通过AWS CloudFormation模板部署。

应用团队应该采取哪些步骤来满足这些要求？（选择两个。）

- A.在管理员AWS账户中创建CloudFormation模板。将堆栈集共享给应用AWS账户。限制模板专门用于应用AWS账户。
- B.在应用AWS账户中创建CloudFormation模板。将输出共享给管理员AWS账户以审查合规资源。限制输出仅供管理员AWS账户使用。
- C.用权限边界防止应用AWS账户配置特定资源，除非满足内部合规要求的条件。
- D.用SCPs防止应用AWS账户配置特定资源，除非满足内部合规要求的条件。
- E.在应用AWS账户中激活针对每个服务的AWS Config托管规则。

▼ 答案:

AD

1. 考察的知识点

- AWS Organizations的使用，包括Service Control Policies (SCPs)。
- 权限边界与资源合规性管理。
- AWS CloudFormation StackSets的共享与部署管理。
- AWS Config规则的使用与资源合规性检查。

2. 选项分析

A.

正确。通过在管理员账户中创建CloudFormation模板并使用StackSets共享给应

用账户，可以确保所有资源通过标准化模板进行部署。这符合要求中“所有基础设施必须通过CloudFormation模板部署”的规定。

B.

错误。此选项建议在应用账户中创建模板并将输出共享给管理员账户进行审查，但这并不能确保所有资源通过CloudFormation模板部署，也无法满足组织级别的合规性要求。

C.

错误。权限边界主要用于限制IAM用户或角色的权限，而不是直接限制账户级别的资源部署行为。此选项无法满足题目中提到的组织级别的合规性要求。

D.

正确。SCPs是AWS Organizations的核心功能之一，可以限制成员账户的操作，确保资源部署符合组织的合规性要求。这符合要求中“所有EC2实例必须从批准的账户启动”的规定。

E.

错误。虽然AWS Config可以帮助监控资源的合规性，但它无法直接限制资源的创建或部署行为，因此无法满足题目中提到的强制性要求。

▼ 76

▼ 英文:

A company has a batch-processing system that uses Amazon S3, Amazon EC2, and AWS Key Management Service (AWS KMS). The system uses two AWS accounts: Account A and Account B. Account A hosts an S3 bucket that stores the objects that will be processed. The S3 bucket also stores the results of the processing. All the S3 bucket objects are encrypted by a KMS key that is managed in Account A.

Account B hosts a VPC that has a fleet of EC2 instances that access the S3 bucket in Account A by using statements in the bucket policy. The VPC was created with DNS hostnames enabled and DNS resolution enabled.

A security engineer needs to update the design of the system without changing any of the system's code. No AWS API calls from the batch-processing EC2 instances can travel over the internet.

Which combination of steps will meet these requirements? (Choose two.)

A. In the Account B VPC, create a gateway VPC endpoint for Amazon S3. For the gateway VPC endpoint, create a resource policy that allows the `s3:GetObject`, `s3:ListBucket`, `s3:PutObject`, and `s3:PutObjectAcl` actions for the S3 bucket.

B. In the Account B VPC, create an interface VPC endpoint for Amazon S3. For the interface VPC endpoint, create a resource policy that allows the `s3:GetObject`, `s3:ListBucket`, `s3:PutObject`, and `s3:PutObjectAcl` actions for the S3 bucket.

C. In the Account B VPC, create an interface VPC endpoint for AWS KMS. For the interface VPC endpoint, create a resource policy that allows the kms:Encrypt, kms:Decrypt, and kms:GenerateDataKey actions for the KMS key. Ensure that privateDNS is turned on for the endpoint.

D. In the Account B VPC, create an interface VPC endpoint for AWS KMS. For the interface VPC endpoint, create a resource policy that allows the kms:Encrypt, kms:Decrypt, and kms:GenerateDataKey actions for the KMS key. Ensure that private DNS is turned off for the endpoint.

E. In the Account B VPC, verify that the S3 bucket policy allows the s3:PutObjectAcl action for cross-account use. In the Account B VPC, create a gateway VPC endpoint for Amazon S3. For the gateway VPC endpoint, create a resource policy that allows the s3:GetObject, s3:ListBucket, and s3:PutObject actions for the S3 bucket.

▼ 中文:

一家公司有一个批处理系统，该系统使用 Amazon S3、Amazon EC2 和 AWS Key Management Service (AWS KMS)。该系统使用两个 AWS 账户：账户 A 和账户 B。账户 A 托管一个 S3 存储桶，用于存储将被处理的对象。S3 存储桶还存储处理结果。所有 S3 存储桶对象均由账户 A 中管理的 KMS 密钥加密。账户 B 托管一个 VPC，该 VPC 有一组 EC2 实例通过存储桶策略中的声明访问账户 A 的 S3 存储桶。该 VPC 创建时启用了 DNS 主机名和 DNS 解析功能。

一名安全工程师需要在[不更改系统代码的情况下更新系统设计](#)。批处理 EC2 实例的[任何 AWS API 调用均不得通过互联网传输](#)。

哪种步骤组合可以满足这些要求？（选择两项）

A.在账户 B 的 VPC 中，为 Amazon S3 创建一个网关 VPC 终端节点。对于网关 VPC 终端节点，创建一个资源策略，允许对 S3 存储桶执行 s3:GetObject、s3:ListBucket、s3:PutObject 和 s3:PutObjectAcl 操作。

B.在账户 B 的 VPC 中，为 Amazon S3 创建一个接口 VPC 终端节点。对于接口 VPC 终端节点，创建一个资源策略，允许对 S3 存储桶执行 s3:GetObject、s3:ListBucket、s3:PutObject 和 s3:PutObjectAcl 操作。

C.在账户 B 的 VPC 中，为 AWS KMS 创建一个接口 VPC 终端节点。对于接口 VPC 终端节点，创建一个资源策略，允许对 KMS 密钥执行 kms:Encrypt、kms:Decrypt 和 kms:GenerateDataKey 操作。确保为终端节点启用私有 DNS。

D.在账户 B 的 VPC 中，为 AWS KMS 创建一个接口 VPC 终端节点。对于接口 VPC 终端节点，创建一个资源策略，允许对 KMS 密钥执行 kms:Encrypt、kms:Decrypt 和 kms:GenerateDataKey 操作。确保为终端节点禁用私有 DNS。

E.在账户 B 的 VPC 中，验证 S3 存储桶策略是否允许跨账户使用 s3:PutObjectAcl 操作。在账户 B 的 VPC 中，为 Amazon S3 创建一个网关 VPC 终端节点。对于网关 VPC 终端节点，创建一个资源策略，允许对 S3 存储桶执行 s3:GetObject、s3:ListBucket 和 s3:PutObject 操作。

▼ 答案:

AC

1. 考察的知识点

跨账户访问 Amazon S3 的最佳实践。

使用 VPC 终端节点 (Gateway 和 Interface) 来确保流量不经过互联网。

使用 AWS KMS 进行加密和解密的权限管理。

2. 选项分析

A. 在账户 B 的 VPC 中，为 Amazon S3 创建一个网关 VPC 终端节点。对于网关 VPC 终端节点，创建一个资源策略，允许对 S3 存储桶执行 s3:GetObject、s3:ListBucket、s3:PutObject 和 s3:PutObjectAcl 操作。

正确：网关 VPC 终端节点是专门为 Amazon S3 和 DynamoDB 设计的，可以确保流量不经过互联网。

正确：资源策略允许所需的 S3 操作 (s3:GetObject、s3:ListBucket、s3:PutObject 和 s3:PutObjectAcl)，满足跨账户访问的需求。

B. 在账户 B 的 VPC 中，为 Amazon S3 创建一个接口 VPC 终端节点。对于接口 VPC 终端节点，创建一个资源策略，允许对 S3 存储桶执行 s3:GetObject、s3:ListBucket、s3:PutObject 和 s3:PutObjectAcl 操作。

错误：Amazon S3 不支持接口 VPC 终端节点，只支持网关 VPC 终端节点。

C. 在账户 B 的 VPC 中，为 AWS KMS 创建一个接口 VPC 终端节点。对于接口 VPC 终端节点，创建一个资源策略，允许对 KMS 密钥执行 kms:Encrypt、kms:Decrypt 和 kms:GenerateDataKey 操作。确保为终端节点启用私有 DNS。

正确：AWS KMS 支持接口 VPC 终端节点，可以确保流量不经过互联网。

正确：资源策略允许所需的 KMS 操作 (kms:Encrypt、kms:Decrypt 和 kms:GenerateDataKey)，满足加密和解密的需求。

正确：启用私有 DNS 确保通过私有网络解析 KMS 的域名。

D. 在账户 B 的 VPC 中，为 AWS KMS 创建一个接口 VPC 终端节点。对于接口 VPC 终端节点，创建一个资源策略，允许对 KMS 密钥执行 kms:Encrypt、kms:Decrypt 和 kms:GenerateDataKey 操作。确保为终端节点禁用私有 DNS。

错误：禁用私有 DNS 会导致无法通过私有网络解析 KMS 的域名，违背题目要求。

E. 在账户 B 的 VPC 中，验证 S3 存储桶策略是否允许跨账户使用 s3:PutObjectAcl 操作。在账户 B 的 VPC 中，为 Amazon S3 创建一个网关 VPC 终端节点。对于网关 VPC 终端节点，创建一个资源策略，允许对 S3 存储桶执行 s3:GetObject、s3:ListBucket 和 s3:PutObject 操作。

错误：虽然网关 VPC 终端节点是正确的，但题目没有要求验证 S3 存储桶策略的 s3:PutObjectAcl 操作。

▼ 77

▼ 英文:

A security engineer is designing an IAM policy for a script that will use the AWS CLI. The script currently assumes an IAM role that is attached to three AWS

managed IAM policies: AmazonEC2FullAccess, AmazonDynamoDBFullAccess, and AmazonVPCFullAccess.

The security engineer needs to construct a least privilege IAM policy that will replace the AWS managed IAM policies that are attached to this role.

Which solution will meet these requirements in the MOST operationally efficient way?

A. In AWS CloudTrail, create a trail for management events. Run the script with the existing AWS managed IAM policies. Use IAM Access Analyzer to generate a new IAM policy that is based on access activity in the trail. Replace the existing AWS managed IAM policies with the generated IAM policy for the role.

B. Remove the existing AWS managed IAM policies from the role. Attach the IAM Access Analyzer Role Policy Generator to the role. Run the script. Return to IAM Access Analyzer and generate a least privilege IAM policy. Attach the new IAM policy to the role.

C. Create an account analyzer in IAM Access Analyzer. Create an archive rule that has a filter that checks whether the PrincipalArn value matches the ARN of the role. Run the script. Remove the existing AWS managed IAM policies from the role.

D. In AWS CloudTrail, create a trail for management events. Remove the existing AWS managed IAM policies from the role.

Run the script. Find the authorization failure in the trail event that is associated with the script. Create a new IAM policy that includes the action and resource that caused the authorization failure. Repeat the process until the script succeeds.

Attach the new IAM policy to the role.

▼ 中文:

一位安全工程师正在为一个将使用AWS CLI的脚本设计IAM策略。该脚本目前假设一个IAM角色，该角色附加了三个AWS 托管IAM策略：

AmazonEC2FullAccess、AmazonDynamoDBFullAccess和AmazonVPCFullAccess。

安全工程师需要构建一个最小权限的IAM策略，以替换附加到该角色的AWS托管IAM策略。

哪种解决方案能够以**最具操作效率的方式满足这些要求**？

A.在AWS CloudTrail中，为管理事件创建一个跟踪。使用现有的AWS托管IAM策略运行脚本。使用IAM Access Analyzer生成一个基于跟踪中的访问活动的新IAM策略。将生成的IAM策略替换现有的AWS托管IAM策略以用于该角色。

B.从角色中移除现有的AWS托管IAM策略。将IAM Access Analyzer Role Policy Generator附加到角色。运行脚本。返回IAM Access Analyzer并生成一个最小权限的IAM策略。将新的IAM策略附加到角色。

C.在IAM Access Analyzer中创建一个账户分析器。创建一个归档规则，该规则具有一个过滤器，用于检查PrincipalArn值是否与角色的ARN匹配。运行脚本。从角色中移除现有的AWS托管IAM策略。

D.在AWS CloudTrail中，为管理事件创建一个跟踪。从角色中移除现有的AWS托管IAM策略。运行脚本。找到与脚本相关的跟踪事件中的授权失败。创建一个包含导致授权失败的操作和资源的新IAM策略。重复该过程直到脚本成功。将新的IAM策略附加到角色。

▼ 答案:

A

1. 考察的知识点

IAM策略的设计与优化

最小权限原则 (Least Privilege Principle)

使用IAM Access Analyzer和AWS CloudTrail进行权限分析

2. 选项分析

A:

正确。此选项使用AWS CloudTrail记录管理事件，并结合IAM Access Analyzer生成基于实际访问活动的最小权限IAM策略。这种方法高效且符合最小权限原则。

B:

错误。IAM Access Analyzer Role Policy Generator并不是一个实际存在的工具或功能。此选项描述的操作不符合AWS的实际功能。

C:

错误。创建账户分析器和归档规则并不能直接生成最小权限策略，也没有提到如何基于实际访问活动生成策略。这种方法不符合题目要求。

D:

错误。此选项描述的过程效率低下，需要多次运行脚本并手动分析授权失败事件，逐步构建IAM策略。这种方法不符合“最具操作效率”的要求。

▼ 78

▼ 英文:

A security engineer is designing a cloud architecture to support an application. The application runs on Amazon EC2 instances and processes sensitive information, including credit card numbers.

The application will send the credit card numbers to a component that is running in an isolated environment. The component will encrypt, store, and decrypt the numbers. The component then will issue tokens to replace the numbers in other parts of the application.

The component of the application that manages the tokenization process will be deployed on a separate set of EC2 instances.

Other components of the application must not be able to store or access the credit card numbers. Which solution will meet these requirements?

- A. Use EC2 Dedicated Instances for the tokenization component of the application.
- B. Place the EC2 instances that manage the tokenization process into a partition placement group.
- C. Create a separate VPC and deploy new EC2 instances into the separate VPC to support the data tokenization.
- D. Deploy the tokenization code onto AWS Nitro Enclaves that are hosted on EC2 instances.

▼ 中文:

一位安全工程师正在设计一个云架构以支持一个应用程序。该应用程序运行在Amazon EC2实例上，并处理敏感信息，包括信用卡号码。

该应用程序将把信用卡号码发送到一个运行在隔离环境中的组件。该组件将对号码进行加密、存储和解密。然后，该组件将发出令牌以在应用程序的其他部分替换这些号码。

管理令牌化过程的应用程序组件将部署在另一组EC2实例上。**应用程序的其他组件不得存储或访问信用卡号码。**

哪种解决方案可以满足这些需求？

- A. 为应用程序的令牌化组件使用EC2 Dedicated Instances。
- B. 将管理令牌化过程的EC2实例放入一个分区放置组（partition placement group）。
- C. 创建一个单独的VPC，在单独的VPC中部署新的EC2实例以支持数据令牌化。
- D. 将令牌化代码部署到托管在EC2实例上的AWS Nitro Enclaves中。

▼ 答案:

D

1. 考察的知识点

数据保护与加密：如何保护敏感数据（如信用卡号）并确保其安全存储和处理。

隔离与安全性：如何设计隔离环境以确保敏感数据不被其他组件访问。

AWS Nitro Enclaves：**用于创建高度隔离的计算环境以保护敏感数据。**

2. 选项分析

A. Use EC2 Dedicated Instances for the tokenization component of the application.

错误：EC2 Dedicated Instances提供物理隔离，但它们并不提供额外的逻辑隔离或加密功能。无法确保其他组件无法访问敏感数据。

B. Place the EC2 instances that manage the tokenization process into a partition placement group.

错误：Partition placement groups用于分布实例以减少硬件故障的影响，与数据

隔离或安全性无关。

C. Create a separate VPC. Deploy new EC2 instances into the separate VPC to support the data tokenization.

错误：虽然单独的VPC可以提供网络隔离，但它无法确保其他组件无法访问敏感数据，也无法提供加密和安全存储功能。

D. Deploy the tokenization code onto AWS Nitro Enclaves that are hosted on EC2 instances.

正确：AWS Nitro Enclaves提供高度隔离的计算环境，专门设计用于处理敏感数据。它们支持加密、存储和解密操作，并确保其他组件无法访问敏感数据。

▼ 79

▼ 英文:

A company has two AWS accounts: Account A and Account B. Account A has an IAM role that IAM users in Account B assume when they need to upload sensitive documents to Amazon S3 buckets in Account A.

A new requirement mandates that users can assume the role only if they are authenticated with multi-factor authentication (MFA). A security engineer must recommend a solution that meets this requirement with minimum risk and effort.

Which solution should the security engineer recommend?

- A. Add an `aws:MultiFactorAuthPresent` condition to the role's permissions policy.
- B. Add an `aws:MultiFactorAuthPresent` condition to the role's trust policy.
- C. Add an `aws:MultiFactorAuthPresent` condition to the session policy.
- D. Add an `aws:MultiFactorAuthPresent` condition to the S3 bucket policies.

▼ 中文:

一家公司有两个AWS账户：账户A和账户B。账户A有一个IAM角色，当账户B中的IAM用户需要将敏感文档上传到账户A的Amazon S3桶时，他们会假设该角色。

一个新的要求规定，用户只有在通过多因素认证（MFA）进行身份验证后才能假设该角色。安全工程师必须推荐一个解决方案，以最低的风险和努力满足此要求。

安全工程师应该推荐哪种解决方案？

- A.在角色的权限策略中添加一个`aws:MultiFactorAuthPresent`条件。
- B.在角色的信任策略中添加一个`aws:MultiFactorAuthPresent`条件。
- C.在会话策略中添加一个`aws:MultiFactorAuthPresent`条件。
- D.在S3桶策略中添加一个`aws:MultiFactorAuthPresent`条件。

▼ 答案:

B

1. 考察的知识点

IAM角色的信任策略和权限策略的区别。

如何使用条件语句（Condition）限制角色的使用，例如基于MFA认证。

跨账户访问的安全配置。

2. 选项分析

A. Add an `aws:MultiFactorAuthPresent` condition to the role's permissions policy.

错误：权限策略用于定义角色可以执行的操作，但无法限制谁可以假设该角色。

MFA认证的限制需要在信任策略中定义，而不是权限策略。

B. Add an `aws:MultiFactorAuthPresent` condition to the role's trust policy.

正确：信任策略定义了谁可以假设角色以及在什么条件下可以假设角色。通过在信任策略中添加`aws:MultiFactorAuthPresent`条件，可以确保只有通过MFA认证的用户才能假设该角色。

C. Add an `aws:MultiFactorAuthPresent` condition to the session policy.

错误：会话策略用于进一步限制角色的权限，而不是限制谁可以假设角色。MFA认证的限制无法通过会话策略实现。

D. Add an `aws:MultiFactorAuthPresent` condition to the S3 bucket policies.

错误：S3桶策略用于控制对桶的访问权限，而不是限制谁可以假设IAM角色。

MFA认证的限制需要在角色的信任策略中定义，而不是桶策略中。

▼ 80

▼ 英文:

A company wants to receive automated email notifications when AWS access keys from developer AWS accounts are detected on code repository sites.

Which solution will provide the required email notifications?

A. Create an Amazon EventBridge rule to send Amazon Simple Notification Service (Amazon SNS) email notifications for Amazon GuardDuty `UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.OutsideAWS` findings.

B. Change the AWS account contact information for the Operations type to a separate email address. Periodically poll this email address for notifications.

C. Create an Amazon EventBridge rule that reacts to AWS Health events that have a value of Risk for the service category. Configure email notifications by using Amazon Simple Notification Service (Amazon SNS).

D. Implement new anomaly detection software. Ingest AWS CloudTrail logs. Configure monitoring for `ConsoleLogin` events in the AWS Management Console. Configure email notifications from the anomaly detection software.

▼ 中文:

一家公司希望在开发人员的AWS账户访问密钥被检测到上传到代码库网站时，接收自动电子邮件通知。哪种解决方案可以提供所需的电子邮件通知？

- A. 创建一个Amazon EventBridge规则，用于发送Amazon Simple Notification Service (Amazon SNS)电子邮件通知，针对Amazon GuardDuty UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.OutsideAWS的发现。
- B. 将AWS账户的操作类型联系信息更改为一个单独的电子邮件地址。定期轮询此电子邮件地址以获取通知。
- C. 创建一个Amazon EventBridge规则，响应服务类别中具有Risk值的AWS Health事件。通过使用Amazon Simple Notification Service (Amazon SNS)配置电子邮件通知。
- D. 实施新的异常检测软件。摄取AWS CloudTrail日志。配置对AWS Management Console中的ConsoleLogin事件的监控。从异常检测软件中配置电子邮件通知。

▼ 答案:

A

1. 考察的知识点

Amazon GuardDuty的功能和用途，特别是检测IAM用户凭证泄露的能力。
Amazon EventBridge规则的配置和与Amazon SNS集成的能力。
如何实现自动化的安全事件通知。

2. 选项分析

A.

正确：Amazon GuardDuty可以检测IAM用户凭证泄露的情况，并生成相关的安全发现（例如UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.OutsideAWS）。
正确：Amazon EventBridge可以监听GuardDuty的发现事件，并触发Amazon SNS发送电子邮件通知。此选项完全符合题目要求。

B.

错误：更改账户联系信息并轮询电子邮件地址无法实现自动化通知，且与题目要求的“检测开发者账户访问密钥泄露”无关。
此选项不涉及GuardDuty或EventBridge，无法满足题目需求。

C.

错误：AWS Health事件主要用于报告账户级别的服务健康状况，与检测访问密钥泄露无关。此选项未提及GuardDuty或相关的安全发现，无法满足题目需求。

D.

错误：此选项提到的异常检测软件和CloudTrail日志分析是一个复杂的解决方案，但题目要求的是针对访问密钥泄露的自动化通知。
此选项未提及GuardDuty或EventBridge，且实现起来复杂度较高，不符合题目需求。

▼ 81

▼ 英文:

A company deployed an Amazon EC2 instance to a VPC on AWS. A recent alert indicates that the EC2 instance is receiving a suspicious number of requests over an open TCP port from an external source. The TCP port remains open for long periods of time.

The company's security team needs to stop all activity to this port from the external source to ensure that the EC2 instance is not being compromised. The application must remain available to other users. Which solution will meet these requirements?

- A. Update the network ACL that is attached to the subnet that is associated with the EC2 instance. Add a Deny statement for the port and the source IP addresses.
- B. Update the elastic network interface security group that is attached to the EC2 instance to remove the port from the inbound rule list.
- C. Update the elastic network interface security group that is attached to the EC2 instance by adding a Deny entry in the inbound list for the port and the source IP addresses.
- D. Create a new network ACL for the subnet. Deny all traffic from the EC2 instance to prevent data from being removed

▼ 中文:

一家公司在AWS上的VPC中部署了一台Amazon EC2实例。最近的警报表明，该EC2实例正在通过一个开放的TCP端口接收到来自外部来源的大量可疑请求。该TCP端口长时间保持开放状态。

公司的安全团队需要阻止来自外部来源对此端口的所有活动，以确保EC2实例不会被入侵。应用程序必须对其他用户保持可用。

哪种解决方案可以满足这些要求？

- A.更新附加到与EC2实例关联的子网的网络ACL。为该端口和源IP地址添加一个Deny语句。
- B.更新附加到EC2实例的弹性网络接口安全组，从入站规则列表中移除该端口。
- C.更新附加到EC2实例的弹性网络接口安全组，通过在入站列表中添加一个Deny条目来针对该端口和源IP地址。
- D.为子网创建一个新的网络ACL。拒绝所有来自EC2实例的流量，以防止数据被移除。

▼ 答案:

A

考察的知识点

本题考察的是AWS网络安全相关知识，特别是网络ACL（Access Control List）和安全组的使用与区别。

网络ACL是子网级别的防火墙，可以设置显式的“Deny”规则，而安全组是实例级别的防火墙，不支持显式的“Deny”规则。

2. 选项分析

A.

正确：网络ACL可以显式地添加“Deny”规则，阻止特定端口和源IP地址的流量。这是解决问题的最佳方法，因为它可以精确地阻止恶意流量，同时允许其他流量正常通过。

B.

错误：移除端口会阻止所有流量，而不仅仅是来自恶意源的流量。这不符合题目要求，因为应用需要保持对其他用户的可用性。

C.

错误：安全组不支持显式的“Deny”规则，只能通过允许规则来控制流量。因此，这个选项在技术上不可行。

D.

错误：拒绝所有流量会导致应用不可用，这与题目要求的“应用必须保持可用性”相矛盾。

▼ 82

▼ 英文:

A company has secured the AWS account root user for its AWS account by following AWS best practices. The company also has enabled AWS CloudTrail, which is sending its logs to Amazon S3. A security engineer wants to receive notification in near-real time if a user uses the AWS account root user credentials to sign in to the AWS Management Console. Which solutions will provide this notification? (Choose two.)

A. Use AWS Trusted Advisor and its security evaluations for the root account. Configure an Amazon EventBridge event rule that is invoked by the Trusted Advisor API. Configure the rule to target an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe any required endpoints to the SNS topic so that these endpoints can receive notification.

B. Use AWS IAM Access Analyzer. Create an Amazon CloudWatch Logs metric filter to evaluate log entries from Access Analyzer that detect a successful root account login. Create an Amazon CloudWatch alarm that monitors whether a root login has occurred. Configure the CloudWatch alarm to notify an Amazon Simple Notification Service (Amazon SNS) topic when the alarm enters the ALARM state. Subscribe any required endpoints to this SNS topic so that these endpoints can receive notification.

C. Configure AWS CloudTrail to send its logs to Amazon CloudWatch Logs. Configure a metric filter on the CloudWatch Logs log group used by CloudTrail to evaluate log entries for successful root account logins. Create an Amazon CloudWatch alarm that monitors whether a root login has occurred. Configure the CloudWatch alarm to notify an Amazon Simple Notification Service (Amazon SNS) topic when the alarm enters the ALARM state. Subscribe any required endpoints

to this SNS topic so that these endpoints can receive notification.

D. Configure AWS CloudTrail to send log notifications to an Amazon Simple Notification Service (Amazon SNS) topic. Create an AWS Lambda function that parses the CloudTrail notification for root login activity and notifies a separate SNS topic that contains the endpoints that should receive notification. Subscribe the Lambda function to the SNS topic that is receiving log notifications from CloudTrail.

E. Configure an Amazon EventBridge event rule that runs when Amazon CloudWatch API calls are recorded for a successful root login. Configure the rule to target an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe any required endpoints to the SNS topic so that these endpoints can receive notification.

▼ 中文:

一家公司通过遵循AWS最佳实践保护了其AWS账户的根用户。该公司还启用了AWS CloudTrail，并将其日志发送到Amazon S3。安全工程师希望在用户使用AWS账户根用户凭证登录AWS管理控制台时，能够[接收到近实时的通知](#)。

哪些解决方案可以提供此通知？（选择两个）

A.使用AWS Trusted Advisor及其针对根账户的安全评估。配置一个由Trusted Advisor API触发的Amazon EventBridge事件规则。将规则配置为以Amazon Simple Notification Service（Amazon SNS）主题为目标。订阅任何需要的终端到该SNS主题，以便这些终端可以接收通知。

B.使用AWS IAM Access Analyzer。创建一个Amazon CloudWatch Logs指标过滤器，用于评估Access Analyzer日志条目以检测成功的根账户登录。创建一个Amazon CloudWatch警报，用于监控是否发生了根账户登录。将CloudWatch警报配置为在警报进入ALARM状态时通知一个Amazon Simple Notification Service（Amazon SNS）主题。订阅任何需要的终端到该SNS主题，以便这些终端可以接收通知。

C.配置AWS CloudTrail将其日志发送到Amazon CloudWatch Logs。为CloudTrail使用的CloudWatch Logs日志组配置一个指标过滤器，以评估成功的根账户登录的日志条目。创建一个Amazon CloudWatch警报，用于监控是否发生了根账户登录。将CloudWatch警报配置为在警报进入ALARM状态时通知一个Amazon Simple Notification Service（Amazon SNS）主题。订阅任何需要的终端到该SNS主题，以便这些终端可以接收通知。

D.配置AWS CloudTrail将日志通知发送到一个Amazon Simple Notification Service (Amazon SNS) 主题。创建一个AWS Lambda函数，用于解析CloudTrail通知中的根账户登录活动，并通知一个包含应接收通知的终端的单独SNS主题。

将Lambda函数订阅到接收CloudTrail日志通知的SNS主题。

E.配置一个Amazon EventBridge事件规则，当记录了成功的根账户登录的Amazon CloudWatch API调用时运行。将规则配置为以Amazon Simple Notification Service (Amazon SNS) 主题为目标。订阅任何需要的终端到该SNS主题，以便这些终端可以接收通知。

▼ 答案:

CE

1. 考察的知识点

如何监控和检测AWS账户根用户的登录活动。

使用AWS服务（如CloudTrail、CloudWatch Logs、SNS、EventBridge等）实现实时通知。

理解AWS最佳实践和服务集成。

2. 选项分析

A. 使用AWS Trusted Advisor及其针对根账户的安全评估。

错误：AWS Trusted Advisor主要用于提供账户安全建议，但它无法实时检测或通知根用户登录活动。

Trusted Advisor的API无法直接触发事件规则来检测登录行为。

B. 使用AWS IAM Access Analyzer。

错误：IAM Access Analyzer用于分析权限和访问风险，而不是监控登录活动。Access Analyzer无法生成与根用户登录相关的日志条目，因此无法实现所需的功能。

C. 配置AWS CloudTrail将其日志发送到Amazon CloudWatch Logs。

正确：CloudTrail可以记录根用户登录活动，并将日志发送到CloudWatch Logs。

通过配置CloudWatch Logs的指标过滤器，可以检测成功的根用户登录事件。

创建CloudWatch警报并通过SNS发送通知是实现实时通知的有效方法。

D. 配置AWS CloudTrail将日志通知发送到一个Amazon SNS主题。

错误：CloudTrail无法直接将日志通知发送到SNS主题。需要通过其他服务（如CloudWatch Logs或Lambda）处理日志。

虽然可以使用Lambda解析日志，但这种方法复杂且不符合题目要求的最佳实践。

E. 配置一个Amazon EventBridge事件规则。

正确：EventBridge可以捕获CloudTrail事件（如根用户登录活动），并触发SNS通知。

这种方法直接且高效，符合题目要求的实时通知需求。

▼ 83

▼ 英文:

A company has AWS accounts that are in an organization in AWS Organizations. A security engineer needs to set up AWS Security Hub in a dedicated account for security monitoring.

The security engineer must ensure that Security Hub automatically manages all existing accounts and all new accounts that are added to the organization.

Security Hub also must receive findings from all AWS Regions.

Which combination of actions will meet these requirements with the LEAST operational overhead? (Choose two.)

A. Configure a finding aggregation Region for Security Hub. Link the other Regions to the aggregation Region.

B. Create an AWS Lambda function that routes events from other Regions to the dedicated Security Hub account. Create an Amazon EventBridge rule to invoke the Lambda function.

C. Turn on the option to automatically enable accounts for Security Hub.

D. Create an SCP that denies the securityhub:DisableSecurityHub permission. Attach the SCP to the organization's root account.

E. Configure services in other Regions to write events to an AWS CloudTrail organization trail. Configure Security Hub to read events from the trail.

▼ 中文:

一家公司拥有多个 AWS 账户，这些账户属于 AWS Organizations 中的一个组织。某位安全工程师需要在一个专用账户中设置 AWS Security Hub，用于安全监控。

安全工程师必须确保 Security Hub 自动管理所有现有账户以及添加到组织中的所有新账户。Security Hub 还必须接收来自所有 AWS 区域的发现结果。

以下哪种操作组合可以以最少的运营开销满足这些要求？（选择两个）

A. 为 Security Hub 配置一个发现结果聚合区域。将其他区域链接到聚合区域。

B. 创建一个 AWS Lambda 函数，将来自其他区域的事件路由到专用的 Security Hub 账户。创建一个 Amazon EventBridge 规则以调用该 Lambda 函数。

C. 启用自动为 Security Hub 启用账户的选项。

D. 创建一个 SCP，拒绝 securityhub:DisableSecurityHub 权限。将 SCP 附加到组织的根账户。

E. 配置其他区域的服务将事件写入 AWS CloudTrail 组织跟踪。配置 Security Hub 从跟踪中读取事件。

▼ 答案:

AC

1. 考察的知识点

AWS Security Hub的跨账户和跨区域配置。

如何自动管理AWS Organizations中的账户。
如何实现安全事件的集中管理和低运营开销。

2. 选项分析

A. Configure a finding aggregation Region for Security Hub. Link the other Regions to the aggregation Region.

正确：Security Hub支持配置一个发现结果聚合区域（Finding Aggregation Region），将其他区域的发现结果集中到一个区域进行管理。这是推荐的最佳实践之一。

此选项可以帮助实现跨区域的集中管理，减少运营开销。

B. Create an AWS Lambda function that routes events from other Regions to the dedicated Security Hub account. Create an Amazon EventBridge rule to invoke the Lambda function.

错误：虽然可以通过Lambda函数和EventBridge规则实现事件路由，但这种方法需要额外的开发和维护工作，增加了运营开销，不符合“LEAST operational overhead”的要求。

C. Turn on the option to automatically enable accounts for Security Hub.

正确：Security Hub提供了一个选项，可以自动为AWS Organizations中的所有现有账户和新账户启用Security Hub。这是实现跨账户管理的推荐方法，且运营开销最低。

D. Create an SCP that denies the securityhub:DisableSecurityHub permission. Attach the SCP to the organization's root account.

错误：虽然SCP可以限制某些操作，但此选项并不能直接实现题目要求的自动管理和跨区域发现结果聚合。

E. Configure services in other Regions to write events to an AWS CloudTrail organization trail. Configure Security Hub to read events from the trail.

错误：Security Hub不直接依赖CloudTrail组织跟踪来读取事件。此选项与题目要求的功能不完全匹配。

▼ 84

▼ 英文:

A security engineer is implementing a solution to allow users to seamlessly encrypt Amazon S3 objects without having to touch the keys directly. The solution must be highly scalable without requiring continual management. Additionally, the organization must be able to immediately delete the encryption keys.

Which solution meets these requirements?

A. Use AWS KMS with AWS managed keys and the ScheduleKeyDeletion API with a PendingWindowInDays set to 0 to remove the keys if necessary.

B. Use KMS with AWS imported key material and then use the DeleteImportedKeyMaterial API to remove the key material if necessary.

C. Use AWS CloudHSM to store the keys and then use the CloudHSM API or the PKCS11 library to delete the keys if necessary.

D. Use the Systems Manager Parameter Store to store the keys and then use the service API operations to delete the keys if necessary.

▼ 中文:

一位安全工程师正在实施一个解决方案，以允许用户无缝加密 Amazon S3 对象，而无需直接接触密钥。该解决方案必须具有高度的可扩展性，并且不需要持续管理。此外，组织必须能够立即删除加密密钥。

满足这些要求的解决方案是什么？

A.使用 AWS KMS 和 AWS managed keys，并使用 ScheduleKeyDeletion API，将 PendingWindowInDays 设置为 0 来删除密钥（如果需要）。

B.使用 KMS 和 AWS imported key material，然后使用 DeleteImportedKeyMaterial API 删除密钥材料（如果需要）。

C.使用 AWS CloudHSM 存储密钥，然后使用 CloudHSM API 或 PKCS11 库删除密钥（如果需要）。

D.使用 Systems Manager Parameter Store 存储密钥，然后使用服务 API 操作删除密钥（如果需要）。

▼ 答案:

B

1. 考察的知识点

Amazon S3对象加密的实现方式。

AWS KMS（Key Management Service）的功能，包括密钥管理和删除。

如何使用AWS服务实现高可扩展性和密钥的即时删除。

2. 选项分析

A.

错误：AWS KMS的ScheduleKeyDeletion API不支持将PendingWindowInDays 设置为0。最短的等待时间是7天，因此无法实现“立即删除密钥”的要求。

B.

正确：使用AWS KMS的导入密钥材料（imported key material）可以实现即时删除。DeleteImportedKeyMaterial API允许立即删除导入的密钥材料，符合题目要求。

C.

错误：虽然AWS CloudHSM可以存储密钥并支持删除，但它需要用户进行更多的管理工作，且复杂性较高，不符合题目中“无需持续管理”的要求。

D.

错误：Systems Manager Parameter Store主要用于存储参数和配置数据，而不是专门设计用于加密密钥管理。它不支持与Amazon S3对象加密的无缝集成。

▼ 英文:

A company needs to implement DNS Security Extensions (DNSSEC) for a specific subdomain. The subdomain is already registered with Amazon Route 53. A security engineer has enabled DNSSEC signing and has created a key-signing key (KSK).

When the security engineer tries to test the configuration, the security engineer receives an error for a broken trust chain.

What should the security engineer do to resolve this error?

- A. Replace the KSK with a zone-signing key (ZSK).
- B. Deactivate and then activate the KSK.
- C. Create a Delegation Signer (DS) record in the parent hosted zone.
- D. Create a Delegation Signer (DS) record in the subdomain.

▼ 中文:

一家公司需要为特定子域实施DNS安全扩展（DNSSEC）。该子域已经通过Amazon Route 53注册。一名安全工程师已启用DNSSEC签名并创建了密钥签名密钥（KSK）。当安全工程师尝试测试配置时，收到一个信任链断裂的错误。

安全工程师应该怎么做来解决这个错误？

- A. 区域签名密钥（ZSK）替换KSK。
- B. 停用然后重新激活KSK。
- C. 在父托管区域中创建一个委派签名者（DS）记录。
- D. 在子域中创建一个委派签名者（DS）记录。

▼ 答案:

C

1. 考察的知识点

本题考察的是DNS Security Extensions (DNSSEC) 的配置与故障排除，特别是如何正确配置信任链以确保DNSSEC的工作。

涉及的关键概念包括：Key-Signing Key (KSK)、Zone-Signing Key (ZSK)、以及Delegation Signer (DS) 记录。

2. 选项分析

A. Replace the KSK with a zone-signing key (ZSK).

错误：KSK和ZSK是两种不同的密钥，分别用于不同的目的。KSK用于签署DS记录，而ZSK用于签署区域数据。替换KSK为ZSK不会解决信任链问题。

B. Deactivate and then activate the KSK.

错误：停用并重新激活KSK不会解决信任链问题，因为问题的根本原因是缺少DS记录，而不是KSK的状态。

C. Create a Delegation Signer (DS) record in the parent hosted zone.

正确：DS记录是用于在父域中建立信任链的关键部分。没有DS记录，父域无法验证子域的DNSSEC签名，从而导致信任链断裂。

D. Create a Delegation Signer (DS) record in the subdomain.

错误：DS记录需要创建在父域中，而不是子域中。子域本身不需要DS记录来建立信任链。

▼ 86

▼ 英文:

A company used AWS Organizations to set up an environment with multiple AWS accounts. The company's organization currently has two AWS accounts, and the company expects to add more than 50 AWS accounts during the next 12 months. The company will require all existing and future AWS accounts to use Amazon GuardDuty. Each existing AWS account has GuardDuty active. The company reviews GuardDuty findings by logging into each AWS account individually.

The company wants a centralized view of the GuardDuty findings for the existing AWS accounts and any future AWS accounts. The company also must ensure that any new AWS account has GuardDuty automatically turned on. Which solution will meet these requirements?

A. Enable AWS Security Hub in the organization's management account.

Configure GuardDuty within the management account to send all GuardDuty findings to Security Hub.

B. Create a new AWS account in the organization. Enable GuardDuty in the new account. Designate the new account as the delegated administrator account for GuardDuty. Configure GuardDuty to add existing accounts as member accounts. Select

the option to automatically add new AWS accounts to the organization.

C. Create a new AWS account in the organization. Enable GuardDuty in the new account. Enable AWS Security Hub in each account. Select the option to automatically add new AWS accounts to the organization.

D. Enable AWS Security Hub in the organization's management account.

Designate the management account as the delegated administrator account for Security Hub. Add existing accounts as member accounts. Select the option to automatically add new AWS accounts to the organization. Send all Security Hub findings to the organization's GuardDuty account.

▼ 中文:

一家公司使用 AWS Organizations 设置了一个包含多个 AWS 账户的环境。该公司的组织目前有两个 AWS 账户，并预计在接下来的 12 个月内新增超过 50 个 AWS 账户。公司要求所有现有和未来的 AWS 账户都启用 Amazon GuardDuty。每个现有的

AWS 账户都已启用 GuardDuty。公司通过单独登录每个 AWS 账户来查看 GuardDuty 的发现结果。

公司希望对现有 AWS 账户和任何未来的 AWS 账户的 GuardDuty 发现结果进行集中查看。公司还必须确保任何新的 AWS 账户都自动启用 GuardDuty。

哪种解决方案可以满足这些要求？

- A. 在组织的管理账户中启用 AWS Security Hub。在管理账户中配置 GuardDuty，将所有 GuardDuty 的发现结果发送到 Security Hub。
- B. 在组织中创建一个新的 AWS 账户。在新账户中启用 GuardDuty。将新账户指定为 GuardDuty 的委派管理员账户。配置 GuardDuty，将现有账户添加为成员账户。选择自动将新的 AWS 账户添加到组织的选项。
- C. 在组织中创建一个新的 AWS 账户。在新账户中启用 GuardDuty。在每个账户中启用 AWS Security Hub。选择自动将新的 AWS 账户添加到组织的选项。
- D. 在组织的管理账户中启用 AWS Security Hub。将管理账户指定为 Security Hub 的委派管理员账户。添加现有账户作为成员账户。选择自动将新的 AWS 账户添加到组织的选项。将所有 Security Hub 的发现结果发送到组织的 GuardDuty 账户。

▼ 答案:

B

1. 考察的知识点

Amazon GuardDuty的集中管理和跨账户配置。

AWS Organizations的使用，包括自动添加新账户的功能。

委派管理员账户的设置和管理。

2. 选项分析

A. 启用 AWS Security Hub 并将 GuardDuty 发现结果发送到 Security Hub:

错误:虽然 Security Hub可以整合GuardDuty的发现结果，但题目要求的是集中管理GuardDuty本身，而不是通过Security Hub查看GuardDuty的发现结果。

错误:此选项没有提到如何自动启用GuardDuty或集中管理GuardDuty的配置。

B. 创建一个新的 AWS 账户并将其设置为 GuardDuty 的委派管理员账户:

正确:此选项符合题目要求，可以通过委派管理员账户集中管理GuardDuty发现结果。

正确:通过GuardDuty的自动成员账户添加功能，可以确保新账户自动启用GuardDuty。

C. 创建一个新的 AWS 账户并启用 GuardDuty 和 Security Hub:

错误:虽然启用了GuardDuty，但没有提到如何集中管理GuardDuty发现结果。

错误:启用Security Hub并不能满足题目要求的GuardDuty集中管理功能。

D. 启用 AWS Security Hub 并将管理账户设置为 Security Hub 的委派管理员账户:

错误:此选项主要关注Security Hub，而题目要求的是GuardDuty的集中管理。

错误:将Security Hub发现结果发送到GuardDuty账户并不符合题目要求。

▼ 英文:

A company wants to remove all SSH keys permanently from a specific subset of its Amazon Linux 2 Amazon EC2 instances that are using the same IAM instance profile. However, three individuals who have IAM user accounts will need to access these

instances by using an SSH session to perform critical duties.

How can a security engineer provide the access to meet these requirements?

A. Assign an IAM policy to the instance profile to allow the EC2 instances to be managed by AWS Systems Manager.

Provide the IAM user accounts with permission to use Systems Manager.

Remove the SSH keys from the EC2 instances. Use Systems Manager Inventory to select the EC2 instance and connect.

B. Assign an IAM policy to the IAM user accounts to provide permission to use AWS Systems Manager Run Command.

Remove the SSH keys from the EC2 instances. Use Run Command to open an SSH connection to the EC2 instance.

C. Assign an IAM policy to the instance profile to allow the EC2 instances to be managed by AWS Systems Manager.

Provide the IAM user accounts with permission to use Systems Manager.

Remove the SSH keys from the EC2 instances.

Use Systems Manager Session Manager to select the EC2 instance and connect.

D. Assign an IAM policy to the IAM user accounts to provide permission to use the EC2 service in the AWS Management Console. Remove the SSH keys from the EC2 instances. Connect to the EC2 instance as the ec2-user through the AWS Management Console's EC2 SSH client method.

▼ 中文:

一家公司希望永久移除特定子集的 Amazon Linux 2 Amazon EC2 实例上的所有 SSH 密钥，这些实例使用相同的 IAM 实例配置文件。然而，有三位拥有 IAM 用户账户的个人需要通过 SSH 会话访问这些实例以执行关键任务。安全工程师如何提供访问权限以满足这些要求？

A. 为实例配置文件分配一个 IAM 策略，允许 EC2 实例由 AWS Systems Manager 管理。为 IAM 用户账户提供使用 Systems Manager 的权限。移除 EC2 实例上的 SSH 密钥。使用 Systems Manager Inventory 选择 EC2 实例并连接。

B. 为 IAM 用户账户分配一个 IAM 策略，提供使用 AWS Systems Manager Run Command 的权限。移除 EC2 实例上的 SSH 密钥。使用 Run Command 打开与 EC2 实例的 SSH 连接。

C. 为实例配置文件分配一个 IAM 策略，允许 EC2 实例由 AWS Systems Manager 管理。为 IAM 用户账户提供使用 Systems Manager 的权限。移除 EC2 实例上的 SSH

密钥。使用 Systems Manager Session Manager 选择 EC2 实例并连接。

D.为 IAM 用户账户分配一个 IAM 策略，提供在 AWS Management Console 中使用 EC2 服务的权限。移除 EC2 实例上的SSH 密钥。通过 AWS Management Console 的 EC2 SSH 客户端方法以 ec2-user 身份连接到 EC2 实例。

▼ 答案:

C

1. 考察的知识点

本题主要考察AWS Systems Manager的功能，尤其是Session Manager的使用。涉及IAM策略的配置以及如何安全地管理EC2实例的访问权限。重点在于移除SSH密钥后如何通过AWS工具实现安全的远程连接。

2. 选项分析

A.

错误:Systems Manager Inventory是用于收集实例信息的工具，不能用于连接到实例。

虽然移除了SSH密钥并配置了IAM策略，但Inventory无法满足连接需求。

B.

错误:AWS Systems Manager Run Command用于执行命令，而不是用于建立SSH连接。

Run Command无法提供交互式会话功能，因此不符合题目要求。

C.

正确:Session Manager是AWS Systems Manager的一部分，支持无SSH密钥的安全远程连接。

通过配置IAM策略，用户可以使用Session Manager连接到EC2实例，满足题目要求。

D.

错误:AWS Management Console没有提供直接的EC2 SSH客户端连接功能。此选项描述的功能不存在，因此不正确。

▼ 88

▼ 英文:

A company is storing data in Amazon S3 Glacier. A security engineer implemented a new vault lock policy for 10 TB of data and called the initiate-vault-lock operation 12 hours ago. The audit team identified a typo in the policy that is allowing unintended access to the vault.

What is the MOST cost-effective way to correct this error?

A. Call the abort-vault-lock operation. Update the policy. Call the initiate-vault-lock operation again.

B. Copy the vault data to a new S3 bucket. Delete the vault. Create a new vault with the data.

C. Update the policy to keep the vault lock in place.

D. Update the policy. Call the initiate-vault-lock operation again to apply the new policy.

▼ 中文:

一家公司正在将数据存储在 Amazon S3 Glacier 中。一位安全工程师为 10 TB 的数据实施了一个新的 vault lock 策略，并在 12 小时前调用了 initiate-vault-lock 操作。审计团队发现该策略中存在一个拼写错误，导致对 vault 的非预期访问。纠正此错误的最具成本效益的方法是什么？

A.调用 abort-vault-lock 操作。更新策略。再次调用 initiate-vault-lock 操作。

B.将 vault 数据复制到一个新的 S3 bucket。删除 vault。使用数据创建一个新的 vault。

C.更新策略以保持 vault lock 不变。

D.更新策略。再次调用 initiate-vault-lock 操作以应用新策略。

▼ 答案:

A

1. 考察的知识点

Amazon S3 Glacier Vault Lock的工作机制，包括锁定策略的创建、修改和终止。

如何处理错误的Vault Lock策略。

成本效益的考虑。

2. 选项分析

A. Call the abort-vault-lock operation. Update the policy. Call the initiate-vault-lock operation again. 正确。Vault Lock的锁定过程分为两个阶段:初始化和完成。在完成之前，可以通过调用abort-vault-lock操作来终止锁定过程并修改策略。这是最成本效益的解决方案，因为不需要重新创建或复制数据。

B. Copy the vault data to a new S3 bucket. Delete the vault. Create a new vault with the data. 错误。这种方法成本高且不必要。复制10 TB的数据到新的S3 bucket会产生额外的存储和数据传输费用，同时删除和重新创建Vault也增加了复杂性。

C. Update the policy to keep the vault lock in place. 错误。一旦Vault Lock完成，策略无法直接更新。此选项忽略了Vault Lock的不可变性。

D. Update the policy. Call the initiate-vault-lock operation again to apply the new policy. 错误。如果Vault Lock已经完成，无法直接更新策略。此选项未提到如何终止当前锁定过程。

▼ 89

▼ 英文:

A company uses HTTP Live Streaming (HLS) to stream live video content to paying subscribers by using Amazon CloudFront.

HLS splits the video content into chunks so that the user can request the right chunk based on different conditions. Because the video events last for several hours, the total video is made up of thousands of chunks.

The origin URL is not disclosed, and every user is forced to access the CloudFront URL. The company has a web application that authenticates the paying users against an internal repository and a CloudFront key pair that is already issued.

What is the simplest and MOST effective way to protect the content?

- A. Develop the application to use the CloudFront key pair to create signed URLs that users will use to access the content.
- B. Develop the application to use the CloudFront key pair to set the signed cookies that users will use to access the content.
- C. Develop the application to issue a security token that Lambda@Edge will receive to authenticate and authorize access to the content.
- D. Keep the CloudFront URL encrypted inside the application, and use AWS KMS to resolve the URL on-the-fly after the user is authenticated.

▼ 中文:

一家公司使用 HTTP Live Streaming (HLS) 通过 Amazon CloudFront 向付费订阅用户直播视频内容。HLS 将视频内容分割成多个片段，以便用户根据不同条件请求正确的片段。由于视频事件持续数小时，总视频由数千个片段组成。

源 URL 未公开，每个用户都必须访问 CloudFront URL。公司有一个网络应用程序，用于根据内部存储库验证付费用户，并且已经颁发了 CloudFront 密钥对。

保护内容最简单且最有效的方法是什么？

- A. 开发应用程序以使用 CloudFront 密钥对创建签名 URL，用户将使用这些 URL 访问内容。
- B. 开发应用程序以使用 CloudFront 密钥对设置签名 Cookie，用户将使用这些 Cookie 访问内容。
- C. 开发应用程序以颁发安全令牌，Lambda@Edge 将接收该令牌以验证和授权访问内容。
- D. 将 CloudFront URL 加密保存在应用程序中，并使用 AWS KMS 在用户验证后即时解析 URL。

▼ 答案:

B

1. 考察的知识点

Amazon CloudFront的内容保护机制，包括签名URL和签名Cookie的使用。

如何通过认证和授权保护视频流内容。

HLS流媒体的工作原理及其与CloudFront的集成。

2. 选项分析

A. 开发应用程序以使用 CloudFront 密钥对创建签名 URL，用户将使用这些 URL 访问内容。

签名URL确实可以保护内容，但对于HLS这种分片视频流，签名URL需要为每个视频片段单独生成URL，这会导致管理复杂性和性能问题。

因此，这种方法虽然可行，但并不是最简单和最有效的方式。

B. 开发应用程序以使用 CloudFront 密钥对设置签名 Cookie，用户将使用这些 Cookie 访问内容。

签名Cookie可以保护内容，并且可以一次性为整个会话设置，而不需要为每个视频片段单独生成URL。

这种方法简化了管理，特别适合HLS流媒体场景，因此是最简单和最有效的方式。

C. 开发应用程序以颁发安全令牌，Lambda@Edge 将接收该令牌以验证和授权访问内容。

使用Lambda@Edge进行内容保护是一种灵活的方式，但实现起来复杂，需要额外的开发和维护工作。

相比签名Cookie，这种方法并不是最简单的解决方案。

D. 将 CloudFront URL 加密保存在应用程序中，并使用 AWS KMS 在用户验证后即时解析 URL。

这种方法涉及使用AWS KMS进行加密和解密，增加了复杂性和成本。

虽然可以保护内容，但并不是最有效的方式，尤其是对于HLS流媒体场景。

▼ 90

▼ 英文:

A company runs workloads in the us-east-1 Region. The company has never deployed resources to other AWS Regions and does not have any multi-Region resources. The company needs to replicate its workloads and infrastructure to the us-west-1 Region.

A security engineer must implement a solution that uses AWS Secrets Manager to store secrets in both Regions. The solution must use AWS Key Management Service (AWS KMS) to encrypt the secrets. The solution must minimize latency and must be able to work if only one Region is available.

The security engineer uses Secrets Manager to create the secrets in us-east-1. What should the security engineer do next to meet the requirements?

A. Encrypt the secrets in us-east-1 by using an AWS managed KMS key.

Replicate the secrets to us-west-1. Encrypt the secrets in us-west-1 by using a

new AWS managed KMS key in us-west-1.

B. Encrypt the secrets in us-east-1 by using an AWS managed KMS key. Configure resources in us-west-1 to call the Secrets Manager endpoint in us-east-1.

C. Encrypt the secrets in us-east-1 by using a customer managed KMS key. Configure resources in us-west-1 to call the Secrets Manager endpoint in us-east-1.

D. Encrypt the secrets in us-east-1 by using a customer managed KMS key. Replicate the secrets to us-west-1. Encrypt the secrets in us-west-1 by using the customer managed KMS key from us-east-1.

▼ 中文:

一家公司在 us-east-1 区域运行工作负载。该公司从未在其他 AWS 区域部署资源，也没有任何多区域资源。该公司需要 将其工作负载和基础设施复制到 us-west-1 区域。一名安全工程师必须实施一个解决方案，该解决方案使用 AWS Secrets Manager 在两个区域存储密钥。该解决方案必须 使用 AWS Key Management Service (AWS KMS) 加密密钥。该解决方案必须 尽量减少延迟，并且能够在只有一个区域可用时正常工作。

安全工程师使用 Secrets Manager 在 us-east-1 创建密钥。安全工程师接下来应该怎么做以满足要求？

A.使用 AWS 托管 KMS 密钥加密 us-east-1 的密钥。将密钥复制到 us-west-1。在 us-west-1 使用新的 AWS 托管 KMS 密钥加密密钥。

B.使用 AWS 托管 KMS 密钥加密 us-east-1 的密钥。在 us-west-1 配置资源调用 us-east-1 的 Secrets Manager 端点。

C.使用客户托管 KMS 密钥加密 us-east-1 的密钥。在 us-west-1 配置资源调用 us-east-1 的 Secrets Manager 端点。

D.使用客户托管 KMS 密钥加密 us-east-1 的密钥。将密钥复制到 us-west-1。在 us-west-1 使用来自 us-east-1 的客户托管 KMS 密钥加密密钥。

▼ 答案:

D

1. 考察的知识点

跨区域资源复制与管理

AWS Secrets Manager的使用

AWS Key Management Service (KMS)的加密与密钥管理

高可用性与区域故障恢复

2. 选项分析

A. Encrypt the secrets in us-east-1 by using an AWS managed KMS key.

Replicate the secrets to us-west-1. Encrypt the

secrets in us-west-1 by using a new AWS managed KMS key in us-west-1.

错误:AWS托管KMS密钥无法跨区域使用。每个区域的托管密钥是独立的，无法满足“使用同一个密钥”的要求。

此外，使用不同的密钥可能导致跨区域访问时的加密解密问题。

B. Encrypt the secrets in us-east-1 by using an AWS managed KMS key.

Configure resources in us-west-1 to call the Secrets

Manager endpoint in us-east-1.

错误:虽然可以通过调用us-east-1的Secrets Manager端点来访问密钥，但这会增加跨区域访问的延迟，不符合“最小化延迟”的要求。

此外，如果us-east-1不可用，us-west-1的资源将无法访问Secrets Manager，违反了“高可用性”的要求。

C. Encrypt the secrets in us-east-1 by using a customer managed KMS key.

Configure resources in us-west-1 to call the

Secrets Manager endpoint in us-east-1.

错误:虽然使用客户托管KMS密钥可以提供更灵活的密钥管理，但与选项B类似，跨区域调用会增加延迟，并且在us-east-1不可用时无法满足高可用性要求。

D. Encrypt the secrets in us-east-1 by using a customer managed KMS key.

Replicate the secrets to us-west-1. Encrypt the

secrets in us-west-1 by using the customer managed KMS key from us-east-1.

正确:使用客户托管KMS密钥可以跨区域使用，并且通过Secrets Manager的复制功能，可以在us-west-1区域中使用相同的密钥进行加密。

这种方法确保了高可用性，因为两个区域都可以独立访问Secrets Manager，即使一个区域不可用，另一个区域仍然可以正常工作。

此外，这种方法最小化了延迟，因为每个区域都有自己的Secrets Manager副本。

▼ 91

▼ 英文:

A company operates a web application that runs on Amazon EC2 instances. The application listens on port 80 and port 443. The company uses an Application Load Balancer (ALB) with AWS WAF to terminate SSL and to forward traffic to the application instances only on port 80.

The ALB is in public subnets that are associated with a network ACL that is named NACL1. The application instances are in dedicated private subnets that are associated with a network ACL that is named NACL2. An Amazon RDS for PostgreSQL DB instance that uses port 5432 is in a dedicated private subnet that is associated with a network ACL that is named NACL3. All the network ACLs currently allow all inbound and outbound traffic.

Which set of network ACL changes will increase the security of the application while ensuring functionality?

A. Make the following changes to NACL3:

- Add a rule that allows inbound traffic on port 5432 from NACL2.
- Add a rule that allows outbound traffic on ports 1024-65536 to NACL2.
- Remove the default rules that allow all inbound and outbound traffic.

B. Make the following changes to NACL3:

- Add a rule that allows inbound traffic on port 5432 from the CIDR blocks of the application instance subnets.
- Add a rule that allows outbound traffic on ports 1024-65536 to the application instance subnets.
- Remove the default rules that allow all inbound and outbound traffic.

C. Make the following changes to NACL2:

- Add a rule that allows outbound traffic on port 5432 to the CIDR blocks of the RDS subnets.
- Remove the default rules that allow all inbound and outbound traffic.

D. Make the following changes to NACL2:

- Add a rule that allows inbound traffic on port 5432 from the CIDR blocks of the RDS subnets.
- Add a rule that allows outbound traffic on port 5432 to the RDS subnets.

▼ 中文:

一家公司运营一个运行在 Amazon EC2 实例上的 Web 应用程序。该应用程序监听端口 80 和端口 443。公司使用一个 Application Load Balancer (ALB) 和 AWS WAF 来终止 SSL，并仅将流量转发到端口 80 的应用程序实例。

ALB 位于与名为 NACL1 的网络 ACL 关联的公共子网中。应用程序实例位于与名为 NACL2 的网络 ACL 关联的专用子网中。使用端口 5432 的 Amazon RDS for PostgreSQL 数据库实例位于与名为 NACL3 的网络 ACL 关联的专用子网中。所有网络 ACL 当前允许所有入站和出站流量。

哪些网络 ACL 更改可以在确保功能的同时提高应用程序的安全性？

A.对 NACL3 进行以下更改: • 添加一条规则，允许来自 NACL2 的端口 5432 的入站流量。 • 添加一条规则，允许到 NACL2 的端口 1024-65536 的出站流量。 • 移除默认规则，禁止所有入站和出站流量。

B.对 NACL3 进行以下更改: • 添加一条规则，允许来自应用程序实例子网的 CIDR 块的端口 5432 的入站流量。 • 添加一条规则，允许到应用程序实例子网的端口 1024-65536 的出站流量。 • 移除默认规则，禁止所有入站和出站流量。

C.对 NACL2 进行以下更改: • 添加一条规则，允许到 RDS 子网的 CIDR 块的端口 5432 的出站流量。 • 移除默认规则，禁止所有入站和出站流量。

D.对 NACL2 进行以下更改: • 添加一条规则，允许来自 RDS 子网的 CIDR 块的端口 5432 的入站流量。 • 添加一条规则，允许到 RDS 子网的端口 5432 的出站流量。

▼ 答案:

B

1. 考察的知识点

网络ACL(NACL)的配置和规则管理。

如何通过网络ACL提高安全性，同时确保应用程序功能正常。

理解网络ACL的入站和出站规则，以及如何限制流量。

2. 选项分析

A:

正确性分析:此选项建议对NACL3进行更改，允许来自NACL2的流量并移除默认规则。但NACL3的流量应该基于应用程序实例的CIDR块，而不是NACL2。此选项错误。

B:

正确性分析:此选项建议对NACL3进行更改，允许来自应用程序实例子网的CIDR块的流量，并移除默认规则。这是正确的，因为NACL3负责保护RDS实例，流量应该来自应用程序实例的子网。

C:

正确性分析:此选项建议对NACL2进行更改，允许到RDS子网的出站流量，但没有处理入站流量规则。此选项不完整，无法确保功能正常。

D:

正确性分析:此选项建议对NACL2进行更改，允许来自RDS子网的入站流量和到RDS子网的出站流量。但NACL2负责保护应用程序实例，而不是RDS实例。此选项错误。

▼ 92

▼ 英文:

AWS CloudTrail is being used to monitor API calls in an organization. An audit revealed that CloudTrail is failing to deliver events to Amazon S3 as expected.

What initial actions should be taken to allow delivery of CloudTrail events to S3? (Choose two.)

A. Verify that the S3 bucket policy allows CloudTrail to write objects.

B. Verify that the IAM role used by CloudTrail has access to write to Amazon CloudWatch Logs.

C. Remove any lifecycle policies on the S3 bucket that are archiving objects to S3 Glacier Flexible Retrieval.

D. Verify that the S3 bucket defined in CloudTrail exists.

E. Verify that the log file prefix defined in CloudTrail exists in the S3 bucket.

▼ 中文:

AWS CloudTrail 正在用于监控组织中的 API 调用。一项审计显示，CloudTrail 未能按预期将事件传递到 Amazon S3。应该采取哪些初步行动以允许 CloudTrail 事件传递到 S3?(选择两个)

- A. 验证 S3 bucket 策略允许 CloudTrail 写入对象。
- B. 验证 CloudTrail 使用的 IAM 角色具有写入 Amazon CloudWatch Logs 的权限。
- C. 移除任何将对象归档到 S3 Glacier Flexible Retrieval 的 S3 bucket 生命周期策略。
- D. 验证 CloudTrail 中定义的 S3 bucket 是否存在。
- E. 验证 CloudTrail 中定义的日志文件前缀是否存在于 S3 bucket 中。

▼ 答案:

AD

1. 考察的知识点

CloudTrail的配置与故障排查。

S3存储桶策略与权限验证。

CloudTrail事件日志的正确交付。

2. 选项分析

A. Verify that the S3 bucket policy allows CloudTrail to write objects.

正确。CloudTrail需要适当的S3存储桶策略来写入日志文件。如果存储桶策略不允许CloudTrail写入对象，事件将无法交付到S3。

B. Verify that the IAM role used by CloudTrail has access to write to Amazon CloudWatch Logs.

错误。此选项与问题无关，因为问题是关于CloudTrail事件未交付到S3，而不是CloudWatch Logs的权限问题。

C. Remove any lifecycle policies on the S3 bucket that are archiving objects to S3 Glacier Flexible Retrieval.

错误。生命周期策略不会影响CloudTrail事件的交付。它仅影响存储桶中现有对象的存储层级。

D. Verify that the S3 bucket defined in CloudTrail exists.

正确。如果CloudTrail配置的S3存储桶不存在，事件无法交付到S3。

E. Verify that the log file prefix defined in CloudTrail exists in the S3 bucket.

错误。日志文件前缀是一个逻辑路径，不需要在S3存储桶中预先存在。

▼ 93

▼ 英文:

A company has public certificates that are managed by AWS Certificate Manager (ACM). The certificates are either imported certificates or managed

certificates from ACM with mixed validation methods. A security engineer needs to design a monitoring solution to provide alerts by email when a certificate is approaching its expiration date.

What is the MOST operationally efficient way to meet this requirement?

A. Create an AWS Lambda function to list all certificates and to go through each certificate to describe the certificate by using the AWS SDK. Filter on the NotAfter attribute and send an email notification. Use an Amazon EventBridge rate

expression to schedule the Lambda function to run daily.

B. Create an Amazon CloudWatch alarm. Add all the certificate ARNs in the AWS/CertificateManager namespace to the DaysToExpiry metric. Configure the alarm to publish a notification to an Amazon Simple Notification Service (Amazon SNS)

topic when the value for the DaysToExpiry metric is less than or equal to 31.

C. Set up AWS Security Hub. Turn on the AWS Foundational Security Best Practices standard with integrated ACM to send findings. Configure and use a custom action by creating a rule to match the pattern from the ACM findings on the NotBefore attribute as the event source. Create an Amazon Simple Notification Service (Amazon SNS) topic as the target.

D. Create an Amazon EventBridge rule by using a predefined pattern for ACM. Choose the metric in the ACM Certificate Approaching Expiration event as the event pattern. Create an Amazon Simple Notification Service (Amazon SNS) topic as the target.

▼ 中文:

一家公司拥有由 AWS Certificate Manager (ACM) 管理的公共证书。这些证书包括导入的证书或使用混合验证方法的 ACM 管理证书。一位安全工程师需要设计一个监控解决方案，当证书接近其到期日期时，通过电子邮件提供警报。满足此要求的最具操作效率的方法是什么？

A. 创建一个 AWS Lambda 函数，列出所有证书，并通过使用 AWS SDK 遍历每个证书以描述证书。根据 NotAfter 属性进行过滤并发送电子邮件通知。使用 Amazon EventBridge 速率表达式来安排 Lambda 函数每天运行。

B. 创建一个 Amazon CloudWatch 警报。在 AWS/CertificateManager 命名空间中添加所有证书 ARN 到 DaysToExpiry 指标。当 DaysToExpiry 指标的值小于或等于 31 时，配置警报以向 Amazon Simple Notification Service (Amazon SNS) 主题发布通知。

C. 设置 AWS Security Hub。启用与 ACM 集成的 AWS Foundational Security Best Practices 标准以发送发现结果。通过创建规则匹配 ACM 发现结果中的 NotBefore 属性作为事件源来配置和使用自定义操作。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题作为目标。

D.通过使用 ACM 的预定义模式创建一个Amazon EventBridge 规则。选择 ACM Certificate Approaching Expiration 事件中的指标作为事件模式。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题作为目标。

▼ 答案:

D

题目分析与解答

1. 考察的知识点

AWS Certificate Manager (ACM) 的证书管理与监控。

Amazon EventBridge 的事件规则和自动化处理能力。

Amazon SNS 的通知功能。

如何设计高效的监控和告警解决方案。

2. 选项分析

D (100%)

A. 创建一个 AWS Lambda 函数，列出所有证书并通过 AWS SDK 遍历每个证书以描述证书。

分析:

正确性:可以实现目标，但需要手动编写代码来处理证书列表和过滤逻辑。

效率:不够高效，因为需要定期运行 Lambda 函数并手动管理逻辑，增加了运维复杂性。

结论:此选项正确但不是最优解。

B. 创建一个 Amazon CloudWatch 警报，使用 DaysToExpiry 指标。

分析:

正确性:AWS Certificate Manager 提供 DaysToExpiry 指标，但仅适用于 ACM 管理的证书，不支持导入的证书。

效率:无法覆盖所有证书(包括导入的证书)，因此不满足题目要求。

结论:此选项错误。

C. 设置 AWS Security Hub 并启用 AWS Foundational Security Best Practices 标准。

分析:

正确性:AWS Security Hub 可以提供安全发现，但其主要目标是安全合规性，而不是专门针对证书到期的监控。

效率:需要额外配置和集成，复杂度较高，且不直接针对证书到期问题。

结论:此选项错误。

D. 创建一个 Amazon EventBridge 规则，使用 ACM 的预定义模式。

分析:

正确性:Amazon EventBridge 提供 ACM Certificate Approaching Expiration 事件，可以直接监控证书到期情况。

效率:无需手动编写代码或复杂配置，直接使用预定义事件模式，最为高效。

结论:此选项正确且是最优解。

▼ 94

▼ 英文:

A security team is responsible for reviewing AWS API call activity in the cloud environment for security violations. These events must be recorded and retained in a centralized location for both current and future AWS regions.

What is the SIMPLEST way to meet these requirements?

- A. Enable AWS Trusted Advisor security checks in the AWS Console, and report all security incidents for all regions.
- B. Enable AWS CloudTrail by creating individual trails for each region, and specify a single Amazon S3 bucket to receive log files for later analysis.
- C. Enable AWS CloudTrail by creating a new trail and applying the trail to all regions. Specify a single Amazon S3 bucket as the storage location.
- D. Enable Amazon CloudWatch logging for all AWS services across all regions, and aggregate them to a single Amazon S3 bucket for later analysis.

▼ 中文:

一个安全团队负责审查云环境中AWS API调用活动以检测安全违规行为。这些事件必须被记录并保存在一个集中位置，以便当前和未来的AWS区域使用。满足这些要求的最简单方法是什么？

- A.在AWS Console中启用AWS Trusted Advisor安全检查，并报告所有区域的所有安全事件。
- B.通过为每个区域创建单独的AWS CloudTrail trails，并指定一个Amazon S3 bucket来接收日志文件以供后续分析。
- C.通过创建一个新的AWS CloudTrail trail并将该trail应用于所有区域。指定一个Amazon S3 bucket作为存储位置。
- D.为所有区域的所有AWS服务启用Amazon CloudWatch日志记录，并将它们汇总到一个Amazon S3 bucket以供后续分析。

▼ 答案:

C

1. 考察的知识点

本题考察的是AWS CloudTrail的使用，特别是如何在所有区域记录和集中存储API调用活动以满足安全审查需求。

涉及的知识点包括:CloudTrail的跨区域支持、日志存储到Amazon S3、以及如何简化配置以覆盖所有区域。

2. 选项分析

A. 启用AWS Trusted Advisor安全检查，并报告所有区域的所有安全事件。

错误:AWS Trusted Advisor主要用于提供优化建议(如成本、性能、安全性等)，而不

是记录API调用活动。它无法满足记录和集中存储API调用日志的需求。

B. 为每个区域创建单独的AWS CloudTrail trails，并指定一个Amazon S3 bucket来接收日志文件以供后续分析。

错误:虽然可以为每个区域创建单独的CloudTrail trails，但这种方法复杂且不必要。

CloudTrail支持跨区域的单一trail配

置，可以简化管理。

C. 创建一个新的AWS CloudTrail trail并将该trail应用于所有区域，指定一个Amazon S3 bucket作为存储位置。

正确:这是最简单且符合要求的解决方案。CloudTrail支持跨区域trail，可以记录所有区域的API调用活动，并集中存储到一个S3 bucket中。

D. 为所有区域的所有AWS服务启用Amazon CloudWatch日志记录，并将它们汇总到一个Amazon S3 bucket以供后续分析。

错误:CloudWatch主要用于监控和日志记录服务运行状态，而不是专门记录API调用活动。使用CloudTrail是更合适的解决方案。

▼ 95

▼ 英文:

A company is running an application on Amazon EC2 instances in an Auto Scaling group. The application stores logs locally. A security engineer noticed that logs were lost after a scale-in event. The security engineer needs to recommend a solution to ensure the durability and availability of log data. All logs must be kept for a minimum of 1 year for auditing purposes. What should the security engineer recommend?

A. Within the Auto Scaling lifecycle, add a hook to create and attach an Amazon Elastic Block Store (Amazon EBS) log volume each time an EC2 instance is created. When the instance is terminated, the EBS volume can be reattached to another instance for log review.

B. Create an Amazon Elastic File System (Amazon EFS) file system and add a command in the user data section of the Auto Scaling launch template to mount the EFS file system during EC2 instance creation. Configure a process on the instance to copy the logs once a day from an instance Amazon Elastic Block Store (Amazon EBS) volume to a directory in the EFS file system.

C. Add an Amazon CloudWatch agent into the AMI used in the Auto Scaling group. Configure the CloudWatch agent to send the logs to Amazon CloudWatch Logs for review.

D. Within the Auto Scaling lifecycle, add a lifecycle hook at the terminating state transition and alert the engineering team by using a lifecycle notification to Amazon Simple Notification Service (Amazon SNS). Configure the hook to remain in the

Terminating:Wait state for 1 hour to allow manual review of the security logs prior to instance termination.

▼ 中文:

一家公司在一个 Auto Scaling 组中的 Amazon EC2 实例上运行一个应用程序。该应用程序将日志存储在本地。一位安全工程师注意到，在缩减规模事件后日志丢失了。安全工程师需要推荐一个解决方案，以确保日志数据的持久性和可用性。所有日志必须至少保存 1 年以供审计使用。

安全工程师应该推荐什么解决方案？

A.在 Auto Scaling 生命周期中，添加一个钩子，每次创建 EC2 实例时创建并附加一个 Amazon Elastic Block Store (Amazon EBS) 日志卷。当实例被终止时，可以将 EBS 卷重新附加到另一个实例以进行日志审查。

B.创建一个 Amazon Elastic File System (Amazon EFS) 文件系统，并在 Auto Scaling 启动模板的用户数据部分添加一个命令，在 EC2 实例创建期间挂载 EFS 文件系统。配置实例上的一个进程，每天将日志从实例的 Amazon Elastic Block Store (Amazon EBS) 卷复制到 EFS 文件系统中的目录。

C.在 Auto Scaling 组中使用的 AMI 中添加一个 Amazon CloudWatch agent。配置 CloudWatch agent 将日志发送到 Amazon CloudWatch Logs 以供审查。

D.在 Auto Scaling 生命周期中，在终止状态转换时添加一个生命周期钩子，并通过生命周期通知使用 Amazon Simple Notification Service (Amazon SNS) 向工程团队发出警报。配置钩子保持在 Terminating:Wait 状态 1 小时，以便在实例终止之前手动审查安全日志。

▼ 答案:

C

1. 考察的知识点

本题考察的是日志的持久性与可用性，特别是在动态扩展和缩减的环境中如何确保日志数据的保存。

涉及的AWS服务包括:Amazon CloudWatch Logs、Amazon EFS、Amazon EBS、Auto Scaling Lifecycle Hooks、Amazon SNS。

2. 选项分析

A.

正确性分析:虽然EBS卷可以存储日志并在实例终止后重新附加到其他实例，但这种方法复杂且不适合大规模自动化

场景。手动管理EBS卷的生命周期和重新附加过程可能会导致操作复杂性和潜在错误。

结论:此选项不够高效，且不符合自动化和持久性要求。

B.

正确性分析:EFS是一个持久化存储解决方案，适合跨多个实例共享数据。然而，要求每天手动复制日志到EFS的过程

增加了复杂性，并且可能导致日志丢失(例如在实例突然终止时)。
结论:此选项虽然可行，但不够高效，且无法保证日志的实时持久性。

C.

正确性分析:CloudWatch Logs是一个高效的日志持久化解决方案，支持实时日志收集和存储。通过在AMI中预配置CloudWatch agent，可以确保所有实例的日志自动发送到CloudWatch Logs，**满足持久性和可用性要求**。

结论:此选项是最佳解决方案，符合题目要求。

D.

正确性分析:使用生命周期钩子可以在实例终止前执行操作，但依赖人工审查日志的过程效率低下，且无法保证日志的持久性和自动化存储。

结论:此选项不符合题目要求，且不够高效。

▼ 96

▼ 英文:

A company uses Amazon EC2 instances to host frontend services behind an Application Load Balancer. Amazon Elastic Block Store (Amazon EBS) volumes are attached to the EC2 instances. The company uses Amazon S3 buckets to store large files for images and music.

The company has implemented a security architecture on AWS to prevent, identify, and isolate potential ransomware attacks.

The company now wants to further reduce risk.

A security engineer must develop a disaster recovery solution that can recover to normal operations if an attacker bypasses preventive and detective controls. The solution must meet an RPO of 1 hour.

Which solution will meet these requirements?

A. Use AWS Backup to create backups of the EC2 instances and S3 buckets every hour. Create AWS CloudFormation templates that replicate existing architecture components. Use AWS CodeCommit to store the CloudFormation templates alongside application configuration code.

B. Use AWS Backup to create backups of the EBS volumes and S3 objects every day. Use Amazon Security Lake to create a centralized data lake for AWS CloudTrail logs and VPC flow logs. Use the logs for automated response.

C. Use Amazon Security Lake to create a centralized data lake for AWS CloudTrail logs and VPC flow logs. Use the logs for automated response. Enable AWS Security Hub to establish a single location for recovery procedures. Create AWS CloudFormation templates that replicate existing architecture components.

Use AWS CodeCommit to store the CloudFormation templates alongside application configuration code.

D. Create EBS snapshots every 4 hours. Enable Amazon GuardDuty Malware Protection. Create automation to immediately restore the most recent snapshot for any EC2 instances that produce an Execution:EC2/MaliciousFile finding in GuardDuty.

▼ 中文:

一家公司使用 Amazon EC2 实例来托管位于 Application Load Balancer 后面的前端服务。Amazon Elastic Block Store

(Amazon EBS) 卷附加到 EC2 实例。该公司使用 Amazon S3 存储桶来存储用于图像和音乐的大型文件。

该公司在 AWS 上实施了一种安全架构，以防止、识别和隔离潜在的勒索软件攻击。现在，该公司希望进一步降低风险。

一名安全工程师必须开发一个灾难恢复解决方案，以便在攻击者绕过预防和检测控制措施时能够恢复到正常运行状态。该解决方案必须满足 1 小时的 RPO 要求。

哪种解决方案可以满足这些要求？

A.使用 AWS Backup 每小时创建 EC2 实例和 S3 存储桶的备份。创建 AWS CloudFormation 模板以复制现有的架构组件。使用 AWS CodeCommit 将 CloudFormation 模板与应用程序配置代码一起存储。

B.使用 AWS Backup 每天创建 EBS 卷和 S3 对象的备份。使用 Amazon Security Lake 创建一个集中式数据湖，用于存储 AWS CloudTrail 日志和 VPC 流日志。使用这些日志进行自动响应。

C.使用 Amazon Security Lake 创建一个集中式数据湖，用于存储 AWS CloudTrail 日志和 VPC 流日志。使用这些日志进行自动响应。启用 AWS Security Hub 来建立一个用于恢复程序的单一位置。创建 AWS CloudFormation 模板以复制现有的架构组件。使用 AWS CodeCommit 将 CloudFormation 模板与应用程序配置代码一起存储。

D.每 4 小时创建一次 EBS 快照。启用 Amazon GuardDuty Malware Protection。创建自动化流程以立即恢复任何在 GuardDuty 中产生 Execution:EC2/MaliciousFile 发现的 EC2 实例的最新快照。

▼ 答案:

A

1. 考察的知识点

灾难恢复 (Disaster Recovery) 的设计与实现。

RPO (恢复点目标) 的定义与满足。

AWS Backup 的使用及其与其他服务的集成。

AWS CloudFormation 和 AWS CodeCommit 的应用于架构恢复。

2. 选项分析

A. 使用 AWS Backup 每小时创建 EC2 实例和 S3 存储桶的备份。创建 AWS CloudFormation 模板以复制现有的架构组

件。使用 AWS CodeCommit 将 CloudFormation 模板与应用程序配置代码一起存储。

正确:AWS Backup 可以满足 RPO 为 1 小时的要求，因为它支持定时备份(例如每小时)。

正确:AWS CloudFormation 模板可以快速恢复架构组件，确保灾难恢复的自动化和一致性。

正确:将 CloudFormation 模板和应用程序配置代码存储在 AWS CodeCommit 中可以确保恢复时的代码版本控制和一致性。

B. 使用 AWS Backup 每天创建 EBS 卷和 S3 对象的备份。使用 Amazon Security Lake 创建一个集中式数据湖，用于存储 AWS CloudTrail 日志和 VPC 流日志。使用这些日志进行自动响应。

错误:每天备份无法满足 RPO 为 1 小时的要求。

错误:Amazon Security Lake 和日志分析主要用于检测和响应，而不是灾难恢复的核心解决方案。

C. 使用 Amazon Security Lake 创建一个集中式数据湖，用于存储 AWS CloudTrail 日志和 VPC 流日志。使用这些日

志进行自动响应。启用 AWS Security Hub 来建立一个用于恢复程序的单一位置。创建 AWS CloudFormation 模板以

复制现有的架构组件。使用 AWS CodeCommit 将 CloudFormation 模板与应用程序配置代码一起存储。

错误:Amazon Security Lake 和 AWS Security Hub 的主要功能是检测和响应安全事件，而不是灾难恢复的核心解决方案。

正确:AWS CloudFormation 和 AWS CodeCommit 的使用是灾难恢复的有效方法，但缺少定时备份的支持，无法满足 RPO 为 1 小时的要求。

D. 每 4 小时创建一次 EBS 快照。启用 Amazon GuardDuty Malware Protection。创建自动化流程以立即恢复任何在 GuardDuty 中产生 Execution:EC2/MaliciousFile 发现的 EC2 实例的最新快照。

错误:4 小时的快照间隔无法满足 RPO 为 1 小时的要求。

错误:Amazon GuardDuty Malware Protection 是检测和响应工具，而不是灾难恢复的核心解决方案。

▼ 97

▼ 英文:

A company has an application that runs on Amazon EC2 instances behind an Application Load Balancer (ALB). The instances are in an Amazon EC2 Auto Scaling group and are attached to Amazon Elastic Block Store (Amazon EBS) volumes.

A security engineer needs to preserve all forensic evidence from one of the instances. Which order of steps should the security engineer use to meet this requirement?

- A. Take an EBS volume snapshot of the instance and store the snapshot in an Amazon S3 bucket. Take a memory snapshot of the instance and store the snapshot in an S3 bucket. Detach the instance from the Auto Scaling group. Deregister the instance from the ALB. Stop the instance.
- B. Take a memory snapshot of the instance and store the snapshot in an Amazon S3 bucket. Stop the instance. Take an EBS volume snapshot of the instance and store the snapshot in an S3 bucket. Detach the instance from the Auto Scaling group. Deregister the instance from the ALB.
- C. Detach the instance from the Auto Scaling group. Deregister the instance from the ALB. Take an EBS volume snapshot of the instance and store the snapshot in an Amazon S3 bucket. Take a memory snapshot of the instance and store the snapshot in an S3 bucket. Stop the instance.
- D. Detach the instance from the Auto Scaling group. Deregister the instance from the ALB. Stop the instance. Take a memory snapshot of the instance and store the snapshot in an Amazon S3 bucket. Take an EBS volume snapshot of the instance and store the snapshot in an S3 bucket.

▼ 中文:

一家公司有一个应用程序运行在 Amazon EC2 实例上，并通过 Application Load Balancer (ALB) 进行负载均衡。这些实例位于 Amazon EC2 Auto Scaling 组中，并附加了 Amazon Elastic Block Store (Amazon EBS) 卷。

一名安全工程师需要保留其中一个实例的所有取证证据。安全工程师应该按照什么步骤顺序来满足这一要求？

- A. 对实例的 EBS 卷进行快照，并将快照存储在 Amazon S3 存储桶中。对实例进行内存快照，并将快照存储在 S3 存储桶中。将实例从 Auto Scaling 组中分离。将实例从 ALB 中注销。停止实例。
- B. 对实例进行内存快照，并将快照存储在 Amazon S3 存储桶中。停止实例。对实例的 EBS 卷进行快照，并将快照存储在 S3 存储桶中。将实例从 Auto Scaling 组中分离。将实例从 ALB 中注销。
- C. 将实例从 Auto Scaling 组中分离。将实例从 ALB 中注销。对实例的 EBS 卷进行快照，并将快照存储在 Amazon S3 存储桶中。对实例进行内存快照，并将快照存储在 S3 存储桶中。停止实例。
- D. 每 4 小时创建一次 EBS 快照。启用 Amazon GuardDuty Malware Protection。创建自动化流程以立即恢复任何在 GuardDuty 中产生 Execution:EC2/MaliciousFile 发现的 EC2 实例的最新快照。

▼ 答案:

C

1. 考察的知识点

Amazon EC2实例的取证流程，包括内存快照和EBS卷快照的保存。

如何正确处理Auto Scaling组中的实例以避免自动替换。

如何从ALB中注销实例以确保流量不再发送到目标实例。

2. 选项分析

A:

首先对EBS卷进行快照，然后进行内存快照。这是错误的，因为内存快照需要在实例运行时进行，停止实例后无法获取内存快照。

顺序错误，未优先处理Auto Scaling组和ALB的分离，可能导致实例被替换或流量继续发送到实例。

首先进行内存快照，然后停止实例。这是正确的，因为内存快照需要在实例运行时进行。

B:

未优先处理Auto Scaling组和ALB的分离，可能导致实例被替换或流量继续发送到实例。

首先分离实例并注销ALB，确保实例不会被替换或继续接收流量。这是正确的流程。

C:

然后对EBS卷和内存进行快照，最后停止实例。这是正确的顺序。

D:

首先分离实例并注销ALB，确保实例不会被替换或继续接收流量。这是正确的流程。然后停止实例后再进行内存快照，这是错误的，因为停止实例后无法获取内存快照。

▼ 98

▼ 英文:

An application team wants to use AWS Certificate Manager (ACM) to request public certificates to ensure that data is secured in transit. The domains that are being used are not currently hosted on Amazon Route 53.

The application team wants to use an AWS managed distribution and caching solution to optimize requests to its systems and provide better points of presence to customers. The distribution solution will use a primary domain name that is customized. The distribution solution also will use several alternative domain names. The certificates must renew automatically over an indefinite period of time.

Which combination of steps should the application team take to deploy this architecture? (Choose three.)

- A. Request a certificate from ACM in the us-west-2 Region. Add the domain names that the certificate will secure.
- B. Send an email message to the domain administrators to request validation of the domains for ACM.
- C. Request validation of the domains for ACM through DNS. Insert CNAME records into each domain's DNS zone.
- D. Create an Application Load Balancer for the caching solution. Select the newly requested certificate from ACM to be used for secure connections.
- E. Create an Amazon CloudFront distribution for the caching solution. Enter the main CNAME record as the Origin Name. Enter the subdomain names or alternate names in the Alternate Domain Names Distribution Settings. Select the newly requested certificate from ACM to be used for secure connections.
- F. Request a certificate from ACM in the us-east-1 Region. Add the domain names that the certificate will secure.

▼ 中文:

一个应用团队希望使用 AWS Certificate Manager (ACM) 来申请公共证书，以确保数据在传输过程中是安全的。当前使用的域名并未托管在 Amazon Route 53。应用团队希望使用 AWS 托管的分发和缓存解决方案来优化对其系统的请求，并为客户提供更好的接入点。分发解决方案将使用一个定制的主域名，并且还将使用多个备用域名。这些证书必须能够在无限期内自动续订。应用团队应该采取哪些步骤来部署此架构?(选择三项)

- A. 从 ACM 在 us-west-2 区域申请证书。添加证书将保护的域名
- B. 向域名管理员发送电子邮件以请求对 ACM 的域名进行验证。
- C. 通过 DNS 请求对 ACM 的域名进行验证。在每个域的 DNS 区域中插入 CNAME 记录。
- D. 为缓存解决方案创建一个 Application Load Balancer。选择从 ACM 新申请的证书用于安全连接。
- E. 为缓存解决方案创建一个 Amazon CloudFront 分发。将主 CNAME 记录输入为 Origin Name。在备用域名分发设置中 输入子域名或备用名称。选择从 ACM 新申请的证书用于安全连接。
- F. 从 ACM 在 us-east-1 区域申请证书。添加证书将保护的域名。

▼ 答案:

CEF

1. 考察的知识点

Amazon EC2实例的取证流程，包括内存快照和EBS卷快照的保存。
 如何正确处理Auto Scaling组中的实例以避免自动替换。

如何从ALB中注销实例以确保流量不再发送到目标实例。

2. 选项分析

A:

首先对EBS卷进行快照，然后进行内存快照。这是错误的，因为内存快照需要在实例运行时进行，停止实例后无法获取内存快照。

顺序错误，未优先处理Auto Scaling组和ALB的分离，可能导致实例被替换或流量继续发送到实例。

B:

首先进行内存快照，然后停止实例。这是正确的，因为内存快照需要在实例运行时进行。

未优先处理Auto Scaling组和ALB的分离，可能导致实例被替换或流量继续发送到实例。

C:

首先分离实例并注销ALB，确保实例不会被替换或继续接收流量。这是正确的流程。然后对EBS卷和内存进行快照，最后停止实例。这是正确的顺序。

D:

首先分离实例并注销ALB，确保实例不会被替换或继续接收流量。这是正确的流程。然后停止实例后再进行内存快照，这是错误的，因为停止实例后无法获取内存快照。

E.

正确：CloudFront 是题目要求的分发和缓存解决方案，支持自定义域名和 ACM 证书。

F.

正确：ACM 公共证书必须在 us-east-1 区域申请才能用于 Amazon CloudFront。

▼ 99

▼ 英文:

A company's security engineer wants to receive an email alert whenever Amazon GuardDuty, AWS Identity and Access Management Access Analyzer, or Amazon Macie generate a high-severity security finding. The company uses AWS Control Tower to govern all of its accounts. The company also uses AWS Security Hub with all of the AWS service integrations turned on. Which solution will meet these requirements with the LEAST operational overhead?

A. Set up separate AWS Lambda functions for GuardDuty, IAM Access Analyzer, and Macie to call each service's public API to retrieve high-severity findings. Use Amazon Simple Notification Service (Amazon SNS) to send the email alerts. Create an Amazon EventBridge rule to invoke the functions on a schedule.

B. Create an Amazon EventBridge rule with a pattern that matches Security Hub findings events with high severity.

Configure the rule to send the findings to a target Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the desired email addresses to the SNS topic.

C. Create an Amazon EventBridge rule with a pattern that matches AWS Control Tower events with high severity. Configure the rule to send the findings to a target Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the desired email addresses to the SNS topic.

D. Host an application on Amazon EC2 to call the GuardDuty, IAM Access Analyzer, and Macie APIs. Within the application, use the Amazon Simple Notification Service (Amazon SNS) API to retrieve high-severity findings and to send the findings to an SNS topic. Subscribe the desired email addresses to the SNS topic.

▼ 中文:

一家公司的一名安全工程师希望在 Amazon GuardDuty、AWS Identity and Access Management Access Analyzer 或 Amazon Macie 生成高严重性安全发现时收到电子邮件警报。该公司使用 AWS Control Tower 来管理其所有账户。公司还使用 AWS Security Hub，并启用了所有 AWS 服务集成。

哪种解决方案能够以最少的运营开销满足这些需求？

A. 为 GuardDuty、IAM Access Analyzer 和 Macie 设置单独的 AWS Lambda 函数，以调用每个服务的公共 API 来检索高严重性发现。使用 Amazon Simple Notification Service (Amazon SNS) 发送电子邮件警报。创建一个 Amazon EventBridge 规则以按计划调用这些函数。

B. 创建一个 Amazon EventBridge 规则，其模式与具有高严重性的 Security Hub 发现事件匹配。将规则配置为将发现发送到目标 Amazon Simple Notification Service (Amazon SNS) 主题。将所需的电子邮件地址订阅到 SNS 主题。

C. 创建一个 Amazon EventBridge 规则，其模式与具有高严重性的 AWS Control Tower 事件匹配。将规则配置为将发现发送到目标 Amazon Simple Notification Service (Amazon SNS) 主题。将所需的电子邮件地址订阅到 SNS 主题。

D. 在 Amazon EC2 上托管一个应用程序，以调用 GuardDuty、IAM Access Analyzer 和 Macie 的 API。在应用程序中，使用 Amazon Simple Notification Service (Amazon SNS) API 来检索高严重性发现，并将发现发送到 SNS 主题。将所需的电子邮件地址订阅到 SNS 主题。

▼ 答案:

B

题目分析与解答

1. 考察的知识点

Amazon EventBridge规则的使用
AWS Security Hub的集成与事件处理
Amazon SNS的通知功能
如何实现高效的安全事件监控和告警

2. 选项分析

A:

B (100%)

错误:设置单独的Lambda函数并调用每个服务的API增加了额外的复杂性和运维开销。

错误:需要手动管理多个Lambda函数和EventBridge规则，违背了“最少运维开销”的要求。

B:

正确:直接使用Amazon EventBridge规则匹配Security Hub的高严重性发现事件，简化了流程。

正确:通过SNS发送通知，订阅邮箱即可接收告警，符合“最少运维开销”的要求。

C:

错误:AWS Control Tower主要用于账户治理，而不是直接处理安全事件。

错误:匹配Control Tower事件无法满足题目要求的“高严重性安全发现”条件。

D:

错误:托管EC2实例运行应用程序增加了运维开销和成本。

错误:需要手动管理应用程序和API调用，违背了“最少运维开销”的要求。

▼ 100

▼ 英文:

A company hosts an application on Amazon EC2 instances. The application also uses Amazon S3 and Amazon Simple QueueService (Amazon SQS). The application is behind an Application Load Balancer (ALB) and scales with AWS Auto Scaling.

The company's security policy requires the use of least privilege access, which has been applied to all existing AWS resources.

A security engineer needs to implement private connectivity to AWS services.

Which combination of steps should the security engineer take to meet this requirement? (Choose three.)

A. Use an interface VPC endpoint for Amazon SQS.

B. Configure a connection to Amazon S3 through AWS Transit Gateway.

C. Use a gateway VPC endpoint for Amazon S3.

D. Modify the IAM role applied to the EC2 instances in the Auto Scaling group to allow outbound traffic to the interface endpoints.

E. Modify the endpoint policies on all VPC endpoints. Specify the SQS and S3 resources that the application uses.

F. Configure a connection to Amazon S3 through AWS Firewall Manager.

▼ 中文:

一家公司在 Amazon EC2 实例上托管了一个应用程序。该应用程序还使用了 Amazon S3 和 Amazon Simple Queue Service

(Amazon SQS)。应用程序位于 Application Load Balancer (ALB) 后面，并通过 AWS Auto Scaling 进行扩展。该公司的安全策略要求使用最小权限访问，并已应用于所有现有的 AWS 资源。一名安全工程师需要实现与 AWS 服务的私有连接。安全工程师应采取哪些步骤来满足此要求?(选择三个)

A. 使用 Amazon SQS 的接口 VPC 端点。

B. 通过 AWS Transit Gateway 配置与 Amazon S3 的连接。

C. 使用 Amazon S3 的网关 VPC 端点。

D. 修改应用于 Auto Scaling 组中 EC2 实例的 IAM 角色，以允许对接口端点的出站流量。

E. 修改所有 VPC 端点上的端点策略。指定应用程序使用的 SQS 和 S3 资源。

F. 通过 AWS Firewall Manager 配置与 Amazon S3 的连接。

▼ 答案:

ACE

1. 考察的知识点

VPC端点的类型和使用场景(接口端点和网关端点)。

IAM角色的权限管理与最小权限原则。

端点策略的配置与资源访问控制。

2. 选项分析

A. Use an interface VPC endpoint for Amazon SQS.

正确。Amazon SQS需要使用接口VPC端点来实现私有连接，因为SQS是一个支持接口端点的服务。

B. Configure a connection to Amazon S3 through AWS Transit Gateway.

错误。AWS Transit Gateway主要用于连接多个VPC或本地网络，而不是用于直接连接到AWS服务。Amazon S3的私有连接应该使用网关VPC端点。

C. Use a gateway VPC endpoint for Amazon S3.

正确。Amazon S3需要使用网关VPC端点来实现私有连接，因为S3是一个支持网关端点的服务。

D. Modify the IAM role applied to the EC2 instances in the Auto Scaling group to allow outbound traffic to the interface endpoints.

错误。IAM角色的权限管理是针对资源访问的，而不是直接控制网络流量。允许出站流量应该通过安全组或路由表来

实现，而不是通过IAM角色。

E. Modify the endpoint policies on all VPC endpoints. Specify the SQS and S3 resources that the application uses.

正确。端点策略可以限制通过VPC端点访问的资源，从而实现最小权限原则。

F. Configure a connection to Amazon S3 through AWS Firewall Manager.

错误。AWS Firewall Manager用于集中管理防火墙规则，而不是用于配置与Amazon S3的私有连接。